Vakzóna.

ELEMZÉS • MI ÉS ADATVÉDELEM



1 / 20

a megoldás és adatkör párosok közül ennyi vállalható feltétel nélkül: helyben futtatott modell üzleti titokra, saját szerveren. 13 csak feltételekkel, 6 egyáltalán nem.

ELEMZÉS · 2026. OKTÓBER 31.

Odaadjuk, de mi lesz vele?

Mit vállalnak az MI-szolgáltatók az átadott adatokról, hol szivároghat az adat, mit vár el a jog, és mit tehet egy szervezet, ha baj van – adatkörönkénti döntési javaslattal, tíz szolgáltató nyilvános feltételei alapján.

SZERZŐ	DÁTUM	VERZIÓ	ONLINE
Vakzóna	2026. október 31.	1.0	vakzona.com/elemzesek/mi-adatvedelmi-garanciak

TARTALOM

Odaadjuk, de mi lesz vele?

—	Összefoglaló	03
—	Alapok: miről van szó?	05
01	Vezetői összefoglaló	09
02	Bevezetés, cél és vizsgálati keretek	13
03	A szolgáltatói vállalások jelenlegi állapota	18
04	Adatszivárgási kockázatok	24
05	Jogi elvárások és várható változások	29
06	Vállalási hiányok és minimum-követelmények	36
07	Jogérvényesítés incidens esetén	42
08	A konstrukciók értékelése adatkörönként	47
09	Következtetések és döntési javaslat	54
M	Fogalmak és rövidítések (1. sz. melléklet)	65
M	Kockázat-katalógus (2. sz. melléklet)	77
M	Vállalási hiány-elemzés (3. sz. melléklet)	80
M	Minimum-követelmény-katalógus (4. sz. melléklet)	85
M	Forrásanyagok	90

Kiadja: Vakzóna · vakzona.com

Online változat: vakzona.com/elemzesek/mi-adatvedelmi-garanciak

Verzió: 1.0 · **Dátum:** 2026. október 31.

Ez a dokumentum a vakzona.com oldalon megjelent elemzés letölthető változata. A forrásokra mutató linkek a PDF-ben is kattinthatók.

Röviden

ÖSSZEFOGLALÓ

- **Üzleti szinten a nagyok nem tanítanak az adatunkkal.** Az OpenAI, az Anthropic, a Google, a Microsoft és az AWS üzleti ajánlatainál közös alapszint, hogy az ügyféltartalommal nem tanítanak modellt, adatfeldolgozóként járnak el, titkosítanak, és független tanúsítvánnyal rendelkeznek. A fogyasztói és ingyenes szint feltételei viszont fejlesztési felhasználást is engedhetnek.
- **A vállalások fele nem szerződésben áll.** A 190 vizsgált szolgáltatói vállalásból 96 súgóoldalon vagy termékdokumentációban szerepel, például a megőrzést kizáró ZDR és a feldolgozási hely egy része. Hogy ezek a konkrét szerződésben is kötik-e a szolgáltatót, nyilvános forrásból nem állapítható meg.
- **Ha baj van, kevés a szerződéses fedezet.** Adatvédelmi incidensre egyik szolgáltató sem vállal kártalanítást. Az OpenAI, az Anthropic és a Mistral felelőssége az előző 12 hónap díjára korlátozott, órában mért értesítési határidőt pedig csak az Anthropic ad (48 óra).
- **A szerződés a tervezett adathasználat ellen véd.** A tanítás, a megőrzés és az alfeldolgozók ügyében erős. A támadások, a hibák, az EU-n kívüli feldolgozás, a külföldi hatósági hozzáférés és a nem engedélyezett eszközhasználat ellen alig vagy egyáltalán nem.
- **A kitettség a szervezetnél marad.** Az érintettel szemben adatkezelőként a szolgáltatóért is felel, az uniós bíróság pedig a bizonyítási terhet is rá rakja. A hatósági bírság nem kártérítés.
- **Feltétel nélkül szinte semmi sem vállalható.** Öt megoldás és négy adatkör 20 párosából egy GO, 13 feltételes GO és 6 NO-GO. Fogyasztói szolgáltatásba egyik adatkör sem való, banktitok a nagy szolgáltatókhoz sem.
- **A védelem a szerződéskötéskor dől el.** A szolgáltatói hozzáférés szűkítését, a külföldi hatósági megkeresések jelentését, az auditjogot, a tartalék adattovábbítási jogalapot és az órában mért értesítést a szerződésbe kell emelni.

SZÁMOKBAN

96 / 190
SZOLGÁLTATÓI VÁLLALÁS CSAK SÚGÓBAN VAGY DOKUMENTÁCIÓBAN ÁLL, NEM SZERZŐDÉSBEN

12 hónap
DÍJA A FELELŐSSÉG PLAFONJA AZ OPENAI-NÁL, AZ ANTHROPICNÁL ÉS A MISTRALNÁL

48 óra
ÓRÁBAN MÉRT INCIDENS-ÉRTESÍTÉS, EGYEDÜL AZ ANTHROPICNÁL

10
VIZSGÁLT SZOLGÁLTATÓ

Ez a dokumentum a Vakzóna „Odaadjuk, de mi lesz vele?” című elemzésének teljes változata. Kilenc fejezetben vizsgálja, mit vállalnak ma az MI-szolgáltatók az átadott adatokról, hol szivároghat az adat, mit vár el a jog és mi várható, mit lehet tenni incidens esetén, és adatkörönként mely konstrukció vállalható. A szögletes zárójeles kódok (például [GDPR]) a Forrásanyagok melléklet tételeire utalnak, a KOC-, HIA-, MIN- és KON-azonosítók a kockázatokat, a vállalási hiányokat, a minimum-követelményeket és a konstrukciókat jelölik (lásd a mellékleteket). A tanulmány a 2026. október 28–29-i forrásállapotot tükrözi, szakértői értékelés, jogi tanácsadásnak nem minősül.

BEVEZETŐ

Alapok: miről van szó?

Miért fontos ez most?

Tegyük fel, hogy egy munkatárs egy hosszú szerződést másol be egy MI-csevegőbe, hogy az összefoglalja. Pár másodperc alatt kész a válasz. Közben az a szöveg kikerült a munkatárs gépéről, és egy szolgáltató rendszerébe került. Onnantól nem a szervezet dönti el, hol tárolják, ki látja, és mire használják.

Ez a helyzet minden olyan szervezetnél előáll, amely felhőben futó, nagy nyelvi modelleken (LLM) alapuló MI-szolgáltatást vesz igénybe. Ugyanez igaz arra a magánemberre is, aki személyes vagy munkahelyi adatot ír be egy ilyen szolgáltatásba. Felmerül, hogy az átadott adat kiszivároghat-e, jogosulatlan felhasználásra kerülhet-e, például modelltanításra, és mi a teendő, ha mégis baj történik.

A kérdés most azért időszerű, mert a szolgáltatók vállalásai eltérnek egymástól, a szabályozás pedig változik. Az elemzés 147 hivatalos, nyilvános forrásra épül, és öt kérdést vizsgál. Mit vállalnak ma a szolgáltatók? Mi elég és mi kevés a jogi elvárásokhoz képest? Mi várható a szabályozásban? Minek kellene elvárhatónak lennie? Incidens esetén milyen jogérvényesítési utak vannak? A végén döntési javaslat áll: melyik megoldás vállalható, és milyen adatra.

Fontos korlát, hogy az elemzés szakértői értékelés, nem jogi tanácsadás, és egy konkrét ajánlat szerződéses átvilágítását nem helyettesíti.

Néhány fogalom, amit érdemes tisztázni

Adatkezelő és adatfeldolgozó. Az adatkezelő az, aki a személyes adatok kezelésének céljait és eszközeit meghatározza. Az adatfeldolgozó az, aki az adatkezelő nevében, annak írásbeli utasításai alapján kezeli az adatot [GDPR]. Ha egy szervezet MI-szolgáltatást vesz igénybe, ő az adatkezelő, a szolgáltató pedig az adatfeldolgozó. Az elemzés szerint a szervezet adatkezelő marad akkor is, ha a szolgáltató adatfeldolgozóként jár el (2.3).

DPA (adatfeldolgozói szerződés). Az adatkezelő és az adatfeldolgozó közötti szerződés vagy szerződésmelléklet (angolul data processing agreement). A GDPR 28. cikke szabja meg a minimumtartalmát: utasítás szerinti kezelés, alfeldolgozók, audit, törlés és visszaadás, biztonság, incidens-értesítés [GDPR].

Alfeldolgozó. Az adatfeldolgozó által igénybe vett további adatfeldolgozó. Például a szolgáltató egy analitikai vagy tárhelyszolgáltatót is bevonhat. Ehhez az adatkezelő felhatalmazása kell, és általános felhatalmazásnál is tájékoztatni kell a változásokról [GDPR]. Dokumentált eset, hogy egy harmadik fél analitikai szolgáltatónál történt behatolás ügyfélazonosítókat és analitikai adatot érintett, tartalmat nem [OAI-INC-MIXPANEL].

Fogyasztói és üzleti szint. Ugyanaz a márka két, jogilag eltérő feltételrendszer alatt érhető el. Üzleti szinten a nagy szolgáltatók szerződésben vagy dokumentációban vállalják, hogy az ügyféltartalmat nem használják modelltanításra [OAI-SA] [ANT-CT]. A fogyasztói vagy ingyenes szinten viszont a fejlesztési felhasználás lehet az alapértelmezés, és a kilépés a felhasználó beállításán múlik [OAI-TOU-F] [ANT-CONSUMER-F] [GOOG-GEMINI-API].

Modelltanítás. Az a folyamat, amelyben a szolgáltató a beküldött tartalmat a modell továbbfejlesztésére használja. Ha az adat bekerül a tanításba, a modell később az érzékeny információt felfedheti. Ezt memorizációnak nevezik, és a NIST már megfigyelt ilyet [NIST-600-1].

Adatmegőrzés és ZDR. A szolgáltatók a beküldött adatot egy ideig megőrzik. A közös kiindulópont a 30 nap az OpenAI, az Anthropic és a Mistral API-jánál [OAI-DATA-CTRL] [ANT-RETENTION] [MIS-PRIVACY]. A zero data retention (ZDR) azt jelenti, hogy a szolgáltató az ügyféltartalmat egyáltalán nem őrzi meg. Nem alapértelmezés: az OpenAI-nál előzetes jóváhagyáshoz kötött [OAI-DATA-CTRL], az Anthropicnál jóváhagyással érhető el [ANT-ZDR], a Mistralnál csak az állapotmentes API-hívásokra szól [MIS-ZDR].

Feldolgozási hely, EU-régió, flex routing. Nem mindegy, hol dolgozzák fel az adatot. Az EU-régió azt jelenti, hogy a szolgáltatás szerverei az Unióban vannak. A flex routing a Microsoft 365 Copilot funkciója, amellyel csúcsidőszakban a feldolgozás az EU Data Boundary-n, vagyis az uniós adathatáron kívül is történhet. A 2026. március 25. után létrehozott jogosult bérlőknél alapértelmezésben be van kapcsolva [MSFT-M365-FLEX].

SCC és DPF. Az Unión kívülre, például az Egyesült Államokba csak megfelelő jogalappal szabad személyes adatot továbbítani. Két gyakori jogalap van. Az SCC a standard szerződéses kikötések (angolul Standard Contractual Clauses) [SCC]. A DPF az EU–USA adatvédelmi keret (Data Privacy Framework): eszerint az Egyesült Államok megfelelő védelmet biztosít a keretben részt vevő szervezeteknek [EU-US-DPF]. A DPF jogalapja nem végleges, mert a Törvényszék 2025. szeptember 3-án fenntartotta [EUB-T553-23], de a fellebbezés folyamatban van [EUB-C703-25P].

Prompt injection. Támadás, amelynél a támadó utasítást juttat a modell bemenetére. Az indirekt változatnál olyan adatba rejti az utasítást, amelyet az alkalmazás valószínűleg előhív. Így védett adat lopható el [NIST-600-1] [OWASP-LLM]. Dokumentált példa a Microsoft 365 Copilot CVE-2025-32711 sérülékenysége, amelyet a Microsoft szerint elhárítottak, és kihasználását nem jelezték [MSRC-CVE-2025-32711].

A négy adatkör. Az elemzés nem az adatot általában, hanem négy kört értékel külön, mert a jogi követelmények eltérnek. A személyes adat (a különleges kategóriákat, például az egészségügyi adatot is beleértve) a GDPR hatálya alá esik. Az üzleti titok védelme feltételezi, hogy a jogosult az elvárható magatartást tanúsítja [UZLETI-TITOK-TV]. A hivatásbeli titok az ügyvédi, orvosi és banktitkot

jelenti, és külön szabályok védik [UTTV] [EUAK] [HPT]. A közszféra- és minősített adatnál az engedélyezési feltételek a legszigorúbbak: minősített adatot csak a Nemzeti Biztonsági Felügyelet engedélye alapján lehet kezelni [MAVTV].

Az öt konstrukció. Az elemzés az MI-igénybevétel öt típusát hasonlítja össze. Az első a fogyasztói szolgáltatás. A második a közvetlen üzleti szolgáltatás ZDR-rel (API és üzleti alkalmazás, például OpenAI vagy Anthropic). A harmadik a hyperscaler-platform EU-régióval, vagyis egy nagy felhőszolgáltató platformja, amelyen modellek is elérhetők (Azure OpenAI és AI Foundry, AWS Bedrock, Google Vertex AI). A negyedik az EU-s szuverén felhő (OVHcloud, STACKIT, IONOS, Aleph Alpha). Az ötödik a helyben futtatott nyílt súlyú modell: olyan modell, amelynek paramétereit a kiadó nyilvánossá teszi, ezért a szervezet a saját infrastruktúráján futtathatja.

GO, feltételes GO, NO-GO. Az elemzés végén minden konstrukció és adatkör párosra egy döntési javaslat áll. A GO azt jelenti, hogy vállalható. A NO-GO azt, hogy nem. A feltételes GO nem azt jelenti, hogy ma vállalható, hanem azt, hogy a megjelölt követelmények teljesítése esetén az lesz (1. fejezet).

Hogyan utazik az adat?

Az út lépésenként a következő.

1. **Átadás.** A felhasználó beírja vagy feltölti az adatot. A szolgáltatás szintje (fogyasztói vagy üzleti) már ekkor meghatározza, mire használhatják.
2. **Továbbítás és feldolgozás.** Az adat titkosítva kerül a szolgáltatóhoz. Az alapszint az AES-256 nyugalmi és a TLS 1.2 vagy újabb továbbítási titkosítás, ezt az OpenAI és az Anthropic kifejezetten vállalja [OAI-BDP] [ANT-DPA]. Hogy hol dolgozzák fel, az szolgáltatótól és beállítástól függ.
3. **Alfeldolgozók.** A szolgáltató további szolgáltatókat vonhat be. A kifogási idő az Anthropicnál 15, az OpenAI-nál 30, a Mistralnál 10, a Googlenél 90 nap, a kifogás következménye többnyire a felmondás [ANT-DPA] [OAI-DPA] [MIS-DPA] [GCP-DPA].
4. **Megőrzés és visszaélés-figyelés.** A szolgáltató egy ideig megőrzi az adatot, és vizsgálja, hogy a szolgáltatást nem használják-e szabálysértően. A jelölt tartalom tovább marad meg: az Anthropic a szabálysértőnek jelölt beszélgetések bemenetét és kimenetét legfeljebb 2 évig, a besorolási pontszámokat legfeljebb 7 évig őrzi [ANT-RETENTION].
5. **Törlés.** A szerződés megszűnése után a törlési idő szolgáltatónként eltér: 30 nap az OpenAI-nál és az Anthropicnál, 90 nap az AWS-nél, legfeljebb 180 nap a Googlenél [OAI-SA] [ANT-DPA] [AWS-DPA] [GCP-DPA].
6. **Ha baj történik.** A szerződésekben az incidens-értesítés „indokolatlan késedelem nélkül” szól. Órában mért határidőt egyedül az Anthropic nevesít, 48 órát [ANT-DPA]. Az adatkezelő szervezetet közben a GDPR szerinti 72 órás bejelentési határidő terheli [GDPR].

A szerződés a szolgáltató tervezett adathasználata ellen, vagyis a tanítás, a megőrzés és az alfeldolgozók esetében véd a legjobban. A váratlan hibák, a támadások, a joghatósági kockázatok és a szervezeti viselkedés ellen alig vagy egyáltalán nem (4.6).

Amit könnyű összekeverni

„Nem tanítanak az adatommal" nem azonos azzal, hogy „nem tárolják, és senki nem látja". A tanítási tilalom azt rögzíti, hogy az ügyféltartalmat nem használják modelltanításra. Az adat ettől még megmaradhat: a közös kiindulópont a 30 napos megőrzés [OAI-DATA-CTRL] [ANT-RETENTION]. Emberi felülvizsgálat is lehetséges. Az OpenAI Safety Retention módjában a jelölt tartalom emberi felülvizsgálat alá kerülhet [OAI-DATA-CTRL], a gyermekek szexuális bántalmazását ábrázolónak (CSAM) gyanított képek pedig ZDR mellett is kézi felülvizsgálatra megmaradnak [OAI-DATA-CTRL]. A ZDR-nek tehát szintén vannak kivételei.

A súgóoldali vállalás nem szerződéses vállalás. A 190 szolgáltatói megállapításból 96 nem szerződéses dokumentumra (súgó, marketing, termékdokumentáció, közlemény) épül. A felsorolt ZDR-vállalások mind súgóoldalakon állnak (3.3). Hogy ezek a konkrét szerződés részeként is kötik-e a szolgáltatót, a forrásokból nem állapítható meg. Az elemzésben a † jel jelzi, ha egy állítás csak ilyen forrásra épül.

Az „n. a." nem azt jelenti, hogy „nem vállalja". Az n. a. forráshiányt jelez: a szerződéses szöveg nincs a forráskészletben, ezért a vállalás nyilvános forrásból nem állapítható meg. A négy európai szolgáltató (Aleph Alpha, OVHcloud, STACKIT, IONOS) 72 vállalási hiány-cellájából 50 ilyen. Ez nem azt jelenti, hogy kevesebbet vállalnak, csak azt, hogy a vállalás nem ellenőrizhető (2.5).

A szolgáltató felelőssége nem azonos a szervezet felelősségével az érintettel szemben. Az érintett felé az adatkezelő szervezet felel, a nevében eljáró adatfeldolgozó adatkezeléséért is [EUB-C683-21]. A szolgáltató az érintettnek szűkebben felel: csak az őt kifejezetten terhelő kötelezettségek megsértéséért vagy az utasítások figyelmen kívül hagyásáért [GDPR]. A szervezet tehát akkor is felelhet az érintettnek, ha a szolgáltatóval szemben csak korlátozott igénye van. Az OpenAI, az Anthropic és a Mistral felelőssége például az esemény előtti 12 hónapban fizetett díjra korlátozott [OAI-SA] [ANT-CT] [MIS-CT], adatvédelmi kártalanítást pedig egyik szolgáltató sem vállal (7.1, 7.2).

A bírság nem kártérítés. A hatósági bírság az érintettnek vagy a megrendelőnek közvetlenül nem jár. Az Európai Unió Bírósága a GDPR 82. cikke szerinti kártérítést kompenzációs, a 83. és 84. cikk szerinti bírságot és szankciót büntető célúnak tekinti [EUB-C667-21]. Például a Garante 15 millió euró bírságot szabott ki az OpenAI-ra, de a határozatot később megsemmisítették, hatáskör hiányában, az érdemi kérdésekről a bíróság nem döntött [GARANTE-OPENAI] [TRIB-ROMA-4153-26].

→ A részletes elemzés az 1. fejezettől következik.

01

01. FEJEZET

Vezetői összefoglaló

Ez a tanulmány az MI-szolgáltatásokat igénybe vevő szervezet nézőpontjából vizsgálja, hogyan biztosítható, hogy az MI-szolgáltatónak (elsősorban a felhőben futó, nagy nyelvi modelleken alapuló szolgáltatásnak) átadott adat ne szivárogjon ki és ne kerüljön jogosulatlan felhasználásra, például modelltanításra, és mit lehet tenni, ha mégis baj történik. A döntési kérdés: **mely szolgáltatói és szerződéses-technikai konstrukció mellett vállalható az MI-feldolgozás, és adatkörönként milyen feltételekkel.** A szervezet az MI-szolgáltatás igénybevevőjeként adatkezelő marad akkor is, ha a szolgáltató adatfeldolgozóként jár el, ezért a kitettség nála keletkezik (2.3). A válasz kizárólag nyilvános, hivatalos forrásokra épül: 147 forrásból 558 megállapítás készült (2.4). A tanulmány szakértői értékelés, jogi tanácsadásnak nem minősül, és a konkrét ajánlat átvilágítását nem helyettesíti.

A következtetési lánc öt lépésből áll.

- **Mit vállalnak ma a szolgáltatók** (3. és 6. fejezet). Az üzleti ajánlatoknál a nagy szolgáltatók alapszintje közös: a beküldött adatokkal nem tanítanak modellt, adatfeldolgozóként járnak el, az alfeldolgozókra kifogást lehet emelni, titkosítanak, és független tanúsítvánnyal vagy auditjelentéssel rendelkeznek (3.2). A tanítási tilalom tehát üzleti szinten általános. Más vállalások már feltételhez kötöttek: az adatok megőrzését kizáró zero data retention (ZDR) opció jóváhagyást kíván, és jellemzően nem a szerződésben, hanem súgóoldalon áll (3.3). A felelősség az OpenAI, az Anthropic és a Mistral esetében 12 havi díjra korlátozott, adatvédelmi kártalanítást egyik szolgáltató sem vállal, órában mért incidens-értesítési határidőt pedig csak az Anthropic (48 óra). A 190 szolgáltatói megállapításból 96 csak dokumentációra épül, nem szerződésre, ezért a kötőerejük a szerződés ismerete nélkül nem állapítható meg. A fogyasztói és ingyenes szolgáltatások feltételei az üzletiekétől eltérnek, és fejlesztési felhasználást is engedhetnek (3.4).
- **Mi elég és mi kevés** (6. fejezet). A tanítási tilalom, a feldolgozói szerep, a törlés és az alapszintű titkosítás szerződéses szinten több szolgáltatónál rendben van. A tanulmány 18 vállalási hiányt azonosított, és egyiknek az összesített értékelése sem elégséges. A legsúlyosabbak a felelősségkorlát, az adatvédelmi kártalanítás hiánya, az órában nem rögzített incidens-értesítési határidő és a nem szerződéses vállalások bizonytalan kötőereje (6.2, 6.7).
- **Hol szivároghat az adat** (4. fejezet). 19 kockázatot azonosítottunk, közülük hét a legsúlyosabb: a fogyasztói szolgáltatások használata, az EU-n kívüli feldolgozás, a prompt injection (a modell bemenetébe csempészett támadó utasítás), az ügyfelek közötti elkülönítés hibája, az alfeldolgozói lánc, a harmadik országbeli hatóságok hozzáférése és a nem jóváhagyott eszközök használata a

szervezeten belül (4.6). A szerződés a szolgáltató tervezett adathasználata ellen, vagyis a tanítás, a megőrzés és az alfeldolgozók esetében véd a legjobban. A váratlan hibák, a támadások, a joghatósági kockázatok és a szervezeti viselkedés ellen alig vagy egyáltalán nem.

- **Mit vár el a jog, és mi várható** (5. fejezet). A közös alap a GDPR 28. cikke szerinti szerződés, a 32. cikk szerinti biztonság, az indokolatlan késedelem nélküli incidens-értesítés és az adattovábbítási jogalap. Hivatásbeli titoknál, közszféra-adatnál és minősített adatnál szigorúbb szabályok állnak (5.6). A szabályozás változik, de a forrásokban nincs olyan hatályos vagy közelgő kötelező változás, amely a legsúlyosabb szerződéses hiányokat közvetlenül megszüntetné, ezért ezek kezelése az ügyfél szerződéses és beszerzési feltételein múlik (6.6). Az EU–USA adattovábbítási keret jogalapja a folyamatban lévő fellebbezés miatt bizonytalan (7.5).
- **Érvényesíthetők-e a jogok** (7. fejezet). Elvben igen, gyakorlatban korlátozottan. Az érintett kártérítési igénye érvényesíthető, és az uniós bírósági gyakorlat a bizonyítási teher szempontjából az érintettnek kedvező. A kitettség viszont a szervezetnél van, mert adatkezelőként a nevében eljáró adatfeldolgozóért is felel. A szerződéses utat a 12 havi díjplafon és a kártalanítás hiánya szűkíti, a hatósági út bírságot adhat, de kártérítést nem, harmadik országbeli szolgáltatónál pedig a jogalap és a joghatóság bizonytalan (7.6). A védelmet ezért a szerződéskötéskor kell kialakítani.

Döntési javaslat (9. fejezet). Szervezeti szinten a javaslat **feltételes GO**: az MI-feldolgozás vállalható, de nem a mai állapotban és nem minden konstrukcióval. A feltételes GO nem azt jelenti, hogy a konstrukció ma vállalható, hanem azt, hogy a megjelölt követelmények teljesítése esetén az lesz. A javaslat öt konstrukcióra és négy adatkörre szól, a minősített adatot külön kezelve. A 20 cellából egy GO, 13 feltételes GO és hat NO-GO, vagyis feltétel nélkül szinte semmi sem vállalható (8.9).

- **NO-GO** a fogyasztói szolgáltatásokra minden adatkörben, mert a feltételeik fejlesztési felhasználást és emberi felülvizsgálatot engednek. NO-GO a banktitokra a közvetlen üzleti szolgáltatások és a hyperscaler-platformok mellett, mert a felügyeleti ellenőrzési jogot egyik szolgáltató sem vállalja. NO-GO a minősített adatra minden külső konstrukciónál, de ez következtetés, nem kifejezett tilalom: a jogszabályi forrás az MI-használatot minősített adatra kifejezetten nem tiltja, csak egyik szolgáltató sem vállalja a kezeléséhez szükséges három feltételt.
- **GO** egyetlen esetben van: helyben futtatott modell üzleti titokra, saját szerveren, az alapkontrollokkal. Bérelt infrastruktúrán ez is feltételes GO.
- **Feltételes GO** a többi cellára. A közvetlen üzleti szolgáltatásoknál és a hyperscaler-platformoknál a kulcsfeltételeket a szerződésbe kell emelni: a szolgáltató munkatársainak hozzáférését szűk, felsorolt esetekre, a harmadik országbeli hatósági megkeresések jelentését, az információadást és az auditjogot, az adattovábbítási jogalapot és annak tartalék jogalapját, valamint az órában mért incidens-értesítési határidőt (adatkörtől függően eltérő körben). Szervezeti oldalon adatosztályozás alapján történő engedélyezés, hatásvizsgálat és kilépési terv szükséges. A helyben futtatott modell az üzleti titok saját szerveren futtatott esetét kivéve minden adatkörben feltételes GO, a minősített adatnál forráshiánnyal. Az EU-s szuverén felhő minden adatkörben feltételes GO, de forráshiánnyal, mert a négy EU-s szolgáltató 72 hiánycellájából 50-nél a szerződéses szöveg nincs a forráskészletben (6.4, 8.8).

A tanulmány egyetlen konstrukciót nem jelöl ki mindenre. A helyben futtatott modell feltételrendszere a legkedvezőbb, de a kockázatot a szervezetre telepíti, a szükséges kapacitásról és költségről pedig a forráskészlet nem szól. A külső szolgáltatós konstrukciók az üzemeltetési terhet átveszik, de a szerződéses hiányokat a szerződésben kell pótolni.

Az alábbi táblázat a döntési javaslatot összegzi. A hivatásbeli titok oszlopában a legszigorúbb alkategória, a banktitok szerepel. A zöld a GO, a sárga a feltételes GO, a piros a NO-GO.

Fogyasztói szolgáltatás	NO-GO	NO-GO	NO-GO	NO-GO	NO-GO
Közvetlen üzleti szolgáltatás (ZDR opcióval)	Feltételes GO	Feltételes GO	NO-GO banktitokra, feltételes GO ügyvédi és orvosi titokra	Feltételes GO	NO-GO
Hyperscaler-platform EU-régióval	Feltételes GO	Feltételes GO	NO-GO banktitokra, feltételes GO ügyvédi és orvosi titokra	Feltételes GO	NO-GO
EU-s szuverén felhő	Feltételes GO (forráshiánnyal)	Feltételes GO (forráshiánnyal)	Feltételes GO (forráshiánnyal)	Feltételes GO (forráshiánnyal)	NO-GO
Helyben futtatott modell	Feltételes GO	GO (saját szerveren)	Feltételes GO	Feltételes GO	Feltételes GO (forráshiánnyal)

A javaslat fő fenntartásai (9.4). A besorolások szakértői értékelések. Az EU-s szolgáltatók szerződéses szövegei nincsenek a forráskészletben, az OpenAI, az Anthropic és a Microsoft trust portáljának tartalma pedig nem volt elérhető, ezek ismeretében az értékelés változhat. A szolgáltatói feltételek egyoldalúan módosulhatnak: a Copilot flex routingja a 2026. március 25. után létrehozott bérlőknél alapértelmezésben be van kapcsolva, az AWS program-ZDR-je pedig 2026. december 31-ig szól. Nyitott jogi kérdés, hogy az MI-szolgáltatás kiszervezésnek minősül-e a banki szabályozás szerint. A feltételes GO a jogérvényesítési kitettséget nem szünteti meg. A javaslat a 2026. október 28–29-i forrásállapotot tükrözi. Hogy egy adott szervezetre a mátrix melyik cellája érvényes, azt az határozza meg, mely adatköröket kívánja MI-szolgáltatással feldolgozni.

Mit tegyen egy szervezet (9.5). A cél az, hogy a feltételek teljesüljenek, és a döntés a kiválasztott szolgáltató konkrét szerződéses szövegének ismeretében véglegesíthető legyen. A teendők a következők.

- A szervezet adatosztályozásának rögzítése: mely adatköröket kívánja MI-szolgáltatással feldolgozni.
- Szerződés előtti átvilágítás a kiválasztott szolgáltatónál: a teljes adatfeldolgozói szerződés, az alfeldolgozói lista, a tanúsítványok hatóköre, az auditjelentés, a ZDR-jóváhagyás és a régióbeállítások bekérése.
- A kulcsfeltételek tárgyalása, a nem szerződéses vállalások szerződéses mellékletbe emelése, valamint a felelősségkorlát és az adatvédelmi kártalanítás tárgyalása.
- A szervezeti kontrollok kialakítása: engedélyezés adatosztályozás alapján, hatásvizsgálat, költség-haszon elemzés és kilépési terv.
- A hiányzó szolgáltatói szövegek beszerzése és a helyben futtatott modell kapacitásának és költségének felmérése.
- A nyitott jogi kérdések tisztázása jogi szakemberrel, az incidens-felkészülés kialakítása és az éves felülvizsgálat.

02

02. FEJEZET

Bevezetés, cél és vizsgálati keretek

Ez a fejezet rögzíti, miért készült a tanulmány, mire keres választ, kinek a nézőpontjából, milyen módszerrel és milyen korlátok között. A fejezet új tényállítást nem tartalmaz, a számok és a megállapítások a 3–8. fejezetből és a mellékletekből származnak.

2.1. Háttér és cél

Az MI-alapú, elsősorban a felhőben futó, nagy nyelvi modelleken (LLM) alapuló szolgáltatások használatakor a szervezet adatot ad át a szolgáltatónak. Az adat így kikerül a szervezet közvetlen ellenőrzése alól. Felmerül, hogy az átadott adat kiszivároghat-e, jogosulatlan felhasználásra kerülhet-e (például modelltanításra), és ha mégis baj történik, milyen jogérvényesítési lehetőségek állnak rendelkezésre.

A kérdés ma azért időszerű, mert a szolgáltatók vállalásai eltérnek egymástól, a szabályozás pedig átalakulóban van. Az AI Act ütemezése, a NIS2, a Data Act és az EU–USA adattovábbítási keret bizonytalansága egyaránt érinti a választ (5. fejezet).

A tanulmány döntési kérdése: mely **szolgáltatói és szerződéses-technikai konstrukció** mellett vállalható az MI-feldolgozás, és **adatkörönként** milyen feltételekkel. Ez a GO/NO-GO döntés tárgya.

A tanulmány a döntést előkészíti, és döntési javaslatot is ad: a GO/NO-GO javaslatot a 9. fejezet (Következtetések és döntési javaslat) tartalmazza. A cél az, hogy az MI-szolgáltatás bevezetéséről döntő szervezet forráshoz kötött, ellenőrizhető alapra támaszkodhasson: mit vállalnak ma a szolgáltatók, mi elég és mi kevés, minek kellene elvárhatónak lennie, és incidens esetén milyen jogérvényesítési utak állnak nyitva.

2.2. Vizsgálati kérdések

A tanulmány **öt vizsgálati kérdésre** keres választ. Mindegyikre egy vagy több fejezet válaszol.

- **Szolgáltatói vállalások.** Milyen szerződéses (ÁSZF, DPA, enterprise feltételek), technikai (adatmegőrzés, ZDR, titkosítás, a feldolgozás helye) és tanúsítási (például ISO 27001, SOC 2) vállalásokat tesznek ma a szolgáltatók? Erre a 3. fejezet válaszol.

- **Elégségesség.** Mi elég és mi kevés a jogszabályi elvárások (GDPR, titokvédelem) és a kockázatok alapján? A 4. fejezet a kockázatokat írja le, az 5. fejezet a jogi hátteret rögzíti, a 6. fejezet a vállalások elégségességét értékeli.
- **Várható változások.** Mi várható a szabályozásban és a piaci gyakorlatban (AI Act, Data Act, NIS2, EU–USA adattovábbítási keret)? Az 5. fejezet válaszol.
- **Normatív elvárás.** Minek kellene elvárhatónak lennie a szolgáltatókkal szemben? A 6. fejezet minimum-követelményei adják a választ.
- **Jogérvényesítés.** Incidens esetén milyen utak vannak (szerződéses igények, felelősségkorlátozás, joghatóság és alkalmazandó jog, GDPR 82. cikk szerinti kártérítés, hatósági panasz), és ezek mennyire hatékonyak? A 7. fejezet válaszol.

Az öt kérdés válaszai a döntési kérdéshez vezetnek. A konstrukciók adatkörönkénti értékelését a 8. fejezet adja, a döntési javaslatot a 9. fejezet.

2.3. Nézőpont és hatókör

A tanulmány az MI-szolgáltatást igénybe vevő szervezet nézőpontjából készült, felhasználói és megrendelői oldalról. Bármely szervezetnek szól, amely MI-szolgáltatással adatot dolgoztatna fel, a döntést a szervezet vezetése hozza. A szervezet az MI-szolgáltatás igénybevevője, és adatkezelő marad akkor is, ha a szolgáltató adatfeldolgozóként jár el (8.1 alfejezet).

A vizsgálat **tíz szolgáltatóra** terjed ki: öt nagy MI-szolgáltatóra (OpenAI, Anthropic, Google, Microsoft, AWS) és öt európai szolgáltatóra (Mistral, Aleph Alpha, OVHcloud, STACKIT, IONOS) (3.1 alfejezet). Összevetési alternatívaként szerepel a helyben futtatott nyílt súlyú modell (Llama, Gemma, Mistral nyílt modellek, Qwen, DeepSeek). Erről szolgáltatói profil nincs, csak a licencekből és a biztonsági keretekből származó megállapítások.

A szolgáltatói kört **öt konstrukcióba** soroltuk (8.1 alfejezet): KON-01 fogyasztói SaaS, KON-02 enterprise API és üzleti szolgáltatás ZDR-rel, KON-03 hyperscaler EU-régióval, KON-04 EU szuverén felhő, KON-05 helyben futtatott nyílt súlyú modell. Az értékelés **négy adatkörre** külön készül: SZA (személyes adat, a különleges kategóriákat is beleértve), UTI (üzleti titok), HIV (hivatásbeli titok: ügyvédi, orvosi, banktitok) és KOZ (közszféra- és minősített adat) (5.4 alfejezet).

Hatókörön kívül van a szolgáltatók gyakorlati műszaki tesztelése (például behatolásteszt), a modellek szakmai minőségének és árának összehasonlítása, valamint a konkrét beszerzési eljárás lebonyolítása. A tanulmány ezekre nem tér ki.

2.4. Módszer

A tanulmány **kizárólag nyilvános, hivatalos külső forrásokra** épül, belső forrás nincs. A forráskészletet 2026. október 28–29-én töltöttük le. Összesen **153 forrás** szerepel benne, és ebből **147** forráshoz készült megállapítás. A szolgáltatói feltételek a 2026. október 28-i állapotot tükrözik (3.1 alfejezet).

A tanulmány alapegysége a megállapítás. A megállapítás egy forráshoz kötött, saját szavas összefoglaló, amelyet a forrás szó szerinti idézete igazol. Összesen **558 megállapítás** készült, 16 dimenzióban. A szövegben a szögletes zárójeles kód (például [ANT-CT]) azt a forrást jelöli, amelyből az állítás származik. A kódok feloldását, a forrás eredeti, internetes lelőhelyével együtt, a Forrásanyagok melléklet tartalmazza.

A megállapításokra négy réteg épül, egymásra hivatkozva. Először azt kérdezzük, mi szivároghat ki (KOC), azután azt, hogy a szolgáltatók ezt ma mennyire fedezik (HIA), majd azt, hogy minek kellene elvárhatónak lennie (MIN), végül azt, hogy egy konstrukció mellett ezek a követelmények teljesülnek-e (KON).

- **KOC, kockázat.** A szivárgási vektorok és gyökérokok, összesen **19** (KOC-01–KOC-19).
- **HIA, vállalási hiány.** Az, amit a szolgáltatók ma nem vállalnak a kockázatokkal szemben, összesen **18** (HIA-01–HIA-18).
- **MIN, minimum-követelmény.** Az, aminek elvárhatónak kellene lennie, összesen **30** (MIN-01–MIN-30).
- **KON, konstrukció.** Az öt konstrukció (KON-01–KON-05), amelyek értékelése a döntési mátrix KON × adatkör celláiban áll.

Minden tényállítás mögött forráskód, illetve KOC-, HIA-, MIN- vagy KON-azonosító áll. A besorolások szakértői értékelések, nem számszerű becslések és nem jogi tanácsadás. Szakértői a kockázat valószínűsége és hatása, a vállalás fokozata, a követelmény erőssége és adatkör-szintje, a maradványkockázat és a döntési mátrix cellaértéke. A fejezetek és a mellékletek ezt kifejezetten jelzik.

Két jelölést érdemes már most ismerni. A † jel azt mutatja, hogy a megállapítás vagy a cella értéke csak nem szerződéses dokumentumra (súgó, marketing, termékdokumentáció, közlemény) épül, ezért a kötőereje a szerződés ismerete nélkül nem állapítható meg. Az **n. a.** jelölés forráshiányt jelez: a szerződéses szöveg nincs a forráskészletben, ezért a vállalás nyilvános forrásból nem állapítható meg. Ez nem azonos azzal, hogy a szolgáltató nem vállal.

2.5. Korlátok

A tanulmány megállapításait az alábbi korlátok figyelembevételével kell olvasni.

- **Csak nyilvános forrás.** A tanulmány belső forrást nem használ, minden állítása nyilvánosan elérhető dokumentumon ellenőrizhető.
- **Egyedi szerződéses feltételek.** A tanulmány a szolgáltatók standard feltételeit rögzíti, a teljes ügyfélszerződés nem része a forráskészletnek (HIA-13). Az értékelés ezért a konkrét ajánlat átvilágítását nem helyettesíti. A szolgáltatói megállapítások mintegy fele nem szerződéses forrásra épül, a kötőerejük a szerződés ismerete nélkül nem állapítható meg (HIA-15).

- **Trust portálok.** Az OpenAI, az Anthropic és a Microsoft trust portáljának tartalma nyilvánosan nem volt elérhető, ezért az onnan származó tanúsítvány-, auditjelentés- és alfeldolgozói információ nincs az értékelésben (8.8 alfejezet).
- **Forráshiány az európai szolgáltatóknál.** Az Aleph Alpha, az OVHcloud, a STACKIT és az IONOS 72 vállalási hiány-cellájából **50** n. a., mert a szerződéses szöveg nincs a forráskészletben (6.4 alfejezet). Ez nem azt jelenti, hogy kevesebbet vállalnak, csak azt, hogy a vállalás nyilvános forrásból nem állapítható meg. A KON-04 minden cellája ezért feltételes besorolás (8.8 alfejezet). Magyar MI-specifikus forrás a forráskészletben nincs, a HUN-REN PULI nyelvmodelljeiről és a NISZ MIA chatbotjáról szóló nyilvános anyagok releváns tartalom hiányában megállapítást nem kaptak.
- **Időbeli érvényesség.** A tanulmány a 2026. október 28–29-i állapotot tükrözi: a szolgáltatói feltételek a 2026. október 28-i, a jogi ütemterv a 2026. október 29-i állapotot mutatja. A szolgáltatói feltételek egyoldalúan változhatnak, a tanulmány az egyoldalú módosíthatóságot nem vizsgálta, ezért kell az éves felülvizsgálat (MIN-24). A DPF jogalapját érintő C-703/25 P ügy állását a CURIA oldalán újra ellenőrizni kell (8.8 alfejezet).
- **Nem jogi tanácsadás.** A tanulmány szakértői értékelés, nem jogi tanácsadás, és egyedi jogvita kimenetelét nem jósolja meg. Nyitott jogi kérdés, hogy az MI-szolgáltatás igénybevétele kiszervezésnek minősül-e a Hpt. szerint, és hogy a tanulmány tárgyát képező használat nagy kockázatú rendszer-e az AI Act szerint (5. fejezet).

2.6. A dokumentum felépítése

A tanulmány kilenc fejezetből és öt mellékletből áll. A fejezetek a következők.

- **1. fejezet, Vezetői összefoglaló.** Rövid összefoglaló a döntés előkészítéséhez.
- **2. fejezet, Bevezetés, cél és vizsgálati keretek.** Ez a fejezet.
- **3. fejezet, A szolgáltatói vállalások jelenlegi állapota.** Az első vizsgálati kérdésre válaszol.
- **4. fejezet, Adatszivárgási kockázatok.** A 19 kockázatot (KOC) mutatja be.
- **5. fejezet, Jogi elvárások és várható változások.** A jogi hátteret és a várható változásokat rögzíti.
- **6. fejezet, Vállalási hiányok és minimum-követelmények.** Megmutatja, mi elég és mi kevés, és minek kellene elvárhatónak lennie (HIA, MIN).
- **7. fejezet, Jogérvényesítés incidens esetén.** Az érvényesíthetőség lehetőségeit és korlátait értékeli.
- **8. fejezet, A konstrukciók értékelése adatkörönként.** A konstrukciók és az adatkörök döntési mátrixát (KON × adatkör) tárgyalja.
- **9. fejezet, Következtetések és döntési javaslat.** A következtetéseket és a döntési javaslatot tartalmazza.

A mellékletek a fejezetek állításait foglalják táblázatba.

1. sz. melléklet	Fogalmak és rövidítések: a fogalmak, a rövidítések, az értékelési skálák és a jelölések.
2. sz. melléklet	Kockázatáttekintő tábla (19 KOC).
3. sz. melléklet	Hiánytábla (18 HIA).
4. sz. melléklet	Követelménytábla (30 MIN).
Forrásanyagok	A szövegben hivatkozott források az eredeti internetes lelőhellyel, hazai, uniós és nemzetközi csoportban.

Hogyan érdemes olvasni. A gyors tájékozódáshoz az 1., a 8. és a 9. fejezet a kiindulópont: az összefoglalót, a konstrukciók értékelését és a döntési javaslatot adja. A 3–7. fejezet az indoklást tartalmazza. Az állítások a szögletes zárójeles forráskódok alapján, a Forrásanyagok mellékletben megadott eredeti forráson ellenőrizhetők.

03. FEJEZET

03

A szolgáltatói vállalások jelenlegi állapota

Ez a fejezet a tanulmány első vizsgálati kérdésére válaszol: milyen szerződéses, technikai és tanúsítási vállalásokat tesznek ma a szolgáltatók. A fejezet kizárólag a **jelenlegi állapotot** rögzíti. A vállalások elégségességének megítélése, a hiányok elemzése és a döntési javaslat a 6., 8. és 9. fejezet feladata.

3.1. Mit vizsgáltunk, és hogyan

A vizsgálat **tíz szolgáltatóra** terjed ki. Öt nagy MI-szolgáltatót néztünk meg (OpenAI, Anthropic, Google, Microsoft, AWS) és öt európai szolgáltatót (Mistral, Aleph Alpha, OVHcloud, STACKIT, IONOS). A nagy szolgáltatóknál közvetlen API és üzleti alkalmazás (OpenAI, Anthropic), felhőplatformon elérhető modellek (Google, Microsoft, AWS) és termékbe épített asszisztensek (Google Workspace, Microsoft 365 Copilot) szerepelnek. Az európai körben modellszolgáltatás (OVHcloud, STACKIT, IONOS), API és üzleti alkalmazás (Mistral), valamint közigazgatási asszisztens és MI-platform (Aleph Alpha) a vizsgált ajánlat. A helyben futtatott open-weight modellek, amelyek a feladatmeghatározásban összevetési alternatívaként szerepelnek, a szolgáltatói profilok között nincsenek. A licenceikről és a biztonsági keretükről a nyílt súlyú modellekre vonatkozó biztonsági útmutatók és licencek adnak megállapításokat.

Az állítások alapja a szolgáltatói dokumentumok (a teljes vizsgálat egésze 558 megállapítás 147 forrásból és 16 dimenzió): **190 megállapítás 51 vizsgált forrásból**, mindegyik pontos idézettel igazolva. Minden megállapítás egy **dimenzióhoz** tartozik. A szolgáltatói rész tizenkét dimenziója a tanítási felhasználás, az adatmegőrzés és törlés, a visszaélés-figyelés és emberi hozzáférés, a zero data retention (ZDR), az adatfeldolgozás helye és adattovábbítás, az alfeldolgozók, a titkosítás és hozzáférés-kezelés, a tanúsítás és audit, az incidenskezelés és értesítés, a felelősségkorlátozás és kártalanítás, a szerződéses szerep és a DPA hatálya, valamint a fogyasztói és üzleti feltételek eltérése.

A szolgáltatói feltételek a **2026. október 28-i** állapotot tükrözik. Néhány forrás saját dátuma eltér ettől. A Mistral DPA hatálya például 2026. július 27., a forráslista korábban 2026. március 12-t írt [MIS-DPA]. A STACKIT AI Model Serving v1.4 szolgáltatás-leírásának hatálya 2026. november 6., vagyis a lekérés napja utáni [STACKIT-AIMS].

A források jogi ereje nem egyforma. A 190 megállapításból **96** nem szerződéses dokumentumra (súgó, marketing, termékdokumentáció, közlemény) épül, a többi szerződéses szövegre vagy fogyasztói feltételre. A katalógus ezt minden megállapításnál jelzi, a fejezet pedig ott utal rá, ahol a megkülönböztetés számít.

3.2. Közös minták

A tíz szolgáltató között van néhány kérdés, amelyben a piac lényegében egységes képet mutat. Hét ilyen mintát találtunk.

- **Üzleti szinten nincs tanítás.** Az OpenAI [OAI-SA], az Anthropic [ANT-CT], a Google felhőszolgáltatása és fizetős Gemini API-ja [GCP-TERMS] [GOOG-GEMINI-API] a szerződéses szövegben, a Microsoft [MSFT-FDP] és az AWS [AWS-PRIVACY-FAQ] termékdokumentációban vállalja, hogy az ügyféltartalmat nem használja modelltanításra. Az európai körben az OVHcloud, a STACKIT és az IONOS ugyanezt közli [OVH-AIE] [STACKIT-FAQ] [IONOS-DATA]. A Mistral kivétel, erről a 3.3 és a 3.5 alfejezet szól.
- **Feldolgozói szerep és DPA.** A nagy szolgáltatók az üzleti ajánlatoknál adatfeldolgozóként határozzák meg magukat, az ügyfél utasításai szerint [OAI-DPA] [ANT-DPA] [GCP-DPA] [MSFT-DPA] [AWS-DPA]. Néhány szolgáltatónál önálló adatkezelői tevékenység is van: a Microsoftnál az üzleti műveletek [MSFT-DPA], a Googlenél a számlázási és használati adat [GOOG-GEMINI-API], a Mistralnál a tanítás és a moderáció [MIS-DPA].
- **Alfeldolgozói lánc.** Az általános felhatalmazás, az előzetes értesítés és a kifogási jog jellemző, a kifogás tényleges következménye pedig többnyire a felmondás [OAI-DPA] [GCP-DPA] [MSFT-DPA] [AWS-DPA]. A kifogási idő **15 nap** az Anthropicnál [ANT-DPA], **30 nap** az OpenAI-nál [OAI-DPA], 10 nap a Mistralnál [MIS-DPA] és 90 nap a Googlenél [GCP-DPA]. Az alfeldolgozókért való helytállást az OpenAI, az Anthropic, a Google, az AWS és a Mistral rögzíti [OAI-DPA] [ANT-DPA] [GCP-DPA] [AWS-DPA] [MIS-DPA].
- **Adattovábbítási alap.** Az EGT-n kívüli továbbítás az OpenAI-nál, az Anthropicnál, a Microsoftnál és a Mistralnál standard szerződéses kikötésekre (SCC) épül, a Microsoft emellett az EU–USA adatvédelmi keretrendszer tanúsítványával is rendelkezik [OAI-DPA] [ANT-DPA] [MSFT-DPA] [MIS-DPA].
- **Titkosítási alapszint.** Az **AES-256** nyugalmi és a **TLS 1.2** vagy újabb továbbítási titkosítás az OpenAI-nál és az Anthropicnál kifejezett vállalás [OAI-BDP] [ANT-DPA]. Az AWS a TLS 1.2 használatát írja elő [AWS-BDP], a nyugalmi titkosítás módjáról a katalógusban nincs megállapítás. A Microsoft és a Google alapértelmezett titkosítást említ [MSFT-DPA] [GCP-DPA].
- **Tanúsítási kör.** Független tanúsítvány vagy auditjelentés mind az öt nagy szolgáltatónál szerepel: SOC 2 az OpenAI-nál és az Anthropicnál, ISO 27001 és SOC 2/3 a Googlenél, ISO 27001/27018 a Microsoftnál, ISO- és SOC-család az AWS-nél [OAI-ENT-PRIV] [ANT-DPA] [GCP-DPA] [MSFT-DPA] [AWS-DPA]. Az ügyfél-audit jellemzően korlátozott gyakoriságú és az ügyfél költségén történik [OAI-DPA] [ANT-DPA] [MIS-DPA].

- **Órában mért incidenshatáridő hiánya.** Az incidens-értesítés a szerződésekben „indokolatlan késedelem nélkül” szól [OAI-DPA] [GCP-DPA] [MSFT-DPA] [AWS-DPA] [MIS-DPA]. Egyetlen vizsgált szolgáltató nevesít határidőt órában: az Anthropic **48 órát** [ANT-DPA].
- **Szellemi tulajdoni kártalanítás.** Az öt nagy szolgáltató és a Mistral is kártalanítási vállalást ad harmadik fél szellemi tulajdoni igényeire, a köre azonban eltér. Az OpenAI és a Mistral vállalása harmadik fél szellemi tulajdoni igényére szól [OAI-SA] [MIS-CT], a generált kimenetre kifejezetten az Anthropic, a Google, a Microsoft és az AWS vállal kártalanítást [ANT-CT] [GCP-TERMS] [MSFT-CCC] [AWS-SVC-TERMS]. Erről a 3.3 alfejezet szól.

3.3. A fő eltérések

A piaci egység határát négy kérdés jelöli ki. Ezekben a szolgáltatók vállalásai számottevően eltérnek.

Megőrzés és visszaélés-figyelés. A közös kiindulópont a **30 nap**: az OpenAI API-naplói [OAI-DATA-CTRL], az Anthropic API-adatai [ANT-RETENTION] és a Mistral API-adatai [MIS-PRIVACY] alapértelmezésben ennyi ideig maradnak meg. Az AWS egyes modelleknél legfeljebb ennyi ideig őrzi a bemenetet és a kimenetet [AWS-BEDROCK-ABUSE]. A különbség a jelölt tartalomnál látszik. Az Anthropic a szabálysértőnek jelölt beszélgetések bemenetét és kimenetét legfeljebb **2 évig**, a besorolási pontszámokat legfeljebb **7 évig** őrzi [ANT-RETENTION]. Az OpenAI Safety Retention módjában a jelölt tartalom megőrizhető és emberi felülvizsgálat alá kerülhet [OAI-DATA-CTRL], a gyanított CSAM-képek pedig ZDR mellett is kézi felülvizsgálatra megmaradnak [OAI-DATA-CTRL]. A Microsoftnál az Azure OpenAI emberi felülvizsgálata EGT-beli felülvizsgálókkal működik az EGT-ben telepített modelleknél, és jóváhagyással módosítható [MSFT-AOAI-ABUSE]. Az AWS egyes modelleknél maga végzi az emberi felülvizsgálatot [AWS-BEDROCK-ABUSE]. A szerződés megszűnése utáni törlés is eltér: 30 nap az OpenAI-nál és az Anthropicnál [OAI-SA] [ANT-DPA], 90 nap az AWS-nél [AWS-DPA], 90 + 90 nap a Microsoftnál [MSFT-DPA] és legfeljebb **180 nap** a Googlenél [GCP-DPA].

A ZDR elérhetősége. A zero data retention ritkán alapértelmezés vagy szerződéses vállalás. Az OpenAI-nál előzetes jóváhagyáshoz kötött, és a végpontok viselkedését is módosítja [OAI-DATA-CTRL]. Az Anthropicnál jóváhagyással érhető el egyes API- és Claude Code Enterprise ügyfeleknek, a biztonsági osztályozó eredményei pedig ZDR mellett is megmaradnak [ANT-ZDR]. A Mistral fizetős csomagon, jóváhagyás után kínálja, csak állapotmentes API-hívásokra [MIS-ZDR]. A Googlenél ügyfél-oldali konfiguráció kell hozzá, egyes funkcióknál nem lehetséges, a Grounding with Google Search legfeljebb három napos naplója pedig nem kapcsolható ki [GCP-VERTEX-GOV]. Az AWS none retenciós módja valódi ZDR [AWS-BEDROCK-RETENTION], az Enterprise Frontier Safeguards program ZDR-je viszont csak **2026. december 31-ig** szól [AWS-BEDROCK-ABUSE]. A Microsoft forrásaiban ZDR-vállalás nincs. A felsorolt ZDR-vállalások mind nem szerződéses súgóoldalakon állnak.

Feldolgozási hely és flex routing. Ebben a legtagoltabb a kép. Az OpenAI API-nál az USA vagy Európa választható, a rendszeradatokra azonban ez nem terjed ki [OAI-BDP] [OAI-DATA-CTRL]. Az Anthropic forrásaiban földrajzi vállalás nincs [ANT-DPA]. A Google DPA-ja szerint az adat bármely olyan országban feldolgozható, ahol a szolgáltató vagy alfeldolgozói létesítményt tartanak fenn, a listás szolgáltatásoknál viszont régió vagy multi-régió választható [GCP-DPA] [GCP-TERMS]. A

Microsoft háromféle telepítést ismer: az ügyfél által megadott terület, DataZone és Global [MSFT-FDP]. Az EU Data Boundary az EU-ban és az EFTA-országokban tartja az adatot, korlátozott kivételekkel [MSFT-EUDB]. A Microsoft 365 Copilot **flex routing** funkciója viszont lehetővé teszi, hogy csúcsidőszakban az LLM-következtetés az EU Data Boundary-n kívül történjen. A funkció a 2026. március 25. után létrehozott jogosult bérlőknél alapértelmezésben be van kapcsolva [MSFT-M365-FLEX]. Az Anthropic alfeldolgozói modelljei jelenleg ki vannak zárva az EU Data Boundary-ből [MSFT-M365-COPILOT]. Az AWS-nél az ügyfél adja meg a régiókat [AWS-DPA], keresztrégiós inferenciánál azonban a megőrzött adat a célrégióban tárolódik [AWS-BEDROCK-ABUSE].

Felelősségkorlát és kártalanítás köre. Az OpenAI, az Anthropic és a Mistral felelőssége az esemény előtti 12 hónapban fizetett díjra korlátozott, a kártalanítási kötelezettségek kivételével [OAI-SA] [ANT-CT] [MIS-CT]. A Microsoft forrásaiban a teljes felelősségkorlátozási szabály nincs meg, a DPA pedig az adattörlésért kifejezetten nem vállal felelősséget [MSFT-DPA]. A Google és az AWS esetében a katalógusban felelősségi plafonra vonatkozó megállapítás nincs. A kártalanítás köre eltér. Az OpenAI és a Mistral szellemi tulajdoni igényekre vállal kártalanítást [OAI-SA] [MIS-CT]. Az Anthropic a fizetett használatra és a kimenetre [ANT-CT]. A Google a módosítatlan generált kimenetre vállal kártalanítást, kizáró esetekkel [GCP-TERMS]. A Microsoft a Customer Copyright Commitment keretében, kockázatcsökkentő intézkedések teljesítése mellett [MSFT-CCC]. Az AWS csak a megnevezett generatív AI-szolgáltatásokra, például az Amazon Nova és Titan modellekre, a harmadik fél Bedrock-modelljeire nem [AWS-SVC-TERMS]. A katalógus megállapításai között adatvédelmi incidens miatti kártalanítási vállalás nincs.

3.4. Fogyasztói és üzleti feltételek közötti szakadék

A nagy szolgáltatóknál ugyanaz a márka két, jogilag eltérő feltételrendszer alatt érhető el. Az adatfelhasználási szabályok a fogyasztói vagy ingyenes és az üzleti szinten különböznek, az üzleti használatot pedig külön feltételek szabályozzák.

Az **OpenAI** fogyasztói feltételei szerint a tartalom fejlesztésre is felhasználható, kilépni a fiókbeállításban lehet [OAI-TOU-F]. A feltételek automatizált rendszerek mellett emberi felülvizsgálatot is említenek [OAI-TOU-F], az üzleti használati kiegészítés szerint pedig az üzleti használó kártalanítja a szolgáltatót [OAI-TOU-F]. Az üzleti használatot (Enterprise, API) külön üzleti feltételek szabályozzák [OAI-TOU-F]. Az **Anthropic** EGT-fogyasztói feltételei szerint a tanítás a kilépésig alapértelmezett, a visszajelzéssel vagy biztonsági felülvizsgálatra jelölt tartalom pedig kilépés mellett is tanításra kerülhet [ANT-CONSUMER-F]. A fogyasztói felelősségi plafon a hat havi díj és **100 euró** közül a magasabb, szemben a kereskedelmi feltételek 12 havi díjplafonjával [ANT-CONSUMER-F] [ANT-CT].

A **Google** ingyenes Gemini API szintje a beküldött tartalmat termékfejlesztésre használja, és emberi felülvizsgálók olvashatják [GOOG-GEMINI-API]. EGT-ben, Svájcban és az Egyesült Királyságban viszont az API-ügyfeleknek elérhető felületeken csak fizetős szolgáltatás használható, és a fizetős szint adathasználati szabályai az ingyenesre is vonatkoznak [GOOG-GEMINI-API]. Az **AWS** szolgáltatási feltételei egyes AI-szolgáltatásoknál, például a Kiro Free Tier és az egyéni előfizetők esetében, fejlesztési célú felhasználást engednek [AWS-SVC-TERMS]. A **Mistral** egyéni fogyasztói az

EU-s fogyasztói feltételekre vannak utalva, ennek szövege a forrásokban nincs, ezért az eltérések nem vethetők össze [MIS-CT]. A **Microsoft** forrásaiban fogyasztói és üzleti feltételek összevetésére alkalmas megállapítás nincs.

A feltételrendszer tehát az igénybe vett ajánlati szinthez kötődik, nem a szolgáltatóhoz vagy a modellhez. Ugyanaz a szolgáltató más adatkezelési szabályokat alkalmaz a fogyasztói vagy ingyenes fiókra, mint az üzleti szerződésre.

3.5. Az európai szolgáltatók helyzete

Az öt európai szolgáltató anyaga jellegében eltér a nagy szolgáltatókétól. Hozzájuk **60 megállapítás** tartozik, ebből **39** nem szerződéses dokumentumra épül. Az 5 szolgáltató és 12 dimenzió 60 párjából **20** marad vállalás nélkül, szemben a nagy szolgáltatók 60 párjából 2-vel (Microsoft: ZDR és fogyasztói-üzleti eltérés).

A **Mistral** az egyetlen európai szolgáltató, amelynél a DPA és a kereskedelmi feltételek szövege is a forráskészletben van, és mind a 12 dimenzióhoz van megállapítás. A szerkezet a nagy szolgáltatókéhoz hasonló: 10 napos alfeldolgozói kifogás [MIS-DPA], évente legfeljebb egy helyszíni audit [MIS-DPA], 12 havi díjplafon és szellemi tulajdoni kártalanítás [MIS-CT]. Az eltérések a következők. A DPA szerint a Mistral önálló adatkezelőként tanításra is használhatja a személyes adatot, ha az ügyfél nem lépett ki [MIS-DPA], a kereskedelmi feltételek viszont főszabály szerint nem tanítanak, kivételekkel [MIS-CT]. Az adat alapértelmezésben az EU-ban van, amerikai végpont választható [MIS-GOV-HELP], egyes funkcióknál átmenetileg az EU-n kívülre is kerülhet [MIS-GOV-HELP]. A biztonsági intézkedéseket a DPA a Trust Centerre utalja, amelynek tartalma nem volt a forráskészlet része [MIS-DPA].

Az **Aleph Alpha**, az **OVHcloud**, a **STACKIT** és az **IONOS** esetében a forrás termékdokumentáció, közlemény vagy tanúsítványoldal. A közös elem az európai infrastruktúra: a STACKIT Németországban és Ausztriában [STACKIT-CERTS], az IONOS német adatközpontokban [IONOS-DATA], az OVHcloud franciaországi Gravelines-ben [OVH-AIE-CAP], az Aleph Alpha pedig a STACKIT EU01 régiójában működik [ALEPH-PGA]. Az adatmegőrzésről több szolgáltató adatmegőrzés nélküli vagy szűk megőrzésű alapműködést közöl. Az IONOS szerint a tartalom nem kerül naplóba vagy tartós tárolóba [IONOS-DATA], a STACKIT szerint az ügyféladat nem tárolódik tartósan, az e-mail-cím és a felhasználóazonosító viszont 30 napig a naplókban marad [STACKIT-SVC-CERT]. Az OVHcloud „zero data retention” megnevezéssel hirdeti, hogy csak a számlázási adatot őrzi [OVH-AIE]. A tanúsítványok közül a STACKIT C5 Type 2-t [STACKIT-CERTS], az IONOS BSI C5 hatókört [IONOS-DATA], az OVHcloud ISO 27001, SOC 2 Type II és HDS tanúsítványt említ [OVH-AIE]. Az IONOS dokumentációja kimondja azt is, hogy harmadik fél alfeldolgozót nem vontak be [IONOS-DATA], és hogy a tartalom feldolgozás közben a memóriában titkosítatlan [IONOS-DATA].

A vállalás nélküli sorok jelentős része **forráshiányból** ered. A szerződéses alap több helyen említett, de a szövege hiányzik a forráskészletből. Az OVHcloud szolgáltatás a Public Cloud Special Conditions 10. függelékére épül, a DPA szövege nincs meg [OVH-AIE-CAP]. A STACKIT AI Model Serving v1.4 leírása a lekérés napja után lép hatályba, a szövege nem volt a forráskészlet része [STACKIT-AIMS]. Az Aleph Alpha esetében csak termékdokumentáció és közlemények állnak rendelkezésre [ALEPH-

PGA] [ALEPH-STACKIT]. Ebből nem következik, hogy a szolgáltató ne vállalna többet, csak az, hogy a vállalás a nyilvános forrásokból nem állapítható meg. A tervezett Cohere–Aleph Alpha egyesülés, amely hatósági jóváhagyásra vár, a jogi keretet változtathatja, adatkezelési vállalást a közlemény nem tartalmaz [ALEPH-COHERE].

3.6. Részösszegzés: mit jelent ez a döntés szempontjából

A jelenlegi állapot három rétegben foglalható össze.

- **Egységes alapszint.** Az üzleti tanítási tilalom, a feldolgozói szerep, az alfeldolgozói kifogási jog, a szokásos titkosítás és a tanúsítási kör a nagy szolgáltatók üzleti ajánlatainál közös (3.2).
- **Szolgáltatónként és ajánlatonként eltérő réteg.** A megőrzés és a jelölt tartalom kezelése, a ZDR, a feldolgozási hely és a flex routing, valamint a felelősségkorlát és a kártalanítás köre különbözik (3.3).
- **Ajánlati szint és forrásminőség.** A fogyasztói vagy ingyenes szint feltételei eltérnek az üzletiétől (3.4). Az európai szolgáltatóknál a vállalások jelentős része nem szerződéses forrásra épül, vagy a szerződésszöveg hiányzik (3.5).

A források jogi ereje döntési szempontból külön figyelmet érdemel. A 190 megállapításból **96**, vagyis mintegy a fele nem szerződéses dokumentumra épül. Több kulcsvállalás ilyen oldalon áll, például a ZDR, a megőrzés és a feldolgozási hely egy része [OAI-DATA-CTRL] [ANT-RETENTION] [ANT-ZDR] [MSFT-FDP] [AWS-BEDROCK-RETENTION]. Hogy ezek a vállalások a konkrét szerződés részeként is kötik-e a szolgáltatót, a jelen forráskészletből nem állapítható meg.

Az OAI-TRUST, az ANT-TRUST és az MSFT-STP trust portál tartalma nyilvánosan nem volt elérhető, ezért az onnan származó információ nincs benne a vizsgálatban. A fejezet **nem értékeli**, hogy a vállalások elégségesek-e. Ezt a 6. és a 8. fejezet végzi el, a döntési javaslatot pedig a 9. fejezet adja.

04

04. FEJEZET

Adatszivárgási kockázatok

Ez a fejezet azt mutatja be, hol és milyen úton szivároghat ki az adat, ha a szervezet MI-szolgáltatást vesz igénybe. A fejezet a *2. sz. melléklet* **19 kockázatára** (KOC-01–KOC-19) épít, amelyek a szolgáltatói dokumentumok és a biztonsági keretek 403 megállapítására támaszkodnak (az utólag felvett három ANSSI-SNC-FAQ megállapítás nélkül). A fejezet csak a kockázatokat írja le. Azt, hogy a szolgáltatói vállalások fedezik-e őket, a 6. fejezet vizsgálja. A tényállítások mögött forráskód, illetve KOC-azonosító áll. A valószínűség és a hatás háromfokú szakértői besorolás (alacsony, közepes, magas).

4.1. Honnan szivároghat az adat

A kockázatokat négy vektortípusba soroltuk. A csoportosítás azt mutatja meg, hogy mi a szivárgás forrása, és ebből következik, hogy ki tehet ellene.

Szerződéses és szolgáltatói működésből eredő vektor (KOC-01–KOC-07). Az adat a szolgáltató dokumentált, rendes működése közben kerül olyan helyre vagy olyan kezekbe, amelyet az ügyfél nem vár. Ide tartozik a modelltanítás, a megőrzés, a visszaélés-figyelés miatti emberi hozzáférés, a ZDR korlátai, az alfeldolgozói lánc, a titkosítás hiányosságai és a fogyasztói szint használata.

Földrajzi és joghatósági vektor (KOC-08–KOC-10). Az adat az elvárt joghatóságon kívülre kerül, vagy ott hozzáférhetővé válik. Ide tartozik az EU-n kívüli feldolgozás, a harmadik országbeli hatósági hozzáférés és a DPF bizonytalansága.

Technikai támadás és hiba vektor (KOC-11–KOC-17). A szivárgást támadás vagy hiba okozza. Ide tartozik a prompt injection, a kimeneti kiszivárogtatás, a RAG, a modellinverzió, az ellátási lánc, az izolációs hiba és a hibásan konfigurált adatbázis.

Szervezeti és felhasználói vektor (KOC-18–KOC-19). A szivárgás a szervezet vagy a felhasználó döntéséből ered, vagyis a nem jóváhagyott eszközhasználatból és a szolgáltatói feltételek átvilágításának elmaradásából.

A katalógus **négy dokumentált incidenst** rögzít: az OpenAI 2023-as gyorsítótár-hibáját [OAI-INC-REDIS], az OpenAI és a Mixpanel 2025-ös esetét [OAI-INC-MIXPANEL], a Microsoft 365 Copilot CVE-2025-32711 sérülékenységét [MSRC-CVE-2025-32711] és a DeepSeek-adatbázis kitettségét, amely

független kutatói jelentés, és a szolgáltató vagy hatóság nem erősítette meg [WIZ-DEEPSEEK]. Három a technikai vektorhoz tartozik, egy a szolgáltatói működéshez (Mixpanel). Szervezeti incidenst a források nem rögzítenek.

4.2. A szolgáltatói működésből eredő kockázatok

Tanítás és fogyasztói szint (KOC-01, KOC-02). Üzleti szinten a nagy szolgáltatók szerződésben vagy dokumentációban vállalják, hogy az ügyféltartalmat nem használják modelltanításra [OAI-SA] [ANT-CT] [GCP-TERMS] [MSFT-FDP] [AWS-PRIVACY-FAQ]. A fogyasztói és ingyenes szinten viszont a fejlesztési felhasználás az alapértelmezés, a kilépés a felhasználó beállításán múlik [OAI-TOU-F] [ANT-CONSUMER-F] [GOOG-GEMINI-API]. A Mistral DPA-ja is engedi a tanítást, ha az ügyfél nem lépett ki [MIS-DPA]. A kockázat ezért kevésbé a szerződés tartalmán, inkább azon múlik, hogy a munkatárs melyik szinten dolgozik. A hatás magas, mert a tanításba beépülő ügyféladat a CCBE szerint sértheti a hivatásbeli titoktartást [CCBE-GENAI].

Megőrzés, emberi hozzáférés és ZDR (KOC-03–KOC-05). A közös kiindulópont a 30 napos megőrzés [OAI-DATA-CTRL] [ANT-RETENTION] [MIS-PRIVACY]. A jelölt tartalom hosszabb ideig marad meg, az Anthropicnál legfeljebb 2 évig [ANT-RETENTION], az OpenAI Safety Retention módjában pedig emberi felülvizsgálat alá is kerülhet [OAI-DATA-CTRL]. A gyanított CSAM-tartalmú képek az OpenAI-nál ZDR mellett is kézi felülvizsgálatra megmaradnak [OAI-DATA-CTRL]. A zero data retention nem alapértelmezés. Az OpenAI-nál jóváhagyáshoz kötött [OAI-DATA-CTRL], a Mistralnál csak az állapotmentes hívásokra szól [MIS-ZDR], az AWS Enterprise Frontier Safeguards programjának ZDR-je 2026. december 31-ig érvényes [AWS-BEDROCK-ABUSE], a Microsoft forrásaiban pedig ZDR-vállalás nincs. A felsorolt ZDR-vállalások nem szerződéses súgóoldalakon állnak (3.3 alfejezet).

Alfeldolgozók és titkosítás (KOC-06, KOC-07). Az alfeldolgozói lánc a szerződésekben általános felhatalmazással működik, a kifogási idő 10 és 90 nap között van, a következmény többnyire felmondás [MIS-DPA] [OAI-DPA] [GCP-DPA]. Dokumentált példa az OpenAI és a Mixpanel esete, ahol a harmadik fél analitikai szolgáltatónál történt behatolás ügyfélazonosítókat és analitikai adatot érintett, tartalmat nem [OAI-INC-MIXPANEL]. A titkosításnál az AES-256 és a TLS 1.2 az alapszint [OAI-BDP] [ANT-DPA]. A használat közbeni védelemre a szolgáltatói dokumentumokban szolgáltatói vállalás nincs, az IONOS pedig kifejezetten közli, hogy feldolgozás közben a tartalom a memóriában titkosítatlan [IONOS-DATA].

4.3. Földrajzi és joghatósági kockázatok

Feldolgozási hely (KOC-08). A legkonkrétabb példa a Microsoft 365 Copilot flex routing funkciója. Csúcsidőszakban az LLM-következtetés az EU Data Boundary-n kívül történhet, és a funkció a 2026. március 25. után létrehozott jogosult bérlőknél alapértelmezésben be van kapcsolva [MSFT-M365-FLEX]. Hasonló kivétel az AWS keresztrégiós inferenciája [AWS-BEDROCK-ABUSE], a Microsoft Global telepítése [MSFT-FDP], a Google DPA-ja szerinti bármely ország [GCP-DPA] és a Mistral EU-n kívülre kerülő funkciói [MIS-GOV-HELP]. Az Anthropic forrásaiban földrajzi vállalás nincs [ANT-DPA]. A magyar jog szerint a Kibtv. hatálya alá tartozó szervezetnek külföldi adatkezelés előtt

adatosztályozást kell végeznie, a hatóság pedig megtilthatja vagy korlátozhatja azt [KIBTV]. A pénzügyi szektorban az MNB az EGT-n kívüli felhőnél különös gondosságot vár el [MNB-2-2025]. A hatás ezért magas.

Hatósági hozzáférés és DPF (KOC-09, KOC-10). Az ANSSI szerint egyes államok területen kívüli hatályú jogszabályai kibertámadás nélkül is hozzáférést adhatnak a felhőben tárolt adatokhoz, és a szolgáltatók fellebbezési vagy tájékoztatási lehetőség nélkül kötelesek az adatot átadni [ANSSI-CLOUD-SENS]. A szolgáltatói dokumentumokban a hatósági kérelmek kezelésére szolgáltatói vállalás nincs. Az EU–USA adatvédelmi keretrendszer (DPF) szerinti továbbítás jogi alapja a Bizottság döntésétől függ, amely felfüggesztheti vagy hatályon kívül helyezheti a határozatot [EU-US-DPF]. A Latombe-fellebbezés folyamatban van [EUB-C703-25P]. A GDPR másodlagos jogalapként az SCC-t is elismeri [GDPR], ezért a DPF-kockázat hatását közepesnek értékeljük.

Az uniós ajánlat sem automatikusan mentes. Az ANSSI az Unión kívüli tulajdonú vagy ellenőrzött harmadik felek technikai hozzáférésének kizárását is kéri [ANSSI-SECNUMCLOUD], az Aleph Alpha tervezett egyesülése pedig kanadai és német jogi keretbe vinné a vállalatot [ALEPH-COHERE].

4.4. Technikai támadások és hibák

A technikai vektor kockázatait két forrástípus támasztja alá. A dokumentált incidensek azt mutatják, mi történt. A szabványok és a hatósági anyagok azt, hogy mi történhet.

Az incidensek tanulságai. Az OpenAI 2023-as esetében a nyílt forráskódú redis-py könyvtár hibája miatt egyes felhasználók más felhasználó csevegési előzményeinek címeit látták, a ChatGPT Plus előfizetők 1,2%-ánál pedig fizetési adat is látható lehetett [OAI-INC-REDIS]. A tanulság: az ügyfelek közötti elkülönítés hibája a vezető szolgáltatónál is bekövetkezett, és az ügyfél nem tudta megelőzni (KOC-16). A Microsoft 365 Copilot CVE-2025-32711 sérülékenysége lehetővé tette, hogy jogosulatlan támadó hálózaton keresztül információt szerezzen. Az MSRC 9,3-as pontszámot adott, az NVD elsődleges értékelése 7,5, a Microsoft szerint a hibát elhárította és kihasználását nem jelezték [MSRC-CVE-2025-32711]. A tanulság: az indirekt injekció a felhasználó hibája nélkül is adatot szerezhet (KOC-11).

A Mixpanel-eset tanulsága, hogy a tartalmon kívüli adat, például a név és az e-mail-cím is támadási alap lehet, mert phishing és social engineering támadásokhoz használható ([OAI-INC-MIXPANEL], KOC-06). A DeepSeek-adatbázis kitettsége azt mutatja, hogy a naplók csevegési előzményeket és API-kulcsokat is tartalmazhatnak ([WIZ-DEEPSEEK], KOC-17). Ezt csak a Wiz független jelentése rögzíti, és a DeepSeek nem szerepel a vizsgált szolgáltatók között.

Amit a szabványok és a hatósági anyagok jeleznek. Konkrét incidens nélkül is kockázatként nevesítik a bővítményeken és a kimeneten át történő kiszivárogtatást (KOC-12), például a markdown képhivatkozással a támadó szerverére küldött beszélgetést [ANSSI-BSI-LLM-ZT]. RAG esetén jogosultságellenőrzés hiányában a feladatkörön kívüli adat is lekérdezhető, a vektoradatbázis beágyazásaiból pedig a forrásszöveg visszaállítható ([ANSSI-BSI-LLM-ZT], [BSI-GENAI], KOC-13). A modellinverzió, a memorizáció és a regurgitáció a NIST szerint már felfedett érzékeny tanítóadatot ([NIST-600-1], KOC-14). Az ellátási lánc harmadik féltől származó összetevői csökkentik az átláthatóságot ([NIST-600-1], KOC-15).

A szolgáltatói vállalások (a szolgáltatói dokumentumok) az injekciós támadás, a kimeneti szivárgás, a RAG-izoláció és a memorizáció ellen nem tartalmaznak megállapítást. A védelmet a biztonsági keretek és szabványok szerinti technikai kontrollok adják [OWASP-LLM] [NIST-600-1] [ANSSI-BSI-LLM-ZT]. Ezek a kockázatok az LLM-alkalmazás tulajdonságai, ezért a helyben futtatott modellnél is fennállhatnak [OWASP-LLM]. A helyben futtatott modellre a szolgáltatói dokumentumok és a biztonsági keretek konkrét megállapítást nem tartalmaznak, a biztonsági útmutatókat és a licenceket a nyílt súlyú modellekre vonatkozó biztonsági útmutatók és licencek külön rögzítik.

4.5. Szervezeti kockázatok

Nem jóváhagyott eszközhasználat (KOC-18). A NAIH szerint a „shadow AI" adatbiztonsági kockázat, mert a szervezet nem rendelkezik kontrollal az ilyen adatkezelések felett [NAIH-BANK-MI]. Az ANSSI szerint nyilvános generatív MI-szolgáltatásnak érzékeny adatot semmiképp sem szabad küldeni, mert a legtöbb szolgáltatás az adatot gyűjti és modelloptimalizálásra használja [ANSSI-GENAI-PA102]. Az üzleti szint szerződéses védelme erre nem terjed ki, mert az üzleti használatot külön feltételek szabályozzák [OAI-TOU-F] [ANT-CONSUMER-F]. A felelősség a szervezeté. Az ügyvéd például maga felel az adatkezelés és az ügyvédi titok feltételrendszerének megteremtéséért [MUK-4-2026].

Az átvilágítás elmaradása (KOC-19). A BSI szerint a szolgáltató C5-jelentését az ügyfélnek magának kell megrendelnie és elemeznie, a fennmaradó kockázatot pedig az ügyfél viseli [BSI-C5]. A BSI Mindeststandard szerint a szervezetnek fel kell derítenie, milyen jogokat enged a szolgáltatónak az ÁSZF elfogadásával [BSI-MINDEST-CLOUD]. Ez azért fontos, mert a 190 szolgáltatói megállapításból 96 nem szerződéses dokumentumra épül (3.6 alfejezet), és a vállalás kötelező ereje a konkrét szerződés ismerete nélkül nem állapítható meg.

Csak e két szervezeti kockázatot vettük fel, mert csak ezeket támasztja alá megállapítás. A jogosultságkezelés hiányosságait a RAG-kockázat tárgyalja (KOC-13).

4.6. Részösszegzés: a legsúlyosabb kockázatok

A 19 kockázatból hét emelkedik ki. Három magas valószínűségű és magas hatású, kettőt megerősített incidens támaszt alá, kettő pedig a közszféra, a pénzügyi szektor és az ügyvédi adatkör ágazati elvárásait érinti. Mindegyiknél jelezzük, hogy a szerződés melyik ellen véd és melyik ellen nem.

- **KOC-02, fogyasztói és ingyenes szint (magas valószínűség, magas hatás).** Véd az üzleti szint tanítási tilalma [OAI-SA] [ANT-CT]. Nem véd, ha a munkatárs a fogyasztói vagy az ingyenes szintet használja, mert annak feltételei fejlesztési felhasználást és emberi felülvizsgálatot engednek [OAI-TOU-F] [GOOG-GEMINI-API].
- **KOC-08, feldolgozás az EU-n kívül (magas valószínűség, magas hatás).** Részben véd, mert az OpenAI, az AWS és a Google régióválasztást vállal [OAI-BDP] [AWS-DPA] [GCP-TERMS]. Nem véd az alapértelmezett kivételek ellen: a Copilot flex routing, a Global telepítés és a keresztrégiós inferencia ellen [MSFT-M365-FLEX] [MSFT-FDP] [AWS-BEDROCK-ABUSE].

- **KOC-11, prompt injection és indirekt injekció (magas valószínűség, magas hatás).** A szerződés nem véd, mert a szolgáltatói dokumentumokban ilyen vállalás nincs. A Microsoft a CVE-2025-32711 hibát elhárította, ez azonban az MSRC-közlemény szerinti hibajavítás, szerződéses vállalás nem [MSRC-CVE-2025-32711].
- **KOC-16, izolációs és gyorsítótár-hiba (magas valószínűség, közepes hatás).** A szerződés a hiba megelőzését nem garantálja, csak az értesítést szabályozza. Az OpenAI, a Google, a Microsoft, az AWS és a Mistral „indokolatlan késedelem nélkül" értesít, az Anthropic 48 órát vállal [OAI-DPA] [GCP-DPA] [MSFT-DPA] [AWS-DPA] [MIS-DPA] [ANT-DPA].
- **KOC-06, alfeldolgozói lánc (magas valószínűség, közepes hatás).** Részben véd az alfeldolgozókért való helytállás és a kifogási jog [OAI-DPA]. Nem véd a kifogás tényleges hatása ellen, mert az többnyire a felmondás, és a Mixpanel-eset a harmadik fél analitikai szolgáltató kockázatát mutatta [OAI-INC-MIXPANEL].
- **KOC-09, harmadik országbeli hatósági hozzáférés (közepes valószínűség, magas hatás).** A szerződés nem véd, mert a szolgáltatói dokumentumokban ilyen vállalás nincs. Az SCC értesítési kötelezettséget ír elő az adatátvevőnek [SCC], az ANSSI szerint viszont egyes államok jogszabályai fellebbezési vagy tájékoztatási lehetőség nélküli adatátadásra kötelezhetnek [ANSSI-CLOUD-SENS].
- **KOC-18, nem jóváhagyott eszközhasználat (közepes valószínűség, magas hatás).** A szerződés nem véd, mert a védekezés szervezeti feladat. Az ANSSI az érzékeny adat küldésének tilalmát várja, a NAIH pedig a kontroll hiányát nevezi kockázatnak [ANSSI-GENAI-PA102] [NAIH-BANK-MI].

A mintázat egyértelmű. A szerződés a szolgáltató tervezett adathasználata ellen, vagyis a tanítás, a megőrzés és az alfeldolgozók esetében véd a legjobban. A váratlan hibák, a támadások, a joghatósági kockázatok és a szervezeti viselkedés ellen alig vagy egyáltalán nem véd. A vállalási hiányok tételes elemzését a 6. fejezet végzi el, a döntési javaslatot a 9. fejezet adja.

05

05. FEJEZET

Jogi elvárások és várható változások

Ez a fejezet a jogi hátteret rögzíti, és a tanulmány harmadik vizsgálati kérdésére, a várható változásokra válaszol. A fejezet kizárólag a **jogi elvárást** foglalja össze. A szolgáltatói vállalásokkal való összevetés, vagyis a vállalási hiányok elemzése a 6. fejezet feladata, a döntési javaslatot a 9. fejezet adja. A tényállítások mögött a jogszabályi és hatósági források forráskódja áll. A Latombe-ügyre a bírósági gyakorlat és a hatósági eljárások forráskódjával hivatkozunk, mert az ügy a jogszabályi és hatósági források között nem szerepel.

5.1. A szabályozási keret felépítése

A szabályozás két rétegből áll. Az **uniós réteg** a GDPR-ből, az AI Act-ből, a Data Act-ből és a NIS2 irányelvből épül fel, kiegészítve az adattovábbítás eszközeivel, vagyis a standard szerződéses kikötésekkel (SCC) és az EU–USA adatvédelmi keretrendszerrel (DPF) [GDPR] [AIA] [DATA-ACT] [NIS2] [SCC] [EU-US-DPF]. A **magyar réteg** két feladatot lát el. Ágazati titokvédelmi szabályokat ad az ügyvédi, banki, egészségügyi és minősített adatra [UTTV] [HPT] [EUAK] [MAVTV], és hazai szabályokat állapít meg a kiberbiztonságra és az MI-rendelet végrehajtására [KIBTV] [KORM-418-2024] [MI-VH-TV].

A szerepeket a GDPR határozza meg. Az MI-szolgáltatást igénybe vevő szervezet **adatkezelő**. A szolgáltató **adatfeldolgozó**, ha a személyes adatot az adatkezelő írásbeli utasításai alapján kezeli [GDPR]. Az EDPB szerint az adatfeldolgozó nem végezhet adatkezelést a saját céljaira [EDPB-GL07-2020]. Egy külső szakértői anyag szerint a szolgáltató a telepítő utasításai szerinti felhőalapú feladatoknál adatfeldolgozó lehet, ez azonban nem EDPB-állásfoglalás [EDPB-SPE-LLM]. A GDPR-megfelelés felelőssége az EDPB taskforce szerint nem hárítható az érintettekre [EDPB-CHATGPT-TF].

Az AI Act külön szerepeket ismer. Az általános célú modell **szolgáltatójára** dokumentációs és kiberbiztonsági kötelezettségek vonatkoznak [AIA]. Az MI-rendszer **alkalmazóját**, vagyis üzemeltetőjét intézkedési és naplómegőrzési kötelezettségek terhelik, de a jogszabályi és hatósági források szerint ez a nagy kockázatú rendszerek alkalmazóira vonatkozik [AIA]. Hogy a tanulmány tárgyát képező használat nagy kockázatú rendszernek minősül-e, azt a jogszabályi és hatósági források nem döntik el. Az AI Act szankcióit Magyarországon közigazgatási hatósági eljárásban lehet alkalmazni, és ez az eljárás kiterjed a harmadik országban működő szolgáltatókra is, ha a rendszer kimenetét Magyarországon használják [MI-VH-TV]. Az MI piacfelügyeleti hatóság feladatait a vállalkozásfejlesztésért felelős miniszter látja el [KORM-344-2025].

A források jogi ereje eltérő. A GDPR, az AI Act és a hazai törvények kötelező követelményt rögzítenek. Az EDPB, a CNIL, az MNB, a MÜK és a CCBE anyagai elvárást fogalmaznak meg, jogszabálynak nem minősülnek [EDPB-OP28] [CNIL-INTERET-LEG] [MNB-2-2025] [MUK-4-2026] [CCBE-GENAI]. A jogszabályi és hatósági források feldolgozása ezt a megállapítások elején álló „Követelmény", „Keret", „Elvárás" és „Megfigyelés (jelentés, nem kötelező erejű)" jelöléssel különbözteti meg.

5.2. Mit követel meg a jog a szolgáltatóval kötött szerződéstől

A GDPR 28. cikke határozza meg az adatfeldolgozói szerződés kötelező tartalmát. Az adatkezelő csak olyan adatfeldolgozót vehet igénybe, amely megfelelő garanciákat nyújt a követelmények teljesítésére [GDPR]. A szerződés minimumtartalma a következő.

- **Utasítás szerinti kezelés.** A szolgáltató a személyes adatot kizárólag az adatkezelő írásbeli utasításai alapján kezelheti, a harmadik országba történő továbbítást is beleértve [GDPR].
- **Alfeldolgozók.** További adatfeldolgozó csak az adatkezelő előzetes írásbeli felhatalmazásával vehető igénybe, általános felhatalmazás esetén is tájékoztatni kell az adatkezelőt a változásokról [GDPR]. Ha az alfeldolgozó nem teljesít, az őt megbízó adatfeldolgozó teljes felelősséggel tartozik az adatkezelő felé [GDPR].
- **Audit.** Az adatfeldolgozónak az auditok, a helyszíni vizsgálatot is ideértve, lehetővé tételéhez és a megfelelés igazolásához szükséges információt az adatkezelő rendelkezésére kell bocsátania [GDPR].
- **Törlés és visszaadás.** A szolgáltatás befejezése után az adatfeldolgozó az adatkezelő döntése szerint töröl vagy visszajuttat minden személyes adatot, és törli a másolatokat [GDPR].
- **Biztonság.** A kockázattal arányos technikai és szervezési intézkedések, ideértve az álnevesítést és a titkosítást, az adatkezelőt és az adatfeldolgozót egyaránt kötelezik [GDPR].
- **Incidens-értesítés.** Az adatfeldolgozónak az incidensről való tudomásszerzés után indokolatlan késedelem nélkül értesítenie kell az adatkezelőt. A 72 órás bejelentési határidő az adatkezelőt terheli [GDPR]. A GDPR a feldolgozói értesítésre órában mért határidőt nem nevesít.

A magyar jog és a hatósági elvárások ezt az alapot ágazatonként egészítik ki. Az Infotv. hatálya alá tartozó adatkezelésnél a további adatfeldolgozó igénybevételéhez az adatkezelő előzetes eseti vagy általános felhatalmazása kell, és azt közokiratba vagy teljes bizonyító erejű magánokiratba kell foglalni [INFOTV]. A hitelintézeti kiszervezésnél a szerződésnek tartalmaznia kell a kiszervezett tevékenységet végző hozzájárulását a belső ellenőrzés, az adatvédelmi tisztviselő, a könyvvizsgáló és a Felügyelet ellenőrzéséhez [HPT]. Közreműködőt a kiszervezett tevékenységet végző csak akkor alkalmazhat, ha a hitelintézet által jóváhagyott szerződés biztosítja az ellenőrzést [HPT]. Az MNB a pénzügyi szektorban az ellenőrzési jog kikötését, a szolgáltatói biztosítékok és a kártérítés rögzítését, valamint a szolgáltatási láncban az alvállalkozói teljesítést és a felügyeleti ellenőrzési jog biztosítását várja el [MNB-2-2025]. Az ügyvédeknek a MÜK ajánlása szerint az adatfeldolgozási megállapodásban rögzíteni kell a dokumentált utasítás szerinti eljárást, a titoktartást, az alfeldolgozók ellenőrzését, a modellképzés és a saját célú felhasználás kizárását [MUK-4-2026].

A kiberbiztonsági szabályok az ellátási láncot és az incidens határidejét érintik. A NIS2 hatálya alá tartozó szervezetnek az ellátási lánc biztonságáról, a közvetlen szolgáltatókkal fennálló kapcsolatokat is ideértve, gondoskodnia kell [NIS2]. A jelentős eseményről a tudomásszerzéstől számított 24 órán belül korai előrejelzést kell küldeni [NIS2], a magyar szabály szerint a kiberbiztonsági incidensről 24 órán belül első bejelentést kell benyújtani a Központ részére [KORM-418-2024]. Ezek a határidők a szervezetre vonatkoznak, nem a szolgáltatóra.

Kárigény esetén az érintett az adatkezelőtől vagy az adatfeldolgozótól kérhet kártérítést [GDPR]. Az adatfeldolgozó felelőssége szűkebb, mert csak az őt kifejezetten terhelő kötelezettségek megsértéséért vagy az utasítások figyelmen kívül hagyásáért felel [GDPR]. A jogérvényesítés részleteit a 7. fejezet tárgyalja.

5.3. Adattovábbítás és harmadik országbeli hozzáférés

A GDPR a harmadik országba történő továbbítást az V. fejezetben szabályozza, és a védelem szintje nem csökkenhet [GDPR]. Továbbítani megfelelőségi határozat alapján lehet, ha a Bizottság megállapította a megfelelő védelmi szintet [GDPR]. Ennek hiányában megfelelő garanciák kellenek, például általános adatvédelmi kikötések, és az érintetteknek érvényesíthető jogokkal és hatékony jogorvoslattal kell rendelkezniük [GDPR]. Harmadik ország hatóságának vagy bíróságának adatátadást előíró határozata csak hatályos nemzetközi megállapodás alapján ismerhető el vagy hajtható végre [GDPR]. A szabályok megsértése a magasabb bírságkategóriába tartozik, amelynek felső határa 20 millió EUR, vállalkozásnál a világpiaci forgalom 4%-a, a kettő közül a magasabb [GDPR].

Két jogalap a gyakorlatban a legfontosabb.

- **EU–USA adatvédelmi keretrendszer (DPF).** Az Egyesült Államok megfelelő védelmi szintet biztosít a keretben részt vevő, a Kereskedelmi Minisztérium listáján szereplő szervezetek számára [EU-US-DPF]. A Bizottság a határozatról a tagállamoknak küldött értesítés időpontjától számított egy éven belül, majd rendszeresen felülvizsgálja a megállapítást [EU-US-DPF]. Ha a megfelelő védelem már nem biztosított, felfüggesztheti, módosíthatja vagy hatályon kívül helyezheti a határozatot, vagy korlátozhatja a hatályát [EU-US-DPF].
- **Standard szerződéses kikötések (SCC).** A 2. modul szerint az adatátvevő az adatátadó előzetes kifejezett írásbeli hozzájárulása nélkül nem vehet igénybe további adatfeldolgozót az 1. lehetőség esetén [SCC]. A felek garantálják, hogy nincs okuk feltételezni, hogy a célország joga és gyakorlata, a hatósági hozzáférést is ideértve, megakadályozná az adatátvevőt a teljesítésben [SCC]. Az adatátvevő köteles haladéktalanul értesíteni az adatátadót, ha hatóság jogilag kötelező érvényű adatkiadási kérelmet intéz hozzá [SCC].

A DPF jogi helyzete nem végleges. A Törvényszék a T-553/23. sz. Latombe-ügyben 2025. szeptember 3-án a DPF-et fenntartotta [EUB-T553-23]. A Latombe-ügy fellebbezése a C-703/25 P. sz. ügyben 2025. október 31-én került benyújtásra a Bírósághoz, és az eljárás folyamatban van [EUB-C703-25P]. A letöltött hivatalos lapi közlemény szerint ítélet vagy főtanácsnoki indítvány még nincs, ennek állását a CURIA oldalán újra kell ellenőrizni. A DPF-határozat addig hatályos [EU-US-DPF], a

kérdés azonban a fellebbezés miatt nincs végleg eldöntve. A GDPR a megfelelőségi határozat mellett a megfelelő garanciákat, például az általános adatvédelmi kikötéseket is elfogadja jogalapként [GDPR].

A nem személyes adatokra a Data Act ad külön védelmet. Az adatkezelési szolgáltatóknak megfelelő technikai, szervezési és jogi, vagyis szerződéses intézkedéseket kell hozniuk az Unióban tárolt nem személyes adatokhoz való harmadik országbeli kormányzati hozzáférés és továbbítás megakadályozására, ha az uniós joggal ütközne [DATA-ACT].

A magyar jog több ponton szigorít. Az Infotv. hatálya alá tartozó adatkezelő vagy adatfeldolgozó harmadik országba csak a 10. § (1) bekezdésben felsorolt feltételek mellett továbbíthat személyes adatot, a közvetett továbbítást is ideértve [INFOTV]. A Kibtv. hatálya alá tartozó szervezetnek adatosztályozást kell végeznie, ha nem privát felhőszolgáltatást vesz igénybe vagy külföldön kezel adatot [KIBTV]. A szervezet vezetője csak akkor dönthet a külföldi adatkezelés vagy a nem privát felhő mellett, ha a költség-haszon elemzés és a kilépési terv alapján az megalapozottan előnyökkel jár [KORM-418-2024]. A pénzügyi szektorban az MNB elvárja, hogy az EGT-n kívüli felhőszolgáltatásnál az intézmény különös gondossággal járjon el, és dokumentáltan igazolja, hogy figyelembe vette a harmadik országbeli adatkezelésre vonatkozó előírásokat [MNB-2-2025].

5.4. Adatkörönkénti szigorítások

A jogi követelmények adatkörönként eltérnek. A tanulmány négy adatkört különböztet meg, és ezeket a következő kódokkal jelöli: **SZA** (személyes adat), **UTI** (üzleti titok), **HIV** (hivatásbeli titok: ügyvédi, orvosi, banktitok) és **KOZ** (közszféra- és minősített adat).

- **SZA, személyes adat.** Az alap a GDPR szerinti szerződés, biztonság és adattovábbítás (5.2 és 5.3). A különleges kategóriás adat, például az egészségügyi adat kezelése főszabály szerint tilos, kivéve a 9. cikk (2) bekezdésében felsorolt eseteket [GDPR]. Nagy számú különleges adat kezelése előtt kötelező az adatvédelmi hatásvizsgálat [GDPR]. Az EDPB szerint a hatásvizsgálat az elszámoltathatóság fontos eleme, ha az MI-modellekkel összefüggő adatkezelés valószínűsíthetően magas kockázattal jár [EDPB-OP28]. Az Infotv. szabályai a bűnüldözési, nemzetbiztonsági és honvédelmi célú adatkezelésre irányadók [INFOTV].
- **UTI, üzleti titok.** Az üzleti titok védelme feltételezi, hogy a jogosult a titokban tartás érdekében az adott helyzetben általában elvárható magatartást tanúsítja [UZLETI-TITOK-TV]. Jogosulatlan hasznosítás vagy felfedés az is, ha valaki a titoktartási megállapodást vagy más titoktartási kötelezettséget megsérti [UZLETI-TITOK-TV]. Az AI Act modellszolgáltatói dokumentációs kötelezettsége sem sértheti az üzleti titkokat [AIA]. A jogszabályi és hatósági források az üzleti titok MI-szolgáltatónak történő átadását tiltó szabályt vagy külön szerződéses minimumot nem rögzítenek.
- **HIV, ügyvédi titok.** Az ügyvéd köteles az ügyvédi titkot megtartani, ez az adathordozóra is kiterjed [UTTV]. Az ügyvédet nem terheli titoktartási kötelezettség az adatfeldolgozóként igénybe vett közreműködővel szemben, a szolgáltatás nyújtásához szükséges mértékben [UTTV]. A MÜK szakmai álláspontja szerint az MI-szolgáltató igénybevétele ide tartozik, az ügyfél jóváhagyása nem törvényi követelmény, és az ügyvéd felel a feltételrendszer megteremtéséért [MUK-4-2026].

A CCBE szerint az MI-nek átadott ügyféladat bizalmassága kockázatos, ha az adatot tárolják, újrahasználják vagy a tanításba beépítik [CCBE-GENAI]. A MÜK-álláspont és a CCBE-útmutatók nem jogszabályok.

- **HIV, orvosi titok.** Az orvosi titkot az adatkezelő és az adatfeldolgozó is köteles megtartani [EUAK]. A közfinanszírozott egészségügyi szolgáltató elektronikus nyilvántartásával kapcsolatos adatfeldolgozó a szerződés megszűnésekor köteles az adatállományt díjmentesen, elektronikusan visszaszolgáltatni [EUAK]. Az egészségügyi adat egyben különleges kategóriás személyes adat [GDPR].

- **HIV, banktitok.** A banktitok fogalma tág: az egyes ügyfelekről a pénzügyi intézmény rendelkezésére álló minden tény, információ, megoldás vagy adat, amely az ügyfél személyére, vagyoni helyzetére, szerződéseire és hasonlókra vonatkozik [HPT]. A titkot időbeli korlátozás nélkül kell megtartani, és az a pénzügyi intézmény vagy az ügyfél felhatalmazása nélkül, a törvényi kivétellel, nem adható ki harmadik személynek [HPT]. Az ügyfél a kiadásra a kiszolgáltatható kör pontos megjelölésével, közokiratba vagy teljes bizonyító erejű magánokiratba foglaltan adhat felhatalmazást, szerződéskötés keretében az okiratba foglalás nem szükséges [HPT]. A kiszervezett tevékenység végzéséhez szükséges adatátadás a kiszervezett tevékenységet végző és az általa igénybe vett közreműködő részére nem sérti a banktitkot [HPT]. A kiszervezés az adatvédelmi előírások betartása mellett lehetséges [HPT], és a hitelintézet felel azért, hogy a kiszervezett tevékenységet végző a jogszabályok betartásával és a tőle elvárható gondossággal dolgozzon [HPT]. A NAIH a bankok MI-használatáról szóló jelentésében a „shadow AI" jelenséget adatbiztonsági kockázatként nevezi meg, a jelentés nem kötelező erejű [NAIH-BANK-MI]. A jogszabályi és hatósági források nem döntik el, hogy az MI-szolgáltatás igénybevétele a Hpt. 68. §-a szerinti kiszervezésnek minősül-e. Ez nyitott jogi kérdés.

- **KOZ, közszféra- és minősített adat.** A minősített adatot csak a Nemzeti Biztonsági Felügyelet engedélye alapján lehet kezelni, és csak akkor, ha az az állami vagy közfeladat ellátásához nélkülözhetetlen [MAVTV]. A minősített adathoz csak személyi biztonsági tanúsítvánnyal és titoktartási nyilatkozattal rendelkező felhasználó férhet hozzá [MAVTV]. Közreműködő igénybevételénél a biztonsági vezetőnek az adat átadása előtt ellenőriznie kell, hogy a közreműködőnél megteremtették-e a védelem feltételeit [MAVTV]. A Kibtv. hatálya alá tartozó szervezet nem privát felhőszolgáltatást csak az adatosztályozás eredményére figyelemmel vehet igénybe, külföldön pedig csak így kezelhet adatot, ha más jogszabály ezt nem tiltja vagy korlátozza [KIBTV]. A nemzeti kiberbiztonsági hatóság megtilthatja vagy korlátozhatja a felhőszolgáltatás igénybevételét és a külföldön történő adatkezelést [KIBTV]. A jogszabályi és hatósági források az MI-szolgáltatás használatát minősített adatra külön nem tiltják, de a fenti engedélyezési és hozzáférési feltételek teljesülése nélkül a minősített adat nem kezelhető.

5.5. Várható változások

A szabályozás több ponton változik. A hatályos, de még nem alkalmazandó tételeket és a folyamatban lévő, nem hatályos javaslatokat külön kell kezelni.

- **AI Act ütemezés az Omnibus után.** Az (EU) 2026/1744 Omnibus-rendelet hatályba lépett, a módosításokat az AI Act konszolidált szövege már tartalmazza [OMNIBUS-AI-2026-1744]. Az általános alkalmazási kezdőnap 2026. augusztus 2., vagyis a tanulmány dátumán már elmúlt [AIA], az általános célú modellek szolgáltatóinak kötelezettségei és a 78. cikk 2025. augusztus 2-től alkalmazandók [AIA]. A 2025. augusztus 2. előtt forgalomba hozott modellek szolgáltatóinak 2027. augusztus 2-ig kell megfelelniük [AIA]. A szintetikus tartalmat létrehozó, 2026. augusztus 2. előtt forgalomba hozott rendszerek szolgáltatóira 2026. december 2. a határidő [AIA]. A III. melléklet szerinti nagy kockázatú rendszerekre 2027. december 2-től, az I. melléklet szerintiekre 2028. augusztus 2-től alkalmazandók a követelmények [AIA]. A megsértés legfeljebb 15 millió EUR vagy a világpiaci árbevétel 3%-át kitevő bírsággal járhat, az alkalmazók 26. cikk szerinti kötelezettségeit is ideértve [AIA].
- **Önkéntes gyakorlati kódex.** Az általános célú modellek szolgáltatóira vonatkozó kódex önkéntes eszköz [GPAI-COP] [OGYK-IJ-2025-29]. Aláírói között szerepel az Aleph Alpha, az Amazon, az Anthropic, a Google, a Microsoft, a Mistral AI és az OpenAI, az aláírói lista folyamatosan frissül [GPAI-COP].
- **Termékfelelősség.** Az új termékfelelősségi irányelv a 2026. december 9. után forgalomba hozott vagy üzembe helyezett termékekre alkalmazandó [PLD-2024], és a termék fogalmába a szoftvert is beleérti [PLD-2024]. Az MI-felelősségi irányelv javaslata a Bizottság visszavont javaslatainak listáján szerepel [AILD-WITHDRAWAL].
- **Data Act.** Az Adattörvény 2025. szeptember 12-től alkalmazandó [DATA-ACT], és 2027. január 12-től az adatkezelési szolgáltatók nem számíthatnak fel szolgáltatóváltási díjat [DATA-ACT].
- **Folyamatban lévő javaslatok.** Egyik sem hatályos. A digitális omnibusz-csomag a lekérés napján bizottsági döntésre várt, elfogadott szöveg nincs, és a GDPR-t módosítaná [OMNIBUS-DATA-COM837]. A Kiberbiztonsági Aktus felülvizsgálatára tett javaslat a kritikus IKT-ellátási láncok kockázatai között a felhőszolgáltatásokat is nevesíti [CSA-REV-COM11], a Bizottság szerint a szuverenitási szempontokkal és a nem műszaki kockázatokkal kapcsolatos hiányokat a készülő CADA tölti ki [EU-CYBERPKG-QA]. A felhő-szuverenitási javaslat szerint az Unió közrendjének védelmét szolgáló ágazatokban a megrendelők csak 2., 3. vagy 4. uniós biztosítási szintre elismert felhőszolgáltatást szerezhetnének be, a javaslat a hatálybalépés után egy évvel alkalmazandó lenne [EU-CLOUD-SOV-COM502].
- **Hazai tételek.** Az MI-végrehajtási törvény főszabály szerint a kihirdetését követő 31. napon lépett hatályba [MI-VH-TV]. A Kormány az állami felhő- és adatkörnyezet struktúrájának, az adatlokációnak és a kiberbiztonsági követelmények érvényesítésének bemutatására kérte fel az energiaügyi minisztert. A határozat a minisztereket hívja fel feladatra [KORMHAT-1369-2025].
- **DPF-kockázat.** A DPF-re épülő továbbítás jogi alapja két irányból bizonytalan. A Bizottság felfüggesztheti vagy hatályon kívül helyezheti a határozatot, ha a megfelelő védelem már nem biztosított [EU-US-DPF], a Latombe-fellebbezés pedig folyamatban van [EUB-C703-25P].

5.6. Részösszegzés: mit jelent ez a minimum-elvárások szempontjából

A jogi elvárások a következőképpen összegezhetők.

- **Közös alap (SZA).** A GDPR 28. cikke szerinti szerződés (utasítás, alfeldolgozói felhatalmazás, audit, törlés), a 32. cikk szerinti biztonság, az indokolatlan késedelem nélküli incidens-értesítés és az V. fejezet szerinti adattovábbítási jogalap (5.2 és 5.3).
- **Adatkörönként emelkedő követelmények.** Az üzleti titoknál az elvárható titokvédelmi magatartás (UTI). A hivatásbeli titoknál az ügyvédi, orvosi és banktitok külön szabályai, banktitoknál a kiszervezés és az ügyfél felhatalmazása (HIV). A minősített adatnál az engedély, a személyi biztonsági tanúsítvány és a közreműködő ellenőrzése, a közszférában az adatosztályozás, a költség-haszon elemzés és a kilépési terv (KOZ).
- **Változó terep.** Az AI Act alkalmazási időpontjai 2026 és 2028 között követik egymást, a Data Act szolgáltatóváltási szabálya 2027. január 12-től alkalmazandó, az új termékfelelősségi irányelv 2026. december 9-től. A felhő-szuverenitási és a Kiberbiztonsági Aktus javaslata, valamint a digitális omnibusz még nem hatályos (5.5).
- **Nyitott jogi kérdések.** A Hpt. 68. §-a szerinti kiszervezés fogalmának alkalmazása az MI-szolgáltatásra, a nagy kockázatú minősítés a vizsgált használatnál, a minősített adat MI-vel történő feldolgozására vonatkozó kifejezett szabály hiánya a jogszabályi és hatósági források között, valamint a Latombe-fellebbezés kimenetele.

A fejezet nem értékeli, hogy a szolgáltatói vállalások megfelelnek-e ezeknek az elvárásoknak. Az összevetést és a minimum-követelmények megfogalmazását a 6. fejezet végzi, a döntési javaslatot a 9. fejezet adja.

06. FEJEZET

06

Vállalási hiányok és minimum-követelmények

Ez a fejezet a tanulmány második és negyedik vizsgálati kérdésére válaszol: mi elég és mi kevés a szolgáltatói vállalásokból, és minek kellene elvárhatónak lennie. A fejezet a *3. sz. melléklet* **18 vállalási hiányára** (HIA-01–HIA-18) és a *4. sz. melléklet* **30 minimum-követelményére** (MIN-01–MIN-30) épít. Ezek a *2. sz. melléklet* kockázataira (KOC) és a források megállapításaira támaszkodnak. Az értékelés szakértői. A tényállítások mögött forráskód, illetve KOC-, HIA- vagy MIN-azonosító áll.

6.1. Mi számít elégséges vállalásnak

Egy vállalás akkor elég, ha a szervezet számíthat rá, amikor baj van. Ezt négy kérdéssel mértük.

- **Kötelező erejű-e?** A szerződésben vagy a DPA-ban szereplő vállalás köti a szolgáltatót. A súgóoldalon vagy a termékdokumentációban szereplő vállalás (jelölése †) kötőereje a szerződés ismerete nélkül nem állapítható meg.
- **Alapértelmezett-e?** Ami csak külön kérésre, jóváhagyással vagy beállítással érhető el, az gyengébb az alapműködésnél.
- **Ellenőrizhető-e?** Audit-jog, tanúsítvány vagy auditjelentés teszi lehetővé, hogy a szervezet a teljesülést ellenőrizze.
- **Van-e mögötte felelősség?** A vállalás értékét az adja, hogy megszegése következménnyel jár.

A skála négyfokozatú: **elégséges**, **részben elégséges**, **elégtelen** és **nincs vállalás**. Az elégséges vállalás szerződéses szövegben áll, alapértelmezett, és ellenőrizhető vagy felelősség áll mögötte. A részben elégséges vállalás tartalma megfelel, de legalább egy szempont hiányzik, például csak dokumentációban áll. Az elégtelen vállalás tartalmában marad el az elvárástól, vagy a kivételek kiüresítik. A nincs vállalás azt jelzi, hogy a szolgáltató szerződéses szövege megvan, a kérdésben mégsincs vállalás (HIA-13).

A forráshiány külön jelölést kap (**n. a.**), mert nem azonos a vállalás hiányával. Az Aleph Alpha, az OVHcloud, a STACKIT és az IONOS esetében a szerződéses szöveg nincs a forráskészletben, ezért a vállalás nyilvános forrásból nem állapítható meg [OVH-AIE-CAP] [STACKIT-AIMS], néhány további cella pedig azért n. a., mert a katalógus az adott pontra nem rögzít megállapítást (a Mistral HIA-02 és HIA-09, a Google és az AWS HIA-12). Ebből nem következik, hogy a szolgáltató ne vállalna többet. A „nincs vállalás” jel is a katalógus alapján értendő, és nem bizonyítja, hogy a teljes szerződésben ne volna ilyen rendelkezés.

6.2. Ahol a vállalások ma elégségesek

A 18 hiány és 10 szolgáltató 180 cellájából **13 elégséges**. Az elégséges cellák szűk területekre koncentrálódnak, és legtöbbjük az Anthropicnál (5), az OpenAI-nál (3) és a Googlenél (3) található.

- **Tanítási tilalom üzleti szinten.** Az OpenAI, az Anthropic és a Google szerződéses szövegben tiltja az ügyféltartalom tanításra használatát, alapértelmezetten (HIA-01, [OAI-SA], [ANT-CT], [GCP-TERMS]).
- **Feldolgozói szerep.** Az OpenAI és az Anthropic DPA-ja adatfeldolgozóként, az ügyfél utasításaihoz kötve határozza meg a szolgáltatót (HIA-10, [OAI-DPA], [ANT-DPA]).
- **Törlés a megszűnéskor.** Az OpenAI és az Anthropic 30 napon belül töröl vagy visszaad, az Anthropic az alfeldolgozóknál is (HIA-03, [OAI-SA], [ANT-DPA]).
- **Alapszintű titkosítás.** Az Anthropic, a Google és a Microsoft szerződéses szinten vállal alapértelmezett titkosítást (HIA-09, [ANT-DPA], [GCP-DPA], [MSFT-DPA]).
- **Egyedi vállalások.** Az AWS DPA-ja az ügyfél által megadott régióhoz köti a feldolgozást (HIA-06, [AWS-DPA]), a Google teljes felelősséget vállal az alfeldolgozóiért (HIA-08, [GCP-DPA]), az Anthropic órában mért, 48 órás incidens-értesítési határidőt nevesít (HIA-11, [ANT-DPA]).

Két korlátot érdemes látni. Egyetlen hiány összesített értékelése sem elégséges, mert az elégséges cellák a szolgáltatók kisebbségét jelentik, a tanítási tilalomnál a tízből hármat (HIA-01). Az elégséges vállalás mögött ráadásul gyakran nincs érdemi felelősség: az OpenAI és az Anthropic felelőssége az esemény előtti 12 hónapban fizetett díjra korlátozott (HIA-12, [OAI-SA], [ANT-CT]).

6.3. A legfontosabb vállalási hiányok

A 18 hiány közül nyolc témakör határozza meg leginkább a döntést.

Nincs adatvédelmi kártalanítás (HIA-13). Mind a hat szerződéses szolgáltató kártalanítást ad harmadik fél szellemi tulajdoni igényeire [OAI-SA] [MIS-CT], a generált kimenettel kapcsolatos igényekre kifejezetten az Anthropic, a Google, a Microsoft és az AWS [ANT-CT] [GCP-TERMS] [MSFT-CCC] [AWS-SVC-TERMS]. Adatvédelmi incidens miatti kártalanítási vállalást viszont a katalógus egyiknél sem rögzít. Ha a szervezet adata szivárog, a kár megtérítése szerződéses kártalanítás nélkül a felelősségi szabályokra támaszkodhat [GDPR], amelyeket a 7. fejezet vizsgál.

Tizenkét havi díjplafon (HIA-12). Az OpenAI, az Anthropic és a Mistral felelőssége az esemény előtti 12 hónapban fizetett díjra korlátozott [OAI-SA] [ANT-CT] [MIS-CT], a Microsoft az adattörlésért felelősséget nem vállal [MSFT-DPA]. Adatvédelmi incidensnél a kár a díjtól független lehet, az MNB pedig a kárral arányos biztosítékot várja el [MNB-2-2025].

Órában mért incidenshatáridő hiánya (HIA-11). A szerződések az „indokolatlan késedelem nélkül” szöveget használják, egyedül az Anthropic nevesít 48 órát [ANT-DPA]. A közszférában 24 órás bejelentési határidő van [NIS2] [KORM-418-2024]. A Mixpanel-esetben a Mixpanel 2025. november 9-én szerzett tudomást a támadásról, és november 25-én osztotta meg az érintett adatkészletet az OpenAI-jal [OAI-INC-MIXPANEL].

Dokumentációs vállalások (HIA-15). A 190 szolgáltatói megállapításból 96 nem szerződéses dokumentumra épül. A ZDR, a megőrzés és a feldolgozási hely egy része ilyen forráson áll, kötőerejük a konkrét szerződés ismerete nélkül nem állapítható meg [OAI-DATA-CTRL] [ANT-ZDR] [MSFT-FDP].

Fogyasztói és ingyenes szint (HIA-02). Ugyanaz a márka fogyasztói szinten fejlesztési felhasználást és emberi felülvizsgálatot engedhet [OAI-TOU-F] [ANT-CONSUMER-F] [GOOG-GEMINI-API]. Olyan szolgáltatói vállalás, amely a fogyasztói szinten bevitt üzleti adatot védené, nincs.

Megőrzés, emberi hozzáférés és ZDR (HIA-04, HIA-05). A jelölt tartalom megőrzése az Anthropicnál 2 évre nő [ANT-RETENTION], az OpenAI-nál a gyanított CSAM-tartalmú képek ZDR mellett is kézi felülvizsgálatra megmaradnak [OAI-DATA-CTRL]. A ZDR jóváhagyáshoz kötött [OAI-DATA-CTRL], a Microsoft forrásaiban pedig ilyen vállalás nincs.

Feldolgozási hely (HIA-06). A Microsoft 365 Copilot flex routingja csúcsidőszakban az EU Data Boundary-n kívülre viheti a következtetést, és a 2026. március 25. után létrehozott jogosult bérlőknél alapértelmezésben be van kapcsolva [MSFT-M365-FLEX]. Az Anthropic forrásaiban földrajzi vállalás nincs [ANT-DPA].

Technikai támadások és izoláció (HIA-16, HIA-17). Szerződéses szolgáltatói vállalás az injekciós támadás, a kimeneti kiszivárogtatás, a memorizáció és az ügyfelek közötti izoláció ellen nincs (KOC-11, KOC-12, KOC-13, KOC-16). A Microsoft 365 Copilot CVE-2025-32711 sérülékenysége és az OpenAI 2023-as gyorsítótár-hibája mutatja, hogy a kockázat a gyakorlatban is előfordul [MSRC-CVE-2025-32711] [OAI-INC-REDIS].

6.4. Szolgáltatói csoportonkénti kép

A szolgáltatónkénti mátrix a három szolgáltatói csoportban eltérő képet mutat.

A táblázat a 18 hiány celláinak eloszlását mutatja szolgáltatónként.

OpenAI	3	7	6	2	0
Anthropic	5	5	4	4	0
Google	3	10	2	2	1
Microsoft	1	10	3	4	0
AWS	1	11	2	3	1
Mistral	0	8	5	3	2
Aleph Alpha	0	4	0	0	14
OVHcloud	0	5	0	0	13
STACKIT	0	5	0	0	13
IONOS	0	8	0	0	10

Nagy LLM-szolgáltatók (OpenAI, Anthropic). Ezeknek a legerősebb a szerződéses szövegük. Az Anthropic öt hiánynál elégséges (HIA-01, HIA-03, HIA-09, HIA-10, HIA-11), az OpenAI hárommal (HIA-01, HIA-03, HIA-10). A gyenge pontjuk a ZDR és a megőrzés dokumentációs jellege, a 12 havi plafon és a kártalanítás hiánya (HIA-04, HIA-05, HIA-12, HIA-13). Az Anthropicnál földrajzi vállalás nincs (HIA-06).

Hyperscalerek (Google, Microsoft, AWS). A szerződéses szöveg itt is megvan, a kulcsvállalások nagyobb része viszont dokumentációban áll. A Microsoftnál a tanítási tilalom, a hely és a visszaélés-figyelés is ilyen (HIA-15), ZDR-vállalás nincs (HIA-05), a Copilot flex routingja pedig alapértelmezett (HIA-06). Az AWS-nél a hely szerződéses [AWS-DPA], a ZDR viszont dokumentációs [AWS-BEDROCK-RETENTION]. A Google DPA-ja bármely országot engedi, ahol létesítménye van, a listás szolgáltatásoknál viszont régió választható [GCP-DPA] [GCP-TERMS]. A Google és az AWS esetében a felelősségi plafon a forráskészletből nem állapítható meg (HIA-12).

EU-s szolgáltatók (Mistral, Aleph Alpha, OVHcloud, STACKIT, IONOS). A kép itt részben forráshiány. A négy utóbbi szolgáltató 72 cellájából 50 n. a., vagyis a szerződéses szöveg hiánya miatt nem értékelhető. A megmaradó 22 cella mind részben elégséges, és 21 közülük nem szerződéses dokumentumra épül (†). Ez nem azt jelenti, hogy az EU-s szolgáltatók kevesebbet vállalnának, csak azt, hogy a vállalás nyilvános forrásból nem állapítható meg [OVH-AIE-CAP] [STACKIT-AIMS] [IONOS-DATA]. A Mistral az egyetlen európai szolgáltató, amelynél a DPA és a kereskedelmi feltételek szövege is megvan. Itt a hiány tartalmi: a DPA tanítást enged az opt-out hiányában [MIS-DPA], a Mistral a tanítás és a moderáció során adatkezelőként is eljár [MIS-DPA], felelőssége pedig 12 havi díjra korlátozott [MIS-CT].

6.5. Minek kellene elvárhatónak lennie

A hiányokra a *4. sz. melléklet* **30 minimum-követelménye** (MIN) ad választ. A követelmények a szolgáltatóval szemben (MIN-01–MIN-22) és az igénybe vevő szervezettel szemben (MIN-23–MIN-30) fogalmaznak meg elvárást. A MIN követelmény-megfogalmazás, nem szerződésszöveg.

Az **erősség** azt mutatja meg, mekkora súllyal támasztja alá a követelményt a forrás. 15 MIN **jogszabályi**, vagyis kötelező erejű jogszabályból következik, például a törlés vagy visszaadás (MIN-06, [GDPR]), az alfeldolgozói felhatalmazás (MIN-10, [GDPR]) és az audit lehetővé tétele (MIN-16, [GDPR]). Három MIN **hatósági elvárás**, például a kárral arányos biztosíték és a kártérítés rögzítése (MIN-21, MIN-22, [MNB-2-2025]). 12 MIN **szakmai ajánlás**, például a ZDR, a használat közbeni védelem és az izoláció (MIN-05, MIN-13, MIN-14, [OWASP-LLM], [BSI-C5-2026], [ANSSI-SECNUMCLOUD]). Ahol a forrás nem kötelező erejű, a követelményt sem tekintjük kötelezőnek.

A követelmények **hét csoportba** tartoznak: adatfelhasználás és megőrzés, helyszín és továbbítás, alfeldolgozók, biztonság és titkosítás, ellenőrizhetőség és audit, incidens és felelősség, valamint szervezeti kontrollok. A 22 szolgáltatói követelmény közül hatot (MIN-01, MIN-06, MIN-07, MIN-10, MIN-11, MIN-20) teljes egészében teljesít legalább egy szolgáltató a mai piacon, a többit egyik sem teljesíti teljesen.

Adatkörönként emelt szint is van. Az alapszint a személyes adatra (SZA) és az üzleti titokra (UTI) vonatkozik. A hivatásbeli titoknál (HIV) és a közszféra-adatnál (KOZ) az 5. fejezetben ismertetett jogi elvárások szigorúbb vagy kiegészítő feltételeket rögzítenek. 19 MIN-nél emelt szintű a HIV, 12 MIN-nél a KOZ adatkör. Példa a bank esetében a Felügyelet ellenőrzési joga (MIN-18, [HPT]), a közszférában a 24 órás incidens-értesítés lehetővé tétele (MIN-20, [NIS2], [KORM-418-2024]), a minősített adatnál a Nemzeti Biztonsági Felügyelet engedélye (MIN-29, [MAVTV]). Emelt szint csak ott szerepel, ahol az 5. fejezetben ismertetett jogi elvárások alátámasztják.

6.6. Mi várható

A szabályozás több ponton változik, a hatás a vállalásokra azonban többnyire közvetett. A hatályos, de még nem alkalmazandó tételeket és a javaslatokat külön kezeljük.

- **AI Act.** A modellszolgáltatók kötelezettségei és a titokvédelem 2025. augusztus 2-től alkalmazandók [AIA], az általános alkalmazási kezdőnap 2026. augusztus 2. volt [AIA], a korábban forgalomba hozott modellekre 2027. augusztus 2. a határidő [AIA]. A modellszolgáltatónak dokumentációt kell adnia a modellt beépítő szolgáltatónak az üzleti titok védelme mellett [AIA], a rendszerszintű kockázatot jelentő modellnél pedig kiberbiztonsági védelem is kell [AIA]. Ez a HIA-15 és a HIA-16 területén hozhat előrelépést, az ügyfél szerződéses vállalásaira gyakorolt hatása a forrásokból nem állapítható meg.
- **Data Act.** 2027. január 12-től az adatkezelési szolgáltatók nem számíthatnak fel szolgáltatóváltási díjat [DATA-ACT]. Ez a kilépési feltételeket érinti (HIA-03, HIA-18).
- **Termékfelelősség.** A 2026. december 9. után forgalomba hozott termékekre alkalmazandó irányelv a szoftvert is termékként kezeli [PLD-2024], az MI-felelősségi irányelv javaslatát visszavonták [AILD-WITHDRAWAL]. A szerződéses plafonra (HIA-12) gyakorolt hatás a

katalógusból nem állapítható meg.

- **DPF.** A Bizottság a határozatot felfüggesztheti vagy hatályon kívül helyezheti [EU-US-DPF]. Az SCC tartalék alapot ad, az ügyfél tájékoztatására viszont a katalógus vállalást nem rögzít (HIA-07, KOC-10).
- **Nem hatályos javaslatok.** A felhő-szuverenitási javaslat az Unió közrendjét szolgáló ágazatokban csak 2., 3. vagy 4. szintre elismert szolgáltatás beszerzését engedné [EU-CLOUD-SOV-COM502], a Kiberbiztonsági Aktus felülvizsgálata a felhőszolgáltatásokat is nevesíti [CSA-REV-COM11], a digitális omnibusz a GDPR-t módosítaná [OMNIBUS-DATA-COM837]. Egyik sem hatályos.
- **Szolgáltatói oldal.** Az AWS programszintű ZDR-je 2026. december 31-ig él [AWS-BEDROCK-ABUSE]. A STACKIT AI Model Serving v1.4 leírása 2026. november 6-tól hatályos, szövege nem volt a forráskészlet része [STACKIT-AIMS]. A tervezett Cohere–Aleph Alpha egyesülés a jogi keretet változtathatja [ALEPH-COHERE].

A forrásokban nincs olyan hatályos vagy közelgő kötelező változás, amely a legsúlyosabb szerződéses hiányokat (HIA-12, HIA-13) közvetlenül megszüntetné. Ezek kezelése ezért elsősorban az ügyfél szerződéses és beszerzési feltételein múlik.

6.7. Részösszegzés: mit jelent ez a döntés szempontjából

A fejezet megállapításai a következők.

Van elégséges vállalás, de szűk körben. A tanítási tilalom, a feldolgozói szerep, a törlés és az alapszintű titkosítás szerződéses szinten több szolgáltatónál rendben van (6.2). Egyetlen hiány összesített értékelése sem elégséges.

A legsúlyosabb hiányok a felelősség és a kötőerő körül vannak. Nincs adatvédelmi kártalanítás, a felelősség 12 havi díjra korlátozott, az incidenshatáridő többnyire nincs órában rögzítve, a szolgáltatói megállapítások mintegy fele dokumentációra épül (HIA-11, HIA-12, HIA-13, HIA-15).

A kép szolgáltatói csoportonként eltér. A nagy LLM-szolgáltatók szerződéses szövege a legerősebb, a hyperscalereknél a kulcsvállalások nagyobb része dokumentációs, az EU-s szolgáltatóknál a kép részben forráshiány miatt nem értékelhető (6.4).

A minimum-követelmények. A *4. sz. melléklet* 30 követelménye három erősségi szinten, adatkörönként alap vagy emelt szinten mondja meg, minek kellene elvárhatónak lennie (6.5). A feltételek egyoldalú módosíthatóságát a katalógus nem vizsgálta. A KOC-18 (érzékeny adat bevitele nem jóváhagyott eszközbe) szervezeti kérdés, ezért nincs HIA-ja.

A 7. fejezet azt vizsgálja, hogy a hiányok miatt bekövetkező incidens esetén milyen jogérvényesítési utak állnak rendelkezésre. A 8. fejezet a konstrukciókat adatkörönként értékeli a minimum-követelmények alapján, a döntési javaslatot pedig a 9. fejezet adja.

07

07. FEJEZET

Jogérvényesítés incidens esetén

Ez a fejezet a tanulmány ötödik vizsgálati kérdésére válaszol: ha MI-szolgáltatás igénybevételekor baj lesz, érvényesíthetők-e a jogok, és hogyan. A fejezet a jogszabályi és hatósági források, valamint a bírósági gyakorlat és a hatósági eljárások megállapításaira, a *2. sz. melléklet* kockázataira (KOC) és a *3. sz. melléklet* hiányaira (HIA) épül. Az értékelés szakértői, jogi tanácsadásnak nem minősül, és jogi kimenetelt nem jósol. A tényállítások mögött forráskód, illetve KOC-, HIA- vagy MIN-azonosító áll.

7.1. Ki, kivel szemben, milyen úton

A jogérvényesítési utak két családba tartoznak. A **szerződéses út** a megrendelő szervezeté, amely a szolgáltatóval szerződött, és igényét a szerződéses feltételek szerint érvényesíti. A **törvényi utak** a GDPR-ből és a kapcsolódó uniós jogból következnek, és elsősorban az érintetteket illetik meg. Ide tartozik a kártérítés az adatkezelővel és az adatfeldolgozóval szemben [GDPR], a panasz a felügyeleti hatóságnál [EUB-C311-18], a bírósági jogorvoslat [GDPR] és a nonprofit egyesületek keresete [EUB-C319-20].

A szervezet kettős helyzetben van. Az érintettel szemben adatkezelőként felel. A Bíróság szerint az adatkezelő a nevében eljáró adatfeldolgozó adatkezeléséért is felel, és vele szemben bírság szabható ki [EUB-C683-21]. A kárt nem háríthatja át azzal, hogy az irányítása alatt eljáró személy mulasztott [EUB-C741-21]. A szolgáltatóval szemben viszont megrendelő, és a szerződés alapján léphet fel. A két helyzet nem esik egybe. A szervezet az érintettnek akkor is felelhet, ha a szolgáltatóval szemben csak korlátozott igénye van. Ezt a rést a hiányelemzés mutatja meg: a 12 havi díjplafon (HIA-12) és az adatvédelmi kártalanítás hiánya (HIA-13). Ez szakértői következtetés.

A szolgáltató felelőssége az érintettel szemben szűkebb. Adatfeldolgozóként csak az őt kifejezetten terhelő kötelezettségek megsértéséért vagy az utasítások figyelmen kívül hagyásáért felel [GDPR]. A feldolgozott ítéletek között nincs olyan, amely az adatfeldolgozó 82. cikk szerinti felelősségét közvetlenül elbírálná. A jogszabályi és hatósági források az adatkezelő és az adatfeldolgozó közötti belső megtérítési igényt (visszkeresetet) sem rögzítik. Mindkettő a forrásokból nem állapítható meg.

A vizsgálat tíz jogérvényesítési utat azonosított, és mindegyiknél azt nézte meg, ki élhet vele, kivel szemben, mi a jogalapja, mit lehet elérni és mi korlátozza. Csak olyan utat vett fel, amelyet a jogszabályi és hatósági források vagy a bírósági gyakorlat és a hatósági eljárások legalább egy megállapítása alátámaszt.

7.2. Szerződéses igények és korlátaik

A szerződéses út a legközvetlenebb, mert a szervezet szerződő fél. Az értéke viszont a feltételeken múlik. **Három szolgáltató** felelőssége, az OpenAI, az Anthropic és a Mistral főszabály szerint az esemény előtti **12 hónapban fizetett díjra** korlátozott. Kivétel a kártalanítási kötelezettség, az OpenAI-nál és a Mistralnál a súlyos gondatlanság és a szándékosság is [OAI-SA] [ANT-CT] [MIS-CT]. Az Anthropic a közvetett károkat is kizárja [ANT-CT]. A Microsoft a DPA szerint az adattörlésért nem vállal felelősséget [MSFT-DPA]. A Google és az AWS esetében a katalógus a plafonra megállapítást nem tartalmaz, ezért az a forrásokból nem állapítható meg (HIA-12).

A plafon és a kár nem arányos. Adatvédelmi incidensnél a kár a fizetett díjtól független lehet. Az MNB ezért a kárral arányos biztosítékot és a kártérítés szerződéses rögzítését várja el ([MNB-2-2025], HIA-12). A szerződéses kártalanítás a szellemi tulajdoni igényekre terjed ki. A generált kimenetre kifejezetten az Anthropic, a Google, a Microsoft és az AWS vállal kártalanítást [ANT-CT] [GCP-TERMS] [MSFT-CCC] [AWS-SVC-TERMS]. Az OpenAI és a Mistral kártalanítása harmadik fél szellemi tulajdoni igényére szól [OAI-SA] [MIS-CT]. **Adatvédelmi incidens miatti kártalanítási vállalást** a katalógus egyik szolgáltatónál sem rögzít (HIA-13).

A vállalás kötőereje. A szolgáltatói megállapítások mintegy fele nem szerződéses forrásra épül, ezért a kötőerejük a szerződés ismerete nélkül nem állapítható meg (HIA-15). A CCBE szerint a szerződés rendelkezései mellett azt is ellenőrizni kell, hogy a szerződés mennyire érvényesíthető ténylegesen [CCBE-TECH].

Joghatóság és alkalmazandó jog. Az uniós tagállamban székhellyel rendelkező szolgáltató főszabály szerint ott perelhető. A felek más tagállam bíróságának joghatóságában is megállapodhatnak, és ez eltérő megállapodás hiányában kizárólagos [BRUSSELS-IA]. A szerződésre a választott jog az irányadó, jogválasztás hiányában a szolgáltató szokásos tartózkodási helye szerinti jog [ROME-I]. A szolgáltatók ilyen kikötései a katalógusban nincsenek, ezért az, hogy hol és mely jog szerint lehetne a szolgáltatót perelni, a forrásokból nem állapítható meg. A Bíróság a fogyasztói joghatósági védelmet a szakmai célú szerződésektől elválasztotta [EUB-C498-16], ezért a szervezet mint üzleti ügyfél nem alapozhat ilyen védelemre. A szerződéses jogérvényesítés időtartamáról és költségéről a forrásokból nem állapítható meg.

7.3. A GDPR szerinti kártérítés az EUB gyakorlatában

A GDPR 82. cikke az érintettnek ad kártérítési jogot az adatkezelővel és az adatfeldolgozóval szemben [GDPR]. Az Európai Unió Bírósága 2023 óta több ítéletben tisztázta a feltételeit. Az **alapfeltétel hármas**: jogsértés, kár és okozati kapcsolat. A puszta jogsértés nem elég [EUB-C300-21] [EUB-C741-21], súlyossági küszöböt viszont nem lehet állítani [EUB-C300-21], és a kárt az érintettnek kell bizonyítania [EUB-C687-21].

A kár fogalma tág. Az adatok feletti rendelkezés korlátozott ideig tartó elvesztése is lehet nem vagyoni kár [EUB-C200-23]. A jogosulatlan továbbítás miatti félelem és harag szintén, ha az érintett bizonyítja [EUB-C655-23]. A visszaéléstől való félelem csak akkor elég, ha az ügy körülményei között megalapozott [EUB-C340-21], és nem elég, ha a jogosulatlan harmadik fél bizonyítottan nem szerzett tudomást az adatról [EUB-C687-21].

A bizonyítási teher az adatkezelőn van. A biztonsági intézkedések megfelelőségét az adatkezelőnek kell bizonyítania [EUB-C340-21], a vétkességet vélelmezni kell [EUB-C667-21]. A harmadik személy támadása önmagában nem mentesít. Az adatkezelőnek azt kell bizonyítania, hogy a kárt előidéző eseményért őt semmilyen módon nem terheli felelősség [EUB-C340-21]. A jogosulatlan hozzáférés ugyanakkor önmagában nem bizonyítja, hogy az intézkedések nem voltak megfelelők [EUB-C340-21].

A kártérítés kompenzációs. A tényleges kár teljes megtérítését szolgálja, büntető funkció nélkül [EUB-C667-21]. A vétkesség súlyossága nem számít [EUB-C655-23], az összeget pedig a nemzeti jog szabályai szerint kell megállapítani [EUB-C300-21].

Ez a szervezetnek fontos üzenet: adatkezelőként ő viseli a kitettséget. A szolgáltatóval szemben a szerződéses út marad, amelynek plafonjáról és kizárásairól az előző alfejezet szólt. Az ítéletek egyike sem MI-szolgáltatással kapcsolatos, az elvek vonatkoztatása szakértői. Szivárgás esetén a szervezet azért kerülhet nehéz helyzetbe, mert a megfelelőség bizonyítása a szolgáltatótól kapott dokumentációt igényel, az ügyfél-audit viszont korlátozott gyakoriságú, az ügyfél költségén történik és bizalmassági megállapodáshoz kötött (HIA-14).

7.4. Hatósági eljárások: mit érnek el és mit nem

A felügyeleti hatóság az érintett panasza alapján köteles eljárni [EUB-C311-18], és korrekciós intézkedést vagy bírságot alkalmazhat. A feldolgozott hatósági ügyek MI-szolgáltatókat érintenek. A Garante **15 millió euró** bírságot és hat hónapos tájékoztató kampányt írt elő az OpenAI-ra ([GARANTE-OPENAI], a határozatot később megsemmisítették), **5 millió euró** bírságot a Replika üzemeltetőjére [GARANTE-REPLIKA], a DeepSeek adatkezelését pedig azonnali hatállyal korlátozta [GARANTE-DEEPSEEK]. A holland hatóság **30,5 millió euró** bírságot szabott ki a Clearview-ra [AP-CLEARVIEW-HAT].

A Garante és az OpenAI ügy tanulsága. A legnagyobb bírságot a Tribunale di Roma 2026. március 18-án megsemmisítette [TRIB-ROMA-4153-26]. Az indok eljárási volt. Az OpenAI ír leányvállalatának 2024. február 15-i létrejöttével az egyablakos ügyintézés szabályai szerint az eljárást az ír hatóságnak kellett volna átadni, így a Garante határozata hatáskör hiányában született [TRIB-ROMA-4153-26]. A bíróság a többi jogalapot nem vizsgálta [TRIB-ROMA-4153-26]. Az érdemi kérdésekben, vagyis az incidens be nem jelentésében, a jogalapban, az átláthatóságban és a korhatár-ellenőrzésben ezért nem döntött. A megsemmisítés tehát a jogsértéseket sem nem cáfolja, sem nem erősíti meg. A per ideiglenes szakaszában a bírság végrehajtásának felfüggesztését a teljes összegre szóló garanciához kötötték [TRIB-ROMA-4153-26]. A forrásolt időrend szerint a vizsgálat 2023 márciusában indult [GARANTE-OPENAI], a bírósági ítélet 2026 márciusi.

Mit nem ér el a hatósági út. A hatósági bírság az érintettnek vagy a megrendelőnek közvetlenül nem jelent kártérítést. A Bíróság a 82. cikk szerinti kártérítést kompenzációs, a 83. és 84. cikk szerinti bírságot és szankciót büntető célúnak tekinti [EUB-C667-21]. A feldolgozott hatósági ügyek egyike sem rögzít kártérítést az érintetteknek. A bírság a szándékos vagy gondatlan jogsértéshez kötött [EUB-C683-21], jogi személlyel szemben is kiszabható [EUB-C807-21].

Harmadik országbeli szolgáltató. A DeepSeek társaságok azt közölték, hogy nem működnek Olaszországban, és rájuk az európai szabályozás nem alkalmazható [GARANTE-DEEPSEEK]. A holland hatóság a Clearview-ra az uniós székhely nélkül is alkalmazta a GDPR-t [AP-CLEARVIEW-HAT]. A társaság viszont a korábbi bírságok után sem látszik változtatni a magatartásán, ezért a hatóság a vezetők személyes felelősségét vizsgálja [AP-CLEARVIEW-PK]. A szolgáltatás igénybevevőjét is fenyegetheti bírság: a holland hatóság a Clearview szolgáltatásának használatát is tiltottnak minősítette [AP-CLEARVIEW-PK]. Ez a forrás arcfelismerő szolgáltatásról szól. Hogy ez az általános MI-szolgáltatásokra is igaz-e, a forrásokból nem állapítható meg.

7.5. Adattovábbítás és harmadik országbeli szolgáltató: Schrems II, DPF és Latombe

A harmadik országba továbbított adat jogérvényesítési kérdése a jogalap stabilitásán múlik. A Schrems II ítélet az EU–USA adatvédelmi pajzs határozatát érvénytelennek mondta ki [EUB-C311-18]. A 2010/87/EU határozat szerinti standard szerződéses kikötések (SCC) érvényességét nem találta érintettnek [EUB-C311-18], azzal, hogy az érintettek jogainak lényegében azonos védelmi szintet kell biztosítaniuk [EUB-C311-18]. Az adatkezelőnek esetről esetre ellenőriznie kell a célország védelmi szintjét, és ha az nem biztosítható, a továbbítást fel kell függesztenie [EUB-C311-18]. Az ítélet ezt az uniós adatkezelő vagy adatfeldolgozó feladatává teszi, ezért a szervezetnek adatkezelőként saját feladatként kell számolnia vele (szakértői következtetés). Az SCC szerint az adatátvevő felel az érintettnek, aki kártérítésre jogosult [SCC].

A DPF és a Latombe-ügy. Az OpenAI, az Anthropic, a Microsoft és a Mistral SCC-re épít, a Microsoft emellett DPF-tanúsítvánnyal is rendelkezik [OAI-DPA] [ANT-DPA] [MSFT-DPA] [MIS-DPA]. A Törvényszék a DPF-megfelelőségi határozat megsemmisítésére irányuló keresetet 2025. szeptember 3-án elutasította [EUB-T553-23]. Az ítélet szerint a határozat jogszerűségét az elfogadásának időpontjában fennálló helyzet alapján kell értékelni [EUB-T553-23]. A Bizottság viszont folyamatosan figyelemmel kíséri a keretet, és felfüggesztheti a határozatot [EUB-T553-23] [EU-US-DPF].

Folyamatban lévő fellebbezés. Latombe 2025. október 31-én fellebbezett a Törvényszék ítélete ellen (C-703/25 P). A letöltött hivatalos lapi közlemény a fellebbezés benyújtását és a jogalapokat rögzíti, ítéletet vagy főtanácsnoki indítványt nem tartalmaz [EUB-C703-25P]. **Az ügy állását a CURIA oldalán újra ellenőrizni kell.** A tanulmány ezért a DPF jogalapját nem kezeli véglegesnek (KOC-10).

A DPF-re épülő továbbításnál a jogérvényesítési kockázat kettős. A jogalap megdőlhet [EUB-C703-25P], a továbbítást pedig a felügyeleti hatóság döntése is felfüggesztheti [EUB-C311-18]. A GDPR megfelelő garanciaként az SCC-t is elfogadja [GDPR], de az SCC alkalmazásához is kell a védelmi szint ellenőrzése [EUB-C311-18]. A harmadik országbeli hatósági hozzáférés kockázatát a KOC-09, a jogalap bizonytalanságát a KOC-10 és a HIA-07 rögzíti.

7.6. Részösszegzés: érvényesíthetők-e a jogok, és mi következik a szerződéskötésre

Az őszinte válasz: **elvben igen, gyakorlatban korlátozottan.** A törvényi utak léteznek, és az uniós bírósági gyakorlat az érintettnek kedvező bizonyítási szabályokat adott [EUB-C340-21] [EUB-C667-21]. Öt megállapítás adja a választ.

Az érintett jogai érvényesíthetők, de a kitettség a szervezetnél van. Az adatkezelő a nevében eljáró adatfeldolgozó adatkezeléséért is felel [EUB-C683-21], a szolgáltató felelőssége szűkebb [GDPR]. A szervezet ezért a szolgáltató mulasztásából eredő igényekkel is szembesülhet.

A szerződéses út korlátozott. A 12 havi díjplafon [OAI-SA] [ANT-CT] [MIS-CT] és az adatvédelmi kártalanítás hiánya (HIA-12, HIA-13) a megtéríthető kárt korlátozza. A Google és az AWS plafonja a forrásokból nem állapítható meg.

A hatósági út nem kártérítés, és a kimenetele bizonytalan. A bírság az érintettnek vagy a megrendelőnek közvetlenül nem jár [EUB-C667-21]. A legnagyobb MI-ügyben a határozatot hatásköri okból megsemmisítették, az érdemi kérdést nem döntötték el [TRIB-ROMA-4153-26].

Harmadik országbeli szolgáltatónál a jogalap és a joghatóság bizonytalan. A DPF-határozatot a Törvényszék fenntartotta, de a fellebbezés folyamatban van, és az állás a CURIA oldalán újra ellenőrizendő [EUB-T553-23] [EUB-C703-25P]. A szolgáltatók jogválasztási és fórumkikötései a katalógusban nincsenek.

A forráskészlet nem tud mindent megmondani. A feldolgozott források között nincs olyan ítélet vagy hatósági határozat, amely MI-szolgáltatóval szembeni kártérítési igényt bírált volna el. Nem állapítható meg a visszkereset kérdése, az üzleti titok megsértése miatti igény jogkövetkezménye, a termékfelelősségi irányelv MI-szolgáltatásra gyakorolt hatása, valamint a jogérvényesítés időtartama és költsége (a hatósági és bírósági út kivételével, ahol egy ügy időrendje ismert). A tanulmány ezekre nem ad választ, és kimenetelt nem jósol.

Mi következik a szerződéskötésre. A jogérvényesítés hatékonysága a szerződés megkötésekor dől el. A *4. sz. melléklet* ezért három követelményt fogalmaz meg erre a rétegre: az órában mért incidens-értesítési határidőt (MIN-20), az adatvédelmi károkat nem kizáró vagy a várható kárral arányos külön plafont előíró felelősségkorlátozást (MIN-21), valamint a szellemi tulajdoni mellett az adatvédelmi kártalanítást (MIN-22). A MIN-21 és a MIN-22 követelményt egyik szolgáltató sem teljesíti, a MIN-20 követelményt csak az Anthropic, és az is 48 órával, ami a 24 órás határidővel dolgozó szervezeteknek kevés lehet (HIA-11). A 8. fejezet a konstrukciókat értékeli, és ezt a jogérvényesítési kitettséget is figyelembe veszi.

08. FEJEZET

08

A konstrukciók értékelése adatkörönként

Ez a fejezet a tanulmány döntési kérdésére készíti elő a választ: mely szolgáltatói és szerződéses-technikai konstrukció mellett vállalható az MI-feldolgozás, és adatkörönként milyen feltételekkel. A fejezet értékelést és feltételrendszert ad, döntési javaslatot nem. A GO/NO-GO javaslat a 9. fejezet feladata. Az értékelés a források megállapításaira, a *2. sz. melléklet* kockázataira (KOC), a *3. sz. melléklet* hiányaira (HIA) és a *4. sz. melléklet* követelményeire (MIN) épül. Szakértői értékelés, jogi tanácsadásnak nem minősül. A tényállítások mögött forráskód, illetve KOC-, HIA-, MIN- vagy KON-azonosító áll.

8.1. Az öt konstrukció

A tanulmány öt konstrukciót (KON) különböztet meg. A felosztás azt követi, hogy ki a szerződő fél, ki üzemelteti a modellt, és hol fut a feldolgozás.

A **KON-01** a fogyasztói SaaS, vagyis az ingyenes és az egyéni előfizetéses chat-felület (ChatGPT Free és Plus, Claude Free és Pro, Gemini app, Le Chat egyéni). A fogyasztói feltételek fejlesztési felhasználást engedhetnek, a DPA-garanciák pedig az üzleti feltételekhez kötődnek [OAI-TOU-F] [ANT-CONSUMER-F] [GDPR].

A **KON-02** az enterprise API és üzleti szolgáltatás ZDR-rel, közvetlen szerződéssel a modellszolgáltatóval (OpenAI, Anthropic, Google, Mistral). Az ügyfél adatkezelő, a szolgáltató a DPA szerint adatfeldolgozó, a Google a számlázási és használati adatnál, a Mistral a tanítás és a moderáció körében önálló adatkezelő is lehet [OAI-DPA] [ANT-DPA] [GOOG-GEMINI-API] [MIS-DPA].

A **KON-03** a hyperscaler EU-régióval (Azure OpenAI és AI Foundry, AWS Bedrock, Google Vertex AI). A Microsoft 365 Copilotot ide soroltuk, mert a szerződéses keret a Microsoft DPA-ja, a feldolgozás helyét az EU Data Boundary határolja, kivétele a flex routing és az Anthropic mint alfeldolgozó [MSFT-DPA] [MSFT-M365-FLEX] [MSFT-M365-COPILOT]. Üzleti SaaS-jellege a KON-02 felé is mutathatna, ezért a besorolás szakértői (8.8).

A **KON-04** az EU szuverén felhő (OVHcloud, STACKIT, IONOS, Aleph Alpha). A mérce a SecNumCloud és a C5 [ANSSI-SECNUMCLOUD] [BSI-C5-2026]. A vállalások nagy része nem szerződéses forrásban áll, a szerződésszövegek többnyire hiányoznak a forráskészletből (HIA-15).

A **KON-05** a helyben futtatott nyílt súlyú modell, saját szerveren vagy saját üzemeltetésű, bérelt infrastruktúrán (Llama, Gemma, Mistral nyílt modellek, Qwen, DeepSeek). Itt a szolgáltatói vállalás kérdése a szervezet saját kontrolljává alakul. A szervezet adatkezelő marad, külső adatfeldolgozó nincs, ha a modellkiadó nem lát adatot (szakértői következtetés az [EDPB-GL07-2020] és a licencek hallgatása alapján: [META-LLAMA-LIC], [GOOG-GEMMA-TOU], [MIS-OPEN-LIC], [QWEN-LIC], [DEEPSEEK-LIC]). Bérelt infrastruktúránál az IaaS-szolgáltató adatfeldolgozó marad.

8.2. Az értékelés módszere

Az értékelés négy lépcsős láncot követ. A KOC azt rögzíti, mi szivároghat (*2. sz. melléklet*), a HIA azt, hogy a szolgáltatók ma mit nem vállalnak (*3. sz. melléklet*), a MIN azt, minek kellene elvárhatónak lennie (*4. sz. melléklet*), a KON pedig azt, hogy egy konstrukció mellett a követelmények teljesülnek-e (ez a fejezet). A maradványkockázatot háromfokú skálán (alacsony, közepes, magas) szakértőileg ítéltük meg, a besorolást forrás-, HIA- és KOC-hivatkozás indokolja.

A döntési mátrix cellája a „KON-nn × adatkör” alak, értéke pontosan egy a háromból: **vállalható**, **feltételekkel vállalható** vagy **nem vállalható**. A kötelező MIN szabálya: kötelező az a MIN, amelynek erőssége Jogszabályi, és szintje az adatkörnél alap vagy emelt (4.A). Ha egy kötelező MIN-t a konstrukcióban ma egyik szolgáltató sem teljesít, és szerződéssel való elérhetősége nem igazolt, a cella legfeljebb feltételekkel vállalható lehet, a feltétel a MIN szerződésbe emelése. Nem vállalható a cella, ha jogszabályi követelmény zárja ki, vagy olyan emelt szintű kötelező MIN hiányzik, amelyhez egyik szolgáltatónál sincs részleges vállalás sem.

A cellaértékeket szkript számította a szolgáltatónkénti mátrix és az adatkörönkénti szintek adataiból, a kézi szakértői korrekciók a 8.8 alfejezetben szerepelnek. Ahol egy cellához nincs elég forrás, a cella mellett forráshiány-megjegyzés áll. A katalógus a szolgáltatók standard feltételeit rögzíti, a teljes ügyfélszerződés nem része a forráskészletnek (HIA-13), ezért az értékelés a konkrét ajánlat átvilágítását nem helyettesíti.

8.3. Személyes adat (SZA)

A GDPR szerint az adatfeldolgozónak garanciákat kell nyújtania, a személyes adatot csak az adatkezelő utasítására kezelheti, alfeldolgozót csak felhatalmazással vehet igénybe, a szerződés megszűnésekor töröl vagy visszaad, és az auditokhoz információt ad [GDPR]. Az incidens bejelentési határideje, 72 óra, az adatkezelőt terheli [GDPR]. Különleges kategóriás adatnál és nagy számú kezelésnél hatásvizsgálat kell ([GDPR], MIN-26).

A **KON-01** nem vállalható. A fogyasztói feltételek fejlesztési felhasználást és emberi felülvizsgálatot engednek, a feldolgozó viszont saját célra nem kezelhet személyes adatot (HIA-02, MIN-01, KOC-02, [OAI-TOU-F], [EDPB-GL07-2020]).

A **KON-02** feltételekkel vállalható. A kötelező MIN-ek közül ma teljesíti a szolgáltatói célhoz kötöttséget az OpenAI, az Anthropic és a Google (MIN-01), a törlést az OpenAI és az Anthropic (MIN-06), az alfeldolgozói felhatalmazást a Google (MIN-10), a titkosítás szerződéses megnevezését az Anthropic és a Google (MIN-11), az incidens-határidőt az Anthropic (MIN-20). A legtöbb kötelező MIN-

t, négyet, az Anthropic teljesíti. Szerződésbe emelendő, mert egyik szolgáltató sem teljesíti: MIN-04 (emberi hozzáférés), MIN-08 (adattovábbítási jogalap és tartalék jogalap), MIN-09 (hatósági kérelem jelentése), MIN-16 (audit).

A **KON-03** szintén feltételekkel vállalható, de több a hiányzó kötelező MIN. A Google a MIN-01, a MIN-10 és a MIN-11 szerint, a Microsoft a MIN-11 szerint teljesít, a MIN-04, MIN-06, MIN-08, MIN-09, MIN-16 és MIN-20 szerződésbe emelendő. A Microsoft nem vállal felelősséget az adattörlésért [MSFT-DPA], a Google és az AWS jogalapot a katalógusban nem rögzít (HIA-07).

A **KON-04** feltételekkel vállalható, forráshiánnyal. A kötelező MIN-ek egyikét sem teljesíti igazolhatóan egyik szolgáltató sem, de ez nem elutasítás: a kapcsolt HIA-cellák n. a. vagy nem szerződéses forrásra épülnek (HIA-15, [OVH-AIE-CAP], [STACKIT-AIMS]). A feldolgozás helyét több szolgáltató az EU-ban közli [STACKIT-CERTS] [IONOS-DATA].

A **KON-05** feltételekkel vállalható. A kötelező szervezeti MIN a hatásvizsgálat (MIN-26), a modell eredetének és anonimitásának vizsgálata az EDPB szerint az elszámoltathatóság része [EDPB-OP28]. A hamburgi hatóság eltérő véleménye szerint a modell tárolása nem adatkezelés, de ez nem a tanulmány alapállása [HMBBFDI-LLM] [CNIL-STATUT-MODELE]. Bérelt infrastruktúránál az IaaS-szerződésre a MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16 és MIN-20 is vonatkozik. Ha az IaaS-szolgáltató EGT-n kívüli, vagy oda továbbít, ehhez jön a MIN-08 és a MIN-09 (elvárt még a MIN-07). A DPF bizonytalansága (KOC-10) a KON-02 és a KON-03 cellát érinti, mert SCC csak az OpenAI, az Anthropic, a Microsoft és a Mistral szerződésében áll [OAI-DPA] [ANT-DPA] [MSFT-DPA] [MIS-DPA].

8.4. Üzleti titok (UTI)

A jogszabályi és hatósági források az üzleti titok MI-szolgáltatónak történő átadását tiltó szabályt vagy külön szerződéses minimumot nem rögzítenek [AIA]. A jogosultnak a titokban tartás érdekében elvárható magatartást kell tanúsítania [UZLETI-TITOK-TV], a nem személyes adatnál a szolgáltatónak intézkednie kell a harmadik országbeli kormányzati hozzáférés ellen [DATA-ACT]. Az üzleti titok védelme ezért elsősorban a szerződéses és technikai kontrollokon múlik.

A **KON-01** nem vállalható, mert a fogyasztói feltételek fejlesztési felhasználást engednek (HIA-02, MIN-01, KOC-01, KOC-02, [OAI-TOU-F]). A kizárás a szerződéses hiányon alapul, nem jogszabályi tiltáson. A **KON-02** és a **KON-03** feltételekkel vállalható. A kötelező MIN-ek a MIN-01, MIN-04, MIN-06, MIN-09, MIN-11, MIN-16 és MIN-20. A KON-02-ben az OpenAI, az Anthropic és a Google a MIN-01-et, az OpenAI és az Anthropic a MIN-06-ot, az Anthropic és a Google a MIN-11-et, az Anthropic a MIN-20-at teljesíti, szerződésbe emelendő a MIN-04, a MIN-09 és a MIN-16. A KON-03-ban a Google a MIN-01-et, a Google és a Microsoft a MIN-11-et teljesíti, szerződésbe emelendő a MIN-04, MIN-06, MIN-09, MIN-16 és MIN-20. A **KON-04** feltételekkel vállalható forráshiánnyal (HIA-15).

A **KON-05** saját szerveren vállalható, mert az UTI adatkörnél az adatkörönkénti szintek szerint nincs kötelező szervezeti MIN. Elvárt alapkontrollok a MIN-23, a MIN-24 és a MIN-25, valamint a nyílt súlyú modellekre vonatkozó biztonsági útmutatók és licencek kontrolljai, amelyek az ellátási lánc, az izoláció és a konfiguráció kockázatát kezelik (KOC-15, KOC-16, KOC-17, [NSA-DEPLOY-AI], [NSA-DEPLOY-AI]). Bérelt infrastruktúránál a cella feltételekkel vállalható, az IaaS-szerződés kötelező MIN-jeivel (MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16, MIN-20). Ha az IaaS-szolgáltató EGT-n

kívüli, vagy oda továbbít, ehhez jön a MIN-08 és a MIN-09 (elvárt még a MIN-07). A memorizáció (KOC-14) az UTI adatkört is érinti, a KON-05-nél ez a modell eredeti tanítóadatából származó visszaadás kockázata [BSI-KRIT-GENKI].

8.5. Hivatásbeli titok (HIV)

A hivatásbeli titok három alkategóriája eltérő feltételt követel. Az ügyvédi titoknál az ügyvédet nem terheli titoktartási kötelezettség az adatfeldolgozóval szemben a szükséges mértékben [UTTV], a MÜK álláspontja szerint az MI-szolgáltató ide tartozik, és az adatfeldolgozási megállapodás rögzítse a modellképzés és a saját célú felhasználás kizárását ([MUK-4-2026], [MUK-4-2026], nem jogszabály). Az orvosi titkot az adatfeldolgozó is köteles megtartani [EUAK]. A banktitok csak törvényi kivétellel vagy az ügyfél okiratba foglalt felhatalmazásával adható ki, kiszervezésnél a szerződésnek tartalmaznia kell a Felügyelet ellenőrzéséhez való hozzájárulást [HPT].

A **KON-01** nem vállalható, mert a tanításba beépülő ügyféladat sértheti a hivatásbeli titoktartást ([CCBE-GENAI], HIA-02, KOC-01). A **KON-02** és a **KON-03** HIV-cellája nem vállalható. A kizáró ok a MIN-18, amely kötelező és emelt szintű, a HIA-18 viszont egyik szolgáltatónál sem teljesül, még részben sem: felügyeleti hozzáférési vagy reverzibilitási vállalás nincs [MNB-2-2025] [HPT]. A kizárás a banktitok kiszervezési útjára igazolt. A jogszabályi és hatósági források nem döntik el, hogy az MI-szolgáltatás kiszervezés-e, az ügyfél felhatalmazása járható út lehet, de a MIN-18 hiányát nem pótolja [HPT]. Ügyvédi titoknál ugyanezek a konstrukciók feltételekkel vállalhatók, a feltételek a MIN-01, MIN-04, MIN-10 és MIN-30 [MUK-4-2026] [UTTV]. Orvosi titoknál a feltétel a szerződés megszűnésekor esedékes díjmentes visszaszolgáltatás (MIN-06) és a különleges adat miatti hatásvizsgálat (MIN-26), a MIN-30 itt nem alkalmazandó [EUAK] [GDPR].

A **KON-04** feltételekkel vállalható forráshiánnyal, mert a HIA-18 cellái n. a. A **KON-05** feltételekkel vállalható. A kötelező szervezeti MIN-ek a MIN-26, a MIN-27, a MIN-28 és a MIN-30. A MIN-30 banktitoknál a kiszervezési kivételt vagy az ügyfél felhatalmazását, ügyvédi titoknál a MÜK szerinti megállapodást jelenti. Hogy a helyben futtatott modell kiszervezésnek minősül-e, a forrásokból nem állapítható meg. Orvosi titoknál a MIN-30 nem alkalmazandó, a feltétel a MIN-26. Bérelt infrastruktúránál az IaaS-szerződésre a MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16 és MIN-20 vonatkozik, ehhez jön a MIN-18 és a MIN-19. Ha az IaaS-szolgáltató EGT-n kívüli, vagy oda továbbít, ehhez jön a MIN-08 és a MIN-09 (elvárt még a MIN-07).

8.6. Közszféra-adat és minősített adat (KOZ)

A nem minősített közszféra-adatnál a nem privát felhő igénybevétele vagy a külföldi adatkezelés előtt adatosztályozás, költség-haszon elemzés és kilépési terv kell, és a vezető csak megalapozott előny esetén dönthet [KIBTV] [KORM-418-2024]. A nemzeti kiberbiztonsági hatóság a felhőhasználatot megtilthatja vagy korlátozhatja [KIBTV]. Az incidensről 24 órán belül első bejelentés kell [KORM-418-2024]. A felhő-szuverenitási javaslat nem hatályos [EU-CLOUD-SOV-COM502].

A **KON-01** nem vállalható (HIA-02, MIN-02, KOC-02). A **KON-02** és a **KON-03** feltételekkel vállalható. A MIN-20 emelt szintje a 24 órás teljesítést kívánja, az Anthropic 48 órás vállalása erre kevés (HIA-11), ezért ennél az adatkörnél a MIN-20 szerződésbe emelendő. Szerződésbe emelendő még a MIN-04,

MIN-08, MIN-09, MIN-16 és MIN-18, a KON-03-ban a MIN-06 is, szervezeti kötelező a MIN-27 és a MIN-28. A **KON-04** feltételekkel vállalható forráshiánnyal, a SecNumCloud-típusú mérce miatt a szerződéses átvilágítás után lehet versenyképes [ANSSI-SECNUMCLOUD]. A **KON-05** feltételekkel vállalható, kötelező a MIN-27 és a MIN-28. Bérelt infrastruktúránál az IaaS-szerződésre a MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16 és MIN-20 vonatkozik, ehhez jön a MIN-18 és a MIN-19. Ha az IaaS-szolgáltató EGT-n kívüli, vagy oda továbbít, ehhez jön a MIN-08 és a MIN-09 (elvárt még a MIN-07).

A **minősített adatot** csak a Nemzeti Biztonsági Felügyelet engedélye alapján lehet kezelni, ahhoz csak személyi biztonsági tanúsítvánnyal és titoktartási nyilatkozattal rendelkező felhasználó férhet hozzá, és a közreműködő védelmi feltételeit az átadás előtt ellenőrizni kell ([MAVTV], [MAVTV], [MAVTV], MIN-29). A jogszabályi és hatósági források az MI-szolgáltatás használatát minősített adatra kifejezetten nem tiltják. A KON-01–KON-04 nem vállalható, mert egyik szolgáltató sem vállalja ezt a három feltételt (HIA-18, HIA-06), vagyis a kizárás következtetés. A KON-05 feltételekkel vállalható az engedély és a hozzáférési feltételek teljesülése esetén, de a forráskészlet nem tárgyalja, hogy helyben futtatott MI-modell minősített adatot kezelő rendszerben engedélyezhető-e, ezért ez forráshiány.

8.7. Javasolt konstrukciók és feltételek

Adatkörönként azt a konstrukciót tüntetjük fel, amelynek a cellaértéke és a kötelező MIN-hiányai a legkedvezőbbek. A feltételekkel vállalható cella nem ma vállalható, hanem a megjelölt MIN-ek teljesítése esetén. A döntési javaslatot a 9. fejezet adja.

Személyes adat. A legkedvezőbb a KON-05, kötelező feltétele a MIN-26 (hatásvizsgálat), a nyílt súlyú modellekre vonatkozó biztonsági útmutatók és licencek kontrolljai és a modell eredetének vizsgálata [EDPB-OP28]. Külső szolgáltató esetén a KON-02, azon belül az Anthropic, a kötelező MIN-ek: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-20, MIN-26. Ezek közül a MIN-04, MIN-08, MIN-09 és MIN-16 szerződésbe emelendő.

Üzleti titok. A legkedvezőbb a KON-05 saját szerveren, vállalható, alapkontrollokkal (MIN-23, MIN-24, MIN-25). Külső szolgáltató esetén a KON-02 feltételekkel vállalható, kötelező MIN-ek: MIN-01, MIN-04, MIN-06, MIN-09, MIN-11, MIN-16, MIN-20. Szerződésbe emelendő a MIN-04, a MIN-09 és a MIN-16.

Hivatásbeli titok. A legkedvezőbb a KON-05, feltételei a MIN-26, MIN-27, MIN-28 és MIN-30 (a MIN-30 banktitoknál és ügyvédi titoknál alkalmazandó, orvosi titoknál nem). A KON-02 és a KON-03 ügyvédi és orvosi titoknál feltételekkel vállalható (ügyvédi titoknál MIN-01, MIN-04, MIN-10 és MIN-30, orvosi titoknál MIN-06 és MIN-26), banktitoknál nem vállalható (MIN-18, HIA-18). A KON-04 a forráshiány miatt nem értékelhető megalapozottan.

Közszféra- és minősített adat. Nem minősített KOZ-adatnál a KON-05 feltételekkel vállalható (MIN-27, MIN-28), a KON-02 és a KON-03 szerződésbe emelendő MIN-04, MIN-08, MIN-09, MIN-16, MIN-18 és MIN-20 mellett (KON-03-ban MIN-06 is). Minősített adatnál csak a KON-05 jöhet szóba, a MIN-29 szerinti NBF-engedély és hozzáférési feltételek mellett, forráshiánnyal.

8.8. Kockázatok, feltételezések, függőségek

Szakértői besorolások. A maradványkockázat, a „kötelező MIN" szerinti számítás és a kézi korrekciók szakértői értékelések. Kézi korrekció a KON-01 minden cellája, a minősített adat kizárása a KON-01–KON-04-nél, a MIN-20 emelt szintjének 24 órás értelmezése és a HIV-cella besorolása a legszigorúbb alkategória szerint. A Microsoft 365 Copilot KON-03-ba sorolása szintén szakértői, az eltérő besorolás (KON-02, üzleti SaaS) a cellaértékeket nem változtatná meg, mert a Microsoft csak a MIN-11-et teljesíti, amelyet a Google is.

Forráshiány az EU-s szolgáltatóknál. A KON-04 szolgáltatóinál a szolgáltatónkénti mátrix celláinak jelentős része n. a., a DPA- és szerződésszövegek nincsenek a forráskészletben [OVH-AIE-CAP] [STACKIT-AIMS] [IONOS-DATA]. A vállalások nem szerződéses forrásban állnak (HIA-15). A KON-04 minden cellája ezért feltételes besorolás, a nem teljesülés nem azonos az elutasítással.

A trust portálok hiánya. Az OAI-TRUST, az ANT-TRUST és az MSFT-STP trust portál tartalma nyilvánosan nem volt elérhető, ezért az onnan származó tanúsítvány-, auditjelentés- és alfeldolgozói információ nincs az értékelésben. A KON-02 és a KON-03 értéke ezek ismeretében javulhat (MIN-10, MIN-17).

A DPF és a C-703/25 P ügy. A DPF jogalapja a Törvényszék ítélete után is bizonytalan, mert a fellebbezés folyamatban van, az ügy állását a CURIA oldalán újra ellenőrizni kell ([EUB-C703-25P], [EUB-C703-25P], KOC-10). A KON-02 és a KON-03 SZA-cellája ettől függ, a tartalék jogalap (SCC) a MIN-08 szerződéses tartalma.

A feltételek egyoldalú változása. A katalógus a szolgáltatói feltételek egyoldalú módosíthatóságát nem vizsgálta, az értékelés a 2026. október 28-i állapotot tükrözi. A változás kockázata konkrét: a Copilot flex routing a 2026. március 25. után létrehozott bérlőknél alapértelmezésben be van kapcsolva [MSFT-M365-FLEX], az AWS program-ZDR-je 2026. december 31-ig szól [AWS-BEDROCK-ABUSE]. Ezért kell a MIN-24 szerinti éves felülvizsgálat.

A KON-05 saját üzemeltetési kapacitásigénye. A KON-05 a szolgáltatói kockázatot a szervezetre telepíti. A modellfájl-ellenőrzés, az izoláció, a titkosítás, a kivezetés és a licenc-átvilágítás a szervezet feladata ([NSA-DEPLOY-AI], [NSA-DEPLOY-AI], [HF-SEC-PICKLE], KOC-15, KOC-17). A szükséges kapacitásról és költségről a forráskészlet nem szól, a modellek minősége és ára a hatókörön kívül van. A bérelt infrastruktúra IaaS-szerződésének feltételeit a szolgáltatónkénti mátrix nem értékeli (forráshiány).

A licencek modellenkénti eltérése. A licenc modellenként és verziónként különbözik. A Llama 700 millió, a Qwen2.5-72B 100 millió havi aktív felhasználói küszöböt tartalmaz, a Devstral 2 módosított MIT licence 20 millió USD havi árbevételi küszöböt [META-LLAMA-LIC] [QWEN-LIC] [MIS-OPEN-LIC]. A Mistral 3 család Apache 2.0, a Gemma 4 Apache 2.0, a Qwen3-8B metaadata szerint Apache 2.0, a DeepSeek R1 MIT [MIS-OPEN-LIC] [GOOG-GEMMA-TOU] [QWEN-LIC] [DEEPSEEK-LIC]. A jogválasztás kaliforniai vagy kínai, a licencek „AS IS" alapon adnak [META-LLAMA-LIC] [QWEN-LIC] [DEEPSEEK-LIC]. A kiadói adathozzáférésről a licencek hallgatnak, ez nem tiltás.

A Llama EU-s többmódú korlátozása. A többmódú Llama 3.2 és Llama 4 modellek használati szabályzata szerint az EU-ban lakóhellyel vagy fő telephellyel rendelkező személy vagy cég az 1(a) szerinti jogokat nem kapja meg, a végfelhasználóra a korlátozás nem vonatkozik [META-LLAMA-LIC]. Hogy a Llama 3.3 tartalmaz-e többmódú modellt, a letöltött források nem rögzítik [META-LLAMA-LIC].

A GPAI-iránymutatás bizonytalansága. Az AI Act kivétele a szabad és nyílt forráskódú modellek szolgáltatóinak egyes kötelezettségei alól nem alkalmazható, ha a modell rendszerszintű kockázatú, és a felhasználói küszöbhöz kötött licenc kizárja a nyílt forráskódú minősítést [EC-GPAI-GL]. Hogy a Llama és a Qwen küszöbe ide tartozik-e, szakértői következtetés, az iránymutatás modellt nem nevez meg. Az ETSI szabvány harmonizált státusza a forrásból nem állapítható meg [ETSI-EN-304223], a BSI katalógusa nem kötelező erejű [BSI-KRIT-GENKI].

Eltérő hatósági álláspontok. A hamburgi hatóság szerint az LLM puszta tárolása nem adatkezelés, az EDPB és a CNIL szerint a modell anonimitása nem vélelmezhető [HMBBFDI-LLM] [EDPB-OP28] [CNIL-STATUT-MODELE]. A tanulmány az EDPB és a CNIL álláspontjára épít.

8.9. Részösszegzés és előreutalás a 9. fejezetre

A fejezet megállapításai a következők.

Feltétel nélkül szinte semmi sem vállalható. A 20 cellából egy vállalható (KON-05 × UTI, saját szerveren, alapkontrollokkal), 13 feltételekkel vállalható, 6 nem vállalható.

A fogyasztói SaaS egyik adatkörre sem vállalható. A kizáró ok a fogyasztói feltételek fejlesztési felhasználása és emberi felülvizsgálata (HIA-02, KOC-02).

A KON-02 és a KON-03 feltételekkel vállalható, banktitokra nem. A kötelező MIN-ek közül a MIN-04, MIN-09 és MIN-16 minden adatkörnél szerződésbe emelendő, a MIN-18 hiánya a hivatásbeli titoknál kizáró ok.

A KON-04 forráshiány miatt nem értékelhető megalapozottan. A szerződésszövegek hiányoznak, a besorolás feltételes (HIA-15).

A KON-05 a legkedvezőbb feltételrendszer minden adatkörre, de a kockázatot a szervezetre telepíti. A saját kapacitás, az ellátási lánc és a licencek átvilágítása a feltétel (KOC-15, KOC-17), minősített adatnál forráshiány van.

A fejezet döntési javaslatot nem ad. A GO/NO-GO javaslatot, az indoklással és a szükséges feltételekkel együtt, a 9. fejezet adja.

09

09. FEJEZET

Következtetések és döntési javaslat

Ez a fejezet a 2–8. fejezet megállapításait foglalja össze, és a 9.3 alfejezet döntési mátrixából adja a GO / NO-GO javaslatot. Új elemzést, tényt vagy számot nem tartalmaz, minden állítás mögött a forrás alfejezet vagy azonosító áll. A javaslat szakértői értékelésre épül, jogi tanácsadásnak nem minősül, és a konkrét ajánlat átvilágítását nem helyettesíti (8.2).

9.1. Összegzés

A tanulmány a döntési kérdésre hat lépésben jutott el a válaszig. Az alábbi összegzés mindegyik lépés fő megállapítását adja.

- **Szolgáltatói vállalások (3. fejezet).** Az üzleti ajánlatoknál a nagy szolgáltatók alapszintje közös: nincs modelltanítás, a szolgáltató adatfeldolgozó, van alfeldolgozói kifogási jog, szokásos titkosítás és tanúsítási kör (3.2). A megőrzés, a zero data retention (ZDR), a feldolgozási hely és a felelősség köre eltér (3.3). A fogyasztói és ingyenes szint feltételei az üzletiekétől különböznek, és fejlesztési felhasználást is engedhetnek (3.4). A 190 szolgáltatói megállapításból 96 nem szerződéses dokumentumra épül, ezért a kötőerejük a szerződés ismerete nélkül nem állapítható meg (3.6, HIA-15).
- **Az adat szivárgási pontjai (4. fejezet).** 19 kockázatot azonosítottunk, közülük hét emelkedik ki (4.6). A szerződés a szolgáltató tervezett adathasználata ellen, vagyis a tanítás, a megőrzés és az alfeldolgozók esetében véd a legjobban. A váratlan hibák, a támadások, a joghatósági kockázatok és a szervezeti viselkedés ellen alig vagy egyáltalán nem véd (4.6).
- **Jogi elvárások és várható változások (5. fejezet).** A közös alap a GDPR 28. cikke szerinti szerződés, a 32. cikk szerinti biztonság, az indokolatlan késedelem nélküli incidens-értesítés és az adattovábbítási jogalap. Hivatásbeli titoknál, közszféra-adatnál és minősített adatnál szigorúbb szabályok állnak erre (5.6). A szabályozás változik, de a forrásokban nincs olyan hatályos vagy közelgő kötelező változás, amely a legsúlyosabb szerződéses hiányokat közvetlenül megszüntetné (6.6, HIA-12, HIA-13).
- **Mi elég és mi kevés (6. fejezet).** A tanítási tilalom, a feldolgozói szerep, a törlés és az alapszintű titkosítás szerződéses szinten több szolgáltatónál rendben van, de egyetlen vállalási hiány összesített értékelése sem elégséges (6.2, 6.7). A legsúlyosabb hiányok a felelősség és a kötőerő

körül vannak: nincs adatvédelmi kártalanítás, az OpenAI, az Anthropic és a Mistral felelőssége 12 havi díjra korlátozott, az incidenshatáridő többnyire nincs órában rögzítve (HIA-11, HIA-12, HIA-13, HIA-15, 3.3). A 30 minimum-követelmény azt mondja meg, minek kellene elvárhatónak lennie (6.5).

- **Jogérvényesítés (7. fejezet).** A jogok elvben érvényesíthetők, gyakorlatban korlátozottan (7.6). Az érintett igénye érvényesíthető, de a kitettség a szervezetnél van, mert adatkezelőként a nevében eljáró adatfeldolgozóért is felel [EUB-C683-21]. A szerződéses utat a 12 havi díjplafon és a kártalanítás hiánya korlátozza, a hatósági út nem ad kártérítést, harmadik országbeli szolgáltatónál pedig a jogalap és a joghatóság bizonytalan (7.6).
- **A konstrukciók értékelése (8. fejezet).** Öt konstrukciót és négy adatkört vizsgáltunk, ez 20 cellát ad. Egy cella vállalható (a helyben futtatott modell üzleti titokra, saját szerveren), 13 feltételekkel vállalható, hat nem vállalható (8.9). A minősített adatot külön kezeltük: külső szolgáltatóval nem vállalható, helyben futtatott modellel feltételekkel és forráshiánnyal vállalható.

9.2. Válasz a vizsgálati kérdésekre

Az öt vizsgálati kérdés (2.2) válasza a következő.

- **1. Szolgáltatói vállalások.** Üzleti szinten a nagy szolgáltatók szerződésben vagy dokumentációban vállalják a tanítási tilalmat, az adatfeldolgozói szerepet, az alfeldolgozói kifogási jogot és a titkosítást, és mind az öt független tanúsítvánnyal vagy auditjelentéssel rendelkezik (3.2). A technikai vállalások eltérnek: a megőrzés alapértelmezésben 30 nap, a ZDR jóváhagyáshoz kötött és nem szerződéses súgóoldalakon áll, a Microsoft forrásaiban ZDR-vállalás nincs, a feldolgozás helyét a flex routing és a keresztrégiós inferencia lazíthatja (3.3). Órában mért incidenshatárt csak az Anthropic vállal (48 óra), adatvédelmi kártalanítást egyik szolgáltató sem (3.2, 3.3). Az európai szolgáltatóknál 60 szolgáltató-dimenzió párból 20 marad vállalás nélkül, főként forráshiány miatt (3.5).
- **2. Elégségesség.** Kevés az, ami ma elég. A 18 hiány és 10 szolgáltató 180 cellájából 13 elégséges, és egyetlen hiány összesített értékelése sem elégséges (6.2). A legsúlyosabb hiányok a felelősségkorlát, az adatvédelmi kártalanítás hiánya, az órában nem rögzített incidenshatáridő és a nem szerződéses vállalások bizonytalan kötőereje (6.7, HIA-11, HIA-12, HIA-13, HIA-15). A kockázatok közül a legsúlyosabb a fogyasztói szint, az EU-n kívüli feldolgozás, a prompt injection, az izolációs hiba, az alfeldolgozói lánc, a harmadik országbeli hatósági hozzáférés és a nem jóváhagyott eszközhasználat (4.6).
- **3. Várható változások.** Az AI Act modellszolgáltatói kötelezettségei 2025. augusztus 2-től alkalmazandók, a korábban forgalomba hozott modellekre 2027. augusztus 2. a határidő. A Data Act 2027. január 12-től tiltja a szolgáltatóváltási díjat, az új termékfelelősségi irányelv a 2026. december 9. után forgalomba hozott termékekre vonatkozik és a szoftvert is termékként kezeli (6.6). A DPF jogalapja a fellebbezés (C-703/25 P) miatt nem végleges (7.5). A felhő-szuverenitási javaslat, a Kiberbiztonsági Aktus felülvizsgálata és a digitális omnibusz nem hatályos (6.6). A legsúlyosabb szerződéses hiányok kezelése ezért az ügyfél szerződéses és beszerzési feltételein múlik (6.6).

- **4. Normatív elvárás.** A tanulmány 30 minimum-követelményt fogalmaz meg, 22-t a szolgáltatóval, 8-at az igénybe vevő szervezettel szemben, hét csoportban (6.5). Közülük 15 jogszabályi, 3 hatósági elvárás és 12 szakmai ajánlás, a hivatásbeli titoknál 19, a közszféra-adatnál 12 követelménynél emelt szint van (6.5). A 22 szolgáltatói követelményből ma hatot teljesít teljesen legalább egy szolgáltató (MIN-01, MIN-06, MIN-07, MIN-10, MIN-11, MIN-20), a többit egyik sem (6.5). A követelmény megfogalmazás, nem szerződésszöveg.

- **5. Jogérvényesítés.** Elvben igen, gyakorlatban korlátozottan (7.6). A törvényi utak léteznek, és az uniós bírósági gyakorlat a bizonyítási teher szempontjából az érintettnek kedvező [EUB-C340-21] [EUB-C667-21]. A szerződéses utat a 12 havi díjplafon és az adatvédelmi kártalanítás hiánya szűkíti, a hatósági út bírságot adhat, kártérítést nem (HIA-12, HIA-13, [EUB-C667-21]). A jogérvényesítés hatékonysága a szerződés megkötésekor dől el, ezért a MIN-20, a MIN-21 és a MIN-22 szerződésbe emelése a legfontosabb védelem (7.6).

9.3. Döntési javaslat

A javaslatot konstrukciónként és adatkörönként adjuk meg, a döntési mátrix alapján. A **GO** a „vállalható", a **feltételes GO** a „feltételekkel vállalható", a **NO-GO** a „nem vállalható" cellaértéknek felel meg. A feltételes GO nem azt jelenti, hogy a konstrukció ma vállalható, hanem azt, hogy a megjelölt minimum-követelmények teljesítése esetén az lesz (8.7). A „forráshiány" jelzés azt mutatja, hogy a kapcsolt hiánycellák n. a. vagy nem szerződéses forrásra épülnek. A besorolások szakértői értékelések, a kézi korrekciókról a 9.4 alfejezet szól.

Szervezeti szintű javaslat: feltételes GO. Az MI-feldolgozás vállalható, de nem a mai állapotban és nem minden konstrukcióval. A javaslat négy részből áll.

- **Feltételes GO** a közvetlen enterprise ajánlatra (KON-02) és a hyperscaler EU-régióra (KON-03) személyes adatnál, üzleti titoknál és nem minősített közszféra-adatnál, hivatásbeli titoknál pedig a banktitok kivételével. Feltételes GO a helyben futtatott modellre (KON-05) minden adatkörben az üzleti titok saját szerveren futtatott esetét kivéve, a minősített adatot is beleértve, de ott forráshiánnyal. Az EU szuverén felhő (KON-04) minden adatkörben feltételes GO, de forráshiánnyal (8.8).

- **GO** egyetlen cellára: a helyben futtatott modell (KON-05) üzleti titokra, saját szerveren, az alapkontrollokkal. Bérelt infrastruktúrán ez is feltételes GO.

- **NO-GO** a fogyasztói szolgáltatásokra (KON-01) minden adatkörben, mert a fogyasztói feltételek fejlesztési felhasználást és emberi felülvizsgálatot engednek (HIA-02, KOC-02, 8.9). NO-GO a banktitokra a KON-02 és a KON-03 mellett, mert a felügyeleti ellenőrzési jogot (MIN-18) egyik szolgáltató sem vállalja (HIA-18). NO-GO a minősített adatra a KON-01–KON-04 mellett, ami következtetés, nem kifejezett tilalom.

- **Egyetlen konstrukciót nem jelölünk ki mindenre.** A helyben futtatott modell feltételrendszere a legkedvezőbb, de a kockázatot a szervezetre telepíti, a szükséges kapacitásról és költségről pedig a forráskészlet nem szól (8.8, 8.9). A külső szolgáltatós konstrukciók az üzemeltetési terhet átveszik, de a szerződéses hiányokat a szerződésben kell pótolni.

Az indoklás három pontból áll. Először, a 20 cellából egy vállalható, 13 feltételekkel vállalható és hat nem vállalható, vagyis feltétel nélkül szinte semmi sem vállalható (8.9). Másodszor, a legsúlyosabb szerződéses hiányok (a 12 havi díjplafon, az adatvédelmi kártalanítás hiánya, a nem szerződéses vállalások bizonytalan kötőereje) külső szolgáltatónál fennállnak, kezelésük elsősorban az ügyfél szerződéses és beszerzési feltételein múlik (6.6, HIA-12, HIA-13, HIA-15). Harmadszor, a jogérvényesítés korlátozott, ezért a védelmet a szerződés megkötésekor kell kialakítani (7.6).

Az alábbi táblázat a döntési mátrixot mutatja. A hivatásbeli titok oszlopa a legszigorúbb alkategória, a banktitok szerint szól. A zöld a GO, a sárga a feltételes GO, a piros a NO-GO.

KON-01	NO-GO	NO-GO	NO-GO	NO-GO	NO-GO
KON-02	Feltételes GO	Feltételes GO	NO-GO (banktitok). Ügyvédi és orvosi titoknál feltételes GO	Feltételes GO	NO-GO
KON-03	Feltételes GO	Feltételes GO	NO-GO (banktitok). Ügyvédi és orvosi titoknál feltételes GO	Feltételes GO	NO-GO
KON-04	Feltételes GO (forráshiány)	Feltételes GO (forráshiány)	Feltételes GO (forráshiány)	Feltételes GO (forráshiány)	NO-GO
KON-05	Feltételes GO	GO (saját szerveren)	Feltételes GO	Feltételes GO	Feltételes GO (forráshiány)

A feltételeket MIN-azonosítókkal adjuk meg, ezek rövid tartalmát az alábbi jegyzék mutatja.

MIN-01	szerződéses célhoz kötöttség, tanítási tilalom	MIN-19	reverzibilitási záradék
MIN-04	emberi hozzáférés szűk, felsorolt esetei	MIN-20	órában mért incidens-értesítési határidő
MIN-06	törlés vagy visszaadás megszűnéskor	MIN-23	engedélyezés adatosztályozás alapján, fogyasztói szint tiltása
MIN-07	feldolgozás helye szerződésben, eltérő alapértelmezés nélkül	MIN-24	szolgáltatói feltételek évenkénti átvilágítása
MIN-08	adattovábbítási jogalap és tartalék jogalap	MIN-25	nem szerződéses vállalások szerződésbe emeltetése
MIN-09	harmadik országbeli hatósági kérelem jelentése	MIN-26	adatvédelmi hatásvizsgálat
MIN-10	alfeldolgozói felhatalmazás és felelősség	MIN-27	adatosztályozás, költség-haszon elemzés, kilépési terv
MIN-11	titkosítás szerződéses rögzítése	MIN-28	ellátási lánc kockázatkezelése
MIN-16	információadás és audit lehetővé tétele	MIN-29	Nemzeti Biztonsági Felügyelet engedélye minősített adatnál
MIN-18	szektorális felügyelet ellenőrzési joga	MIN-30	a hivatásbeli titok szakmai feltételei

A feltételes GO cellák feltételeit és a NO-GO cellák kizáró okát az alábbi táblázat adja. A „szerződésbe emelendő” az a kötelező szolgáltatói MIN, amelyet a konstrukcióban ma egyik szolgáltató sem teljesít. A KON-04 celláinál a forráshiány azt jelenti, hogy a kapcsolt hiánycellák n. a. vagy nem szerződéses forrásra épülnek, a nem teljesülés nem azonos az elutasítással. A KON-05 minden celláján elvárt a MIN-23, a MIN-24 és a MIN-25 alapkontroll és a nyílt súlyú modellekre vonatkozó biztonsági útmutatók és licencek kontrollja.

KON-01 × SZA, UTI, HIV, KOZ	NO-GO	Kizáró ok: a fogyasztói feltételek fejlesztési felhasználást és emberi felülvizsgálatot engednek, a feldolgozó pedig saját célra nem kezelhet személyes adatot (HIA-02, MIN-01, KOC-02). Üzleti titoknál ez szerződéses hiány, nem jogszabályi tilalom. Hivatásbeli titoknál a tanításba beépülő ügyféladat sértheti a titoktartást (KOC-01). Közszféra-adatnál a fogyasztói szint szerződéses garanciát nem ad (MIN-02). A kizárás szakértői besorolás.
KON-02 × SZA	Feltételes GO	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-20. Szervezeti: MIN-26. Szerződésbe emelendő, mert ma egyik szolgáltató sem teljesíti: MIN-04, MIN-08, MIN-09, MIN-16. A DPF bizonytalansága (KOC-10) érinti, a tartalék jogalap a MIN-08 szerződéses tartalma (8.8).
KON-02 × UTI	Feltételes GO	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-09, MIN-11, MIN-16, MIN-20. Szervezeti: nincs. Szerződésbe emelendő, mert ma egyik szolgáltató sem teljesíti: MIN-04, MIN-09, MIN-16.
KON-02 × HIV	NO-GO (banktitok)	Kizáró ok: a MIN-18 kötelező és emelt szintű (a kiszervezési szerződésnek tartalmaznia kell a belső ellenőrzés, az adatvédelmi tisztviselő, a könyvvizsgáló és a Felügyelet ellenőrzési jogát), a HIA-18 viszont egyik szolgáltatónál sem teljesül, még részben sem. A kizárás a banktitok kiszervezési útjára igazolt. Az ügyfél felhatalmazása járható út lehet, de a MIN-18 hiányát nem pótolja (szakértői). Ügyvédi titoknál feltételes GO: MIN-01, MIN-04, MIN-10 és MIN-30 (MÜK-feltételek). Orvosi titoknál feltételes GO: MIN-06 (díjmentes visszaszolgáltatás megszűnéskor) és MIN-26 (hatásvizsgálat).
KON-02 × KOZ	Feltételes GO	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-18, MIN-20. Szervezeti: MIN-27, MIN-28. Szerződésbe emelendő, mert ma egyik szolgáltató sem teljesíti: MIN-04, MIN-08, MIN-09, MIN-16, MIN-18, MIN-20. A MIN-20 emelt szintje 24 órás teljesítést kíván, az Anthropic 48 órás vállalása kevés (HIA-11).
KON-03 × SZA	Feltételes GO	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-20. Szervezeti: MIN-26. Szerződésbe emelendő, mert ma egyik szolgáltató sem teljesíti: MIN-04, MIN-06, MIN-08, MIN-09, MIN-16, MIN-20. A DPF bizonytalansága (KOC-10) érinti, a tartalék jogalap a MIN-08 szerződéses tartalma (8.8).
KON-03 × UTI	Feltételes GO	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-09, MIN-11, MIN-16, MIN-20. Szervezeti: nincs. Szerződésbe emelendő, mert ma egyik szolgáltató sem teljesíti: MIN-04, MIN-06, MIN-09, MIN-16, MIN-20.
KON-03 × HIV	NO-GO (banktitok)	Kizáró ok ugyanaz, mint a KON-02 × HIV celláé: a MIN-18 kötelező és emelt szintű, a HIA-18 viszont egyik szolgáltatónál sem teljesül, még részben sem. Ügyvédi titoknál feltételes GO: MIN-01, MIN-04, MIN-10 és MIN-30 (MÜK-feltételek), a feltételek szerződésbe emelendők. Orvosi titoknál feltételes GO: MIN-06 és MIN-26.
KON-03 × KOZ	Feltételes GO	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-18, MIN-20. Szervezeti: MIN-27, MIN-28. Szerződésbe emelendő, mert ma egyik szolgáltató sem teljesíti: MIN-04, MIN-06, MIN-08, MIN-09, MIN-16, MIN-18, MIN-20. A MIN-20 emelt szintje 24 órás teljesítést kíván, az Anthropic 48 órás vállalása kevés (HIA-11).

KON-04 × SZA	Feltételes GO (forráshiány)	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-20. Szervezeti: MIN-26. Szerződésbe emelendő a felsorolt szolgáltatói MIN mindegyike, mert egyik szolgáltató sem teljesít igazolhatóan kötelező MIN-t.
KON-04 × UTI	Feltételes GO (forráshiány)	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-09, MIN-11, MIN-16, MIN-20. Szervezeti: nincs. Szerződésbe emelendő a felsorolt szolgáltatói MIN mindegyike, mert egyik szolgáltató sem teljesít igazolhatóan kötelező MIN-t.
KON-04 × HIV	Feltételes GO (forráshiány)	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-18, MIN-20. Szervezeti: MIN-26, MIN-27, MIN-28, MIN-30. Szerződésbe emelendő a felsorolt szolgáltatói MIN mindegyike, mert egyik szolgáltató sem teljesít igazolhatóan kötelező MIN-t. A MIN-20 emelt szintje 24 órás teljesítést kíván, az Anthropic 48 órás vállalása kevés (HIA-11). A HIA-18 cellái n. a..
KON-04 × KOZ	Feltételes GO (forráshiány)	Teljesítendő: Szolgáltatói: MIN-01, MIN-04, MIN-06, MIN-08, MIN-09, MIN-10, MIN-11, MIN-16, MIN-18, MIN-20. Szervezeti: MIN-27, MIN-28. Szerződésbe emelendő a felsorolt szolgáltatói MIN mindegyike, mert egyik szolgáltató sem teljesít igazolhatóan kötelező MIN-t. A MIN-20 emelt szintje 24 órás teljesítést kíván, az Anthropic 48 órás vállalása kevés (HIA-11).
KON-05 × SZA	Feltételes GO	Teljesítendő: Szervezeti: MIN-26. Bérelt infrastruktúrán az IaaS-szerződésre: MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16, MIN-20. Ha az IaaS EGT-n kívüli vagy oda továbbít: még MIN-08, MIN-09 (elvárt még a MIN-07). A modell eredetét és anonimitását vizsgálni kell.
KON-05 × UTI	GO (saját szerveren)	GO saját szerveren, kötelező MIN nincs. Elvárt alapkontrollok: MIN-23, MIN-24, MIN-25 és a nyílt súlyú modellekre vonatkozó biztonsági útmutatók és licencek kontrolljai (modellfájl-ellenőrzés, izoláció, titkosítás, kivezetés). Bérelt infrastruktúrán a cella feltételes GO, az IaaS-szerződésre: MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16, MIN-20. Ha az IaaS EGT-n kívüli vagy oda továbbít: még MIN-08, MIN-09 (elvárt még a MIN-07).
KON-05 × HIV	Feltételes GO	Teljesítendő: Szervezeti: MIN-26, MIN-27, MIN-28, MIN-30. Bérelt infrastruktúrán az IaaS-szerződésre: MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16, MIN-18, MIN-19, MIN-20. Ha az IaaS EGT-n kívüli vagy oda továbbít: még MIN-08, MIN-09 (elvárt még a MIN-07). A MIN-30 banktitoknál a kiszervezési kivételt vagy az ügyfél felhatalmazását, ügyvédi titoknál a MÜK szerinti megállapodást jelenti, orvosi titoknál nem alkalmazandó, ott a MIN-26 a feltétel. Forráshiány: a forráskészlet nem dönti el, hogy az MI-szolgáltatás kiszervezés-e.
KON-05 × KOZ	Feltételes GO	Teljesítendő: Szervezeti: MIN-27, MIN-28. Bérelt infrastruktúrán az IaaS-szerződésre: MIN-01, MIN-04, MIN-06, MIN-10, MIN-11, MIN-16, MIN-18, MIN-19, MIN-20. Ha az IaaS EGT-n kívüli vagy oda továbbít: még MIN-08, MIN-09 (elvárt még a MIN-07).
KON-01–KON-04 × minősített adat	NO-GO	Kizáró ok: minősített adatot csak a Nemzeti Biztonsági Felügyelet engedélye alapján lehet kezelni, ahhoz csak személyi biztonsági tanúsítvánnyal és titoktartási nyilatkozattal rendelkező felhasználó férhet hozzá, és a közreműködő védelmi feltételeit az átadás előtt ellenőrizni kell (MIN-29). Egyik szolgáltató sem vállalja ezt a három feltételt (HIA-18, HIA-06). Az MI-használatot minősített

		adatra a jogszabályi forrás kifejezetten nem tiltja, ezért a kizárás következtetés, és forráshiány van az engedély megszerezhetőségéről.
KON-05 × minősített adat	Feltételes GO (forráshiány)	Feltétel: NBF-engedély, a hozzáférés csak személyi biztonsági tanúsítvánnyal rendelkező felhasználónak, bérelt infrastruktúránál a közreműködő védelmi feltételeinek előzetes ellenőrzése (MIN-29, MIN-16, MIN-27). Forráshiány: a forráskészlet nem tárgyalja, hogy helyben futtatott MI-modell minősített adatot kezelő rendszerben engedélyezhető-e, ezért ez feltételes besorolás, nem igazolt vállalhatóság.

A MIN-04, a MIN-09 és a MIN-16 a KON-02 és a KON-03 minden adatkörénél szerződésbe emelendő (8.9). Ezek mellett a MIN-21 és a MIN-22 (felelősségkorlát és adatvédelmi kártalanítás) a mátrixban nem kötelező feltétel, mert hatósági elvárások, de hiányukban az adatvédelmi kitettséget a szervezet viseli (7.6).

Ajánlott konstrukció adatkörönként. Adatkörönként azt a konstrukciót jelöljük meg, amelynek a cellaértéke és a kötelező MIN-hiányai a legkedvezőbbek (8.7).

- **Személyes adat.** A legkedvezőbb a KON-05, kötelező feltétele a MIN-26 (hatásvizsgálat), a nyílt súlyú modellekre vonatkozó biztonsági útmutatók és licencek kontrolljai és a modell eredetének vizsgálata. Külső szolgáltatónál a KON-02, azon belül az Anthropic, a MIN-04, MIN-08, MIN-09 és MIN-16 szerződésbe emelésével (8.7).
- **Üzleti titok.** A legkedvezőbb a KON-05 saját szerveren, GO, alapkontrollokkal (MIN-23, MIN-24, MIN-25). Külső szolgáltatónál a KON-02 feltételes GO, szerződésbe emelendő a MIN-04, a MIN-09 és a MIN-16 (8.7).
- **Hivatásbeli titok.** A legkedvezőbb a KON-05, feltételei a MIN-26, MIN-27, MIN-28 és MIN-30 (a MIN-30 banktitoknál és ügyvédi titoknál alkalmazandó, orvosi titoknál nem). A KON-02 és a KON-03 ügyvédi és orvosi titoknál feltételes GO, banktitoknál NO-GO. A KON-04 forráshiány miatt nem értékelhető megalapozottan (8.7).
- **Közszféra- és minősített adat.** Nem minősített adatnál a KON-05 feltételes GO (MIN-27, MIN-28), a KON-02 és a KON-03 a MIN-04, MIN-08, MIN-09, MIN-16, MIN-18 és MIN-20 szerződésbe emelésével (a KON-03-ban a MIN-06 is). Minősített adatnál csak a KON-05 jöhet szóba, NBF-engedéllyel (MIN-29), forráshiánnyal (8.7).

9.4. A javaslat feltételei és fenntartásai

A javaslat csak az alábbi feltételezések és függőségek fennállása esetén érvényes (8.8).

- **Szakértői besorolások.** A kockázatok valószínűsége és hatása, a vállalások fokozata, a követelmények erőssége és adatkör-szintje, a maradványkockázat és a cellaérték szakértői értékelés (2.4). A hét kézi korrekció közül kiemelendő a KON-01 minden cellájának NO-GO besorolása, a minősített adat kizárása a KON-01–KON-04-nél, a MIN-20 emelt szintjének 24 órás

értelmezése és a HIV-cella besorolása a legszigorúbb alkategória szerint. A Microsoft 365 Copilot KON-03-ba sorolása szintén szakértői, az eltérő besorolás a cellaértékeket nem változtatná meg (8.8).

- **Forráshiány.** A KON-04 minden cellája feltételes besorolás, mert a négy EU-s szolgáltató 72 hiánycellájából 50 n. a., a DPA- és szerződésszövegek nincsenek a forráskészletben (6.4, 8.8). A nem teljesülés nem azonos az elutasítással, ezért a KON-04 besorolása a szövegek beszerzése nélkül nem véglegesíthető. Az OpenAI, az Anthropic és a Microsoft trust portáljának tartalma nem volt elérhető, ezek ismeretében a KON-02 és a KON-03 értéke javulhat (8.8).
- **A DPF és a C-703/25 P ügy.** A DPF jogalapja a Törvényszék ítélete után is bizonytalan, mert a fellebbezés folyamatban van. A KON-02 és a KON-03 személyesadat-cellája ettől függ, a tartalék jogalap (SCC) a MIN-08 szerződéses tartalma. Az ügy állását a CURIA oldalán újra ellenőrizni kell (7.5, 8.8, KOC-10).
- **A feltételek egyoldalú változása.** A katalógus a szolgáltatói feltételek egyoldalú módosíthatóságát nem vizsgálta, az értékelés a 2026. október 28-i állapotot tükrözi. A kockázat konkrét: a Copilot flex routing a 2026. március 25. után létrehozott bérlőknél alapértelmezésben be van kapcsolva, az AWS program-ZDR-je 2026. december 31-ig szól (8.8). Ezért kell a MIN-24 szerinti éves felülvizsgálat.
- **A nem szerződéses források kötőereje.** A szolgáltatói megállapítások mintegy fele dokumentációra épül, a standard feltételek pedig nem helyettesítik a teljes ügyfélszerződést (HIA-13, HIA-15, 8.2). A javaslat a konkrét ajánlat átvilágítását nem pótolja.
- **A Hpt. szerinti kiszervezés kérdése.** Nyitott jogi kérdés, hogy az MI-szolgáltatás kiszervezésnek minősül-e (2.5, 5.6). A banktitok KON-02 és KON-03 melletti NO-GO besorolása a kiszervezési útra igazolt, az ügyfél felhatalmazása járható út lehet, de a MIN-18 hiányát nem pótolja. A KON-05 banktitok-cellája is forráshiányos, mert nem dönthető el, hogy a helyben futtatott modell kiszervezés-e (8.5).
- **A minősített adat kizárásának következtetés jellege.** A jogszabályi forrás az MI-használatot minősített adatra kifejezetten nem tiltja. A KON-01–KON-04 kizárása azon alapul, hogy egyik szolgáltató sem vállalja a Mavtv. három feltételét (8.6). A KON-05 esetén a forráskészlet nem tárgyalja, hogy helyben futtatott MI-modell minősített adatot kezelő rendszerben engedélyezhető-e, ezért a feltételes GO nem igazolt vállalhatóság (8.6).
- **A KON-05 saját üzemeltetési kapacitása.** A KON-05 a szolgáltatói kockázatot a szervezetre telepíti. A modellfájl-ellenőrzés, az izoláció, a titkosítás, a kivezetés és a licenc-átvilágítás a szervezet feladata. A szükséges kapacitásról és költségről a forráskészlet nem szól, a modellek minősége és ára a hatókörön kívül van (8.8). A licenc modellenként és verziónként eltér, a hatósági álláspontok pedig nem egységesek a modell adatkezelési minősítéséről (8.8).
- **A jogérvényesítés rései.** A forráskészletből nem derül ki a szolgáltatók jogválasztási és fórumkikötése, a Google és az AWS felelősségi plafonja, a visszkereset kérdése, valamint a jogérvényesítés időtartama és költsége (7.6). A feltételes GO ezért a jogérvényesítési kitettséget nem szünteti meg.

- **Időbeli érvényesség.** A javaslat a 2026. október 28–29-i forrásállapotot tükrözi (2.5).

Amit a szervezetnek magának kell tisztáznia. A mátrix általános, az, hogy melyik cellája érvényes egy adott szervezetre, a szervezet saját helyzetén múlik: mely adatköröket kíván MI-szolgáltatással feldolgozni, és kezel-e banktitkot, ügyvédi vagy orvosi titkot, illetve minősített adatot. Ugyanígy a szervezetnek kell megítélnie, vállalni tudja-e a KON-05 üzemeltetési terhét (8.8).

9.5. Mit tegyen egy szervezet

A cél az, hogy a feltételes GO feltételei teljesüljenek, és a döntés a kiválasztott konstrukció és szolgáltató konkrét szerződéses szövegének ismeretében véglegesíthető legyen (8.7, 8.2). A teendők a tanulmányban már szereplő feladatokból állnak, új elemzés nem szükséges. A felelőst és a határidőt a döntést hozó szervezet jelöli ki.

A szervezet adatosztályozása az MI-használathoz, és annak rögzítése, mely adatkörökre kell a mátrix.	2.3, 9.4, MIN-23, MIN-27
A szakértői besorolások áttekintése a szervezet saját helyzetére: a kockázatok valószínűsége és hatása, a MIN-ek erőssége és adatkör-szintje.	2.4, 8.8
Szerződés előtti átvilágítás a kiválasztott szolgáltatónál: a teljes DPA, az ajánlati szintek, az alfeldolgozói lista, a tanúsítványok hatóköre, az auditjelentés, a ZDR-jóváhagyás és a régióbeállítás bekérése.	MIN-17, MIN-24, MIN-25
A szerződésbe emelendő MIN-ek tárgyalása: MIN-04, MIN-08, MIN-09 és MIN-16, adatkörtől függően MIN-06, MIN-10, MIN-18 és MIN-20, cellánként a 9.3 alfejezet szerint. A nem szerződéses vállalások (ZDR, megőrzés, feldolgozási hely) szerződéses mellékletbe emelése. A MIN-21 és a MIN-22 (felelősségkorlát, adatvédelmi kártalanítás) tárgyalása.	9.3, MIN-25
A szervezeti kontrollok kialakítása: engedélyezés adatosztályozás alapján (MIN-23), hatásvizsgálat (MIN-26), költség-haszon elemzés és kilépési terv (MIN-27), ellátási lánc (MIN-28), hivatásbeli titoknál a MIN-30.	8.3–8.6
Az EU-s szolgáltatók (OVHcloud, STACKIT, IONOS, Aleph Alpha) DPA- és szerződésszövegeinek beszerzése, a STACKIT AI Model Serving v1.4 szövegével együtt, és a KON-04 cellák újraértékelése. Az OpenAI, az Anthropic és a Microsoft trust portál tartalmának bekérése a KON-02 és a KON-03 újraértékeléséhez.	6.4, 8.8
KON-05 esetén a saját üzemeltetési kapacitás és költség felmérése (a forráskészlet nem szól róla), a felelős kijelölése, a nyílt súlyú modellekre vonatkozó biztonsági útmutatók kontrolljainak és a választott modell licencfeltételeinek átvilágítása. Bérelt infrastruktúránál az IaaS-szerződés MIN-jeinek tárgyalása.	8.8
Nyitott jogi kérdések tisztázása jogi szakemberrel: kiszervezés a Hpt. 68. §-a szerint (a helyben futtatott modellre is), nagy kockázatú rendszer az AI Act szerint, az ügyfél felhatalmazásának szerepe banktitoknál, minősített adatnál az NBF-engedély megszerezhetősége, a szerződésszöveg jogi értékelése.	2.5, 5.6, 8.5
Incidens-felkészülés: értesítési lánc, belső bejelentési határidők, bizonyíték-megőrzés, a szerződéses és szolgáltatói feltételek verziójának archiválása.	7.6
Változásfigyelés és éves felülvizsgálat: a C-703/25 P ügy állása a CURIA oldalán, a flex routing, a régió- és keresztrégiós beállítások, az AWS program-ZDR lejárata (2026. december 31.), a szabályozási ütemterv határidői (például a Data Act 2027. január 12-i határideje), a szolgáltatói feltételek évenkénti átvilágítása (MIN-24) és a döntési mátrix éves újraértékelése.	8.8, MIN-24

MELLÉKLET

Fogalmak és rövidítések (1. sz. melléklet)

A melléklet a tanulmányban használt fogalmakat (1.A) és rövidítéseket (1.B) gyűjti. A jogi fogalmaknál a meghatározás a jogszabály szövegéből származik, a forráskóddal. A legfontosabb értékelési skálákat és jelöléseket a 2.4 alfejezet és az egyes táblák bevezetője ismerteti.

1.A. Fogalmak

A tábla a fogalmakat ábécérendben mutatja. A „Jelentés a tanulmányban” oszlop a jogszabályi vagy forrásbeli meghatározást, illetve a munkadefiníciót adja.

Adatfeldolgozó	Az a természetes vagy jogi személy, közhatalmi szerv, ügynökség vagy bármely egyéb szerv, amely az adatkezelő nevében személyes adatokat kezel. A személyes adatot kizárólag az adatkezelő írásbeli utasításai alapján kezelheti. A nagy szolgáltatók az üzleti ajánlatoknál adatfeldolgozóként határozzák meg magukat (3.2 alfejezet).	GDPR 4. cikk 8. pont (forrás: GDPR). [GDPR], [GDPR]
Adatkezelő	Az a természetes vagy jogi személy, közhatalmi szerv, ügynökség vagy bármely egyéb szerv, amely a személyes adatok kezelésének céljait és eszközeit önállóan vagy másokkal együtt meghatározza. A tanulmányban a szervezet adatkezelő marad akkor is, ha az MI-szolgáltatót adatfeldolgozóként veszi igénybe (8.1 alfejezet).	GDPR 4. cikk 7. pont (forrás: GDPR). [GDPR]
Adatkör	A tanulmány négy adatkört értékel külön: **SZA** (személyes adat, a különleges kategóriákat is beleértve), **UTI** (üzleti titok), **HIV** (hivatásbeli titok: ügyvédi, orvosi, banktitok) és **KOZ** (közszféra- és minősített adat).	Munkadefiníció (5.4 alfejezet)
Adatrezidencia, adathatár	Az adatrezidencia az adatok tárolásának és feldolgozásának rögzített földrajzi helye, például a szolgáltatónál választható régió. Az adathatár a feldolgozás földrajzi határa, amelyen belül a szolgáltató vállalása szerint az adat marad. A Microsoft EU Data Boundary vállalása szerint az ügyféladatot az EU-ban és az EFTA-országokban tárolják és dolgozzák fel, korlátozott kivételekkel.	Munkadefiníció. [MSFT-EUDB]†, [OAI-BDP]†
Alfeldolgozó	Az adatfeldolgozó által igénybe vett további adatfeldolgozó. Igénybevételéhez az adatkezelő előzetes írásbeli, eseti vagy általános felhatalmazása kell, általános felhatalmazás esetén is tájékoztatni kell az adatkezelőt a változásokról.	[GDPR] (GDPR 28. cikk (2) bekezdés)
Alkalmazó (üzemeltető) az AI Act szerint	Olyan természetes vagy jogi személy, hatóság, ügynökség vagy egyéb szerv, aki vagy amely a felügyelete alá tartozó MI-rendszert használja, kivéve, ha az MI-rendszert személyes, nem szakmai jellegű tevékenység során használják. Az alkalmazót a nagy kockázatú rendszereknél intézkedési és naplómegőrzési kötelezettségek terhelik. Hogy a tanulmány tárgyát képező használat nagy kockázatú rendszernek minősül-e, a jogszabályi és hatósági források nem döntik el.	AIA 3. cikk 4. pont (forrás: AIA). [AIA], [AIA], [AIA]
Általános célú MI-modell (GPAI)	Olyan MI-modell, amely jelentős általánosságot mutat, forgalomba hozatalának módjától függetlenül különféle feladatok széles körének elvégzésére képes, és többféle downstream rendszerbe vagy alkalmazásba integrálható. A forgalomba hozatal előtt kutatási, fejlesztési vagy prototípus-alkotási tevékenységre használt modellek kivételek. A GPAI az angol General-Purpose AI rövidítése. A modell szolgáltatójára dokumentációs és kiberbiztonsági kötelezettségek vonatkoznak.	AIA 3. cikk 63. pont (forrás: AIA). [AIA], [AIA], [GPAI-COP]
Banktitok	Minden, az egyes ügyfelekről a pénzügyi intézmény rendelkezésére álló tény, információ, megoldás vagy adat, amely az ügyfél személyére, adataira, vagyoni helyzetére,	[HPT], [HPT]

	üzleti tevékenységére, kapcsolataira, számlájára vagy szerződéseire vonatkozik. A hivatásbeli titok egyik alkategóriája. Időbeli korlátozás nélkül kell megtartani, és az ügyfél vagy a pénzügyi intézmény felhatalmazása nélkül, a törvényi kivétellel, nem adható ki harmadik személynek.	
C5	A BSI (Bundesamt für Sicherheit in der Informationstechnik) felhőbiztonsági követelménykatalógusa (Cloud Computing Compliance Criteria Catalogue), amelyre a szolgáltatók tanúsítása és auditjelentése épül. A felhőszolgáltatás ügyfelének magának kell megrendelnie és elemeznie a szolgáltató C5-jelentését, az eljárást évente meg kell ismételni. A C5:2026 a többbérlős működést és a szuverenitás műszaki megvalósítását részletesebben kezeli.	[BSI-C5], [BSI-C5-2026]
DPA	Adatfeldolgozási megállapodás (data processing agreement vagy addendum): az adatkezelő és az adatfeldolgozó közötti szerződés vagy szerződésmelléklet. A GDPR 28. cikke szerinti minimumtartalma van, például az adatkezelés kizárólag az írásbeli utasítások alapján, a harmadik országba történő továbbítást is beleértve.	[GDPR]. A megnevezés munkadefiníció
DPF	Az EU–USA adatvédelmi keret (Data Privacy Framework). A megfelelőségi határozat szerint az Egyesült Államok a keretben részt vevő, a Kereskedelmi Minisztérium listáján szereplő szervezetek számára megfelelő védelmi szintet biztosít. A Bizottság a határozatot felfüggesztheti, módosíthatja vagy hatályon kívül helyezheti. A jogalap a Latombe-fellebbezés (C-703/25 P) miatt bizonytalan.	[EU-US-DPF], [EU-US-DPF], [EUB-C703-25P]
Ellátási lánc	Az MI-rendszer értékláncának harmadik féltől származó összetevői, például beszerzett adatkészletek, előtanított modellek és szoftverkönyvtárak. A NIS2 szerint az alapvető és fontos szervezeteknek a kockázatkezelési intézkedések körében az ellátási lánc biztonságáról is gondoskodniuk kell.	[NIS2], [NIST-600-1], [NCSC-SECAI-DEV]
Felelősségkorlátozás	A szolgáltató szerződéses felelősségének felső határa. Az OpenAI, az Anthropic és a Mistral felelőssége az esemény előtti 12 hónapban fizetett díjra korlátozott, a kártalanítási kötelezettségek kivételével. A korlát a kártól független, ezért az elvárást nem éri el (az értékelési szempontrendszer szerint).	[OAI-SA], [ANT-CT], [MIS-CT]. HIA-12
Flex routing	A Microsoft 365 Copilot funkciója, amely lehetővé teszi, hogy az LLM-következtetés csúcsidőszakban az EU Data Boundary-n kívül történjen. A funkció a 2026. március 25. után létrehozott jogosult bérlőknél alapértelmezésben be van kapcsolva, a rendszergazda módosíthatja.	[MSFT-M365-FLEX]†
Forráshiány	Az a helyzet, amikor a szerződéses szöveg nincs a forráskészletben, vagy a forrás maga jelzi a hiányát, ezért a vállalás nyilvános forrásból nem állapítható meg. Nem azonos azzal, hogy a szolgáltató nem vállal. Jelölése: n. a.	Munkadefiníció (6.4 alfejezet)

Hivatásbeli titok	A HIV adatkör: jogszabállyal védett titokfajták, amelyeket a hivatás gyakorlója köteles megtartani. A tanulmányban három alkategóriája van: ügyvédi titok, orvosi titok és banktitok. A három alkategória feltételei eltérnek.	Munkadefiníció (5.4 alfejezet, 8.5 alfejezet)
Hyperscaler	Nagy felhőplatform-szolgáltató, amelynek felhőjében modellek is elérhetők. A tanulmányban a KON-03 konstrukció tartozik ide (Azure OpenAI és AI Foundry, AWS Bedrock, Google Vertex AI).	Munkadefiníció (8.1 alfejezet)
Kártalanítás	A szolgáltató vállalása, hogy az ügyfelet harmadik fél igényeivel szemben mentesíti. Szellemi tulajdoni igényekre az öt nagy szolgáltató és a Mistral vállal kártalanítást, a köre eltér (3.2 alfejezet). Adatvédelmi kártalanítási vállalást a katalógus egyik szolgáltatónál sem rögzít (HIA-13).	[OAI-SA], HIA-13
Kiszervezés (Hpt.)	Ha a pénzügyi intézmény a pénzügyi vagy kiegészítő pénzügyi szolgáltatási tevékenységéhez kapcsolódó vagy jogszabály által végezni rendelt olyan tevékenységét, amelynek során adatkezelés, adatfeldolgozás vagy adattárolás valósul meg, nem önállóan végzi, hanem annak folyamatos vagy rendszeres elvégzésére tőle szervezetileg független személlyel köt szerződést. Hogy az MI-szolgáltatás igénybevétele kiszervezésnek minősül-e, a jogszabályi és hatósági források nem döntik el, ez nyitott jogi kérdés.	Hpt. 6. § (1) bekezdés 58. pont (forrás: HPT). [HPT], [HPT]
Konstrukció (KON)	A szolgáltatói és szerződéses-technikai megoldás típusa, a döntési mátrix sora. Öt van: KON-01 fogyasztói SaaS, KON-02 enterprise API és üzleti szolgáltatás ZDR-rel, KON-03 hyperscaler EU-régióval, KON-04 EU szuverén felhő, KON-05 helyben futtatott nyílt súlyú modell.	Munkadefiníció (8.1 alfejezet)
Különleges kategóriás személyes adat	Olyan személyes adat, például az egészségügyi adat, amelynek kezelése főszabály szerint tilos, kivéve a GDPR 9. cikk (2) bekezdésében felsorolt eseteket. Nagy számú kezelése előtt adatvédelmi hatásvizsgálat kötelező.	[GDPR], [GDPR]
Maradványkockázat	A kockázat szintje, amely akkor marad, ha a konstrukciót a szolgáltatók ma ismert vállalásaival és a szervezeti kontrollokkal (MIN-23–MIN-30) üzemeltetik. Háromfokú szakértői besorolás: alacsony, közepes, magas.	Munkadefiníció (8. fejezet)
Megállapítás (MEG)	A tanulmány alapegysége: egy forráshoz kötött, saját szavas összefoglaló, amelyet a forrás szó szerinti idézete igazol. Azonosítója a forráskód és a forrásonkénti sorszám (például [ANT-CT]).	Munkadefiníció
Memorizáció	Az az eset, amikor a modell a tanítóadatában szereplő érzékeny információt támadás során felfedi. A tanulmány a modellinverzióval és a regurgitációval együtt egy kockázatként kezeli (KOC-14).	[NIST-600-1], [ANSSI-GENAI-PA102], [BSI-GENAI]
Minősített adat	A minősítéssel védhető közérdekek körébe tartozó, minősítési jelöléssel ellátott adat, amelyről a minősítő a	Mavtv. 3. § 1. pont a) alpont (forrás: MAVTV).

	minősítési eljárás során megállapította, hogy jogosulatlan nyilvánosságra hozatala, megszerzése, módosítása vagy felhasználása a minősítéssel védhető közérdekek valamelyikét közvetlenül sérti vagy veszélyezteti, ezért a nyilvánosságát és megismerhetőségét korlátozza (nemzeti minősített adat, tömörített szöveg). Kezelése csak a Nemzeti Biztonsági Felügyelet engedélye alapján lehetséges.	[MAVTV], [MAVTV]
Nyílt súlyú (open-weight) modell	Olyan MI-modell, amelynek betanított paramétereit (súlyait) a kiadó nyilvánossá teszi, ezért a szervezet a saját infrastruktúráján futtathatja. Nem azonos a nyílt forráskódú modellel: a felhasználói létszámküszöbhöz kötött használati korlátozás kizárja, hogy a licenc szabad és nyílt forráskódúnak minősüljön. A licencfeltételek modellenként és verziónként eltérnek.	Munkadefiníció. [EC-GPAI-GL], [EC-GPAI-GL], [BSI-KRIT-GENKI]
Orvosi titok	A gyógykezelés során az adatkezelő tudomására jutott egészségügyi és személyazonosító adat, továbbá a szükséges vagy folyamatban lévő, illetve befejezett gyógykezelésre vonatkozó, valamint a gyógykezeléssel kapcsolatban megismert egyéb adat. Az adatkezelő és az adatfeldolgozó is köteles megtartani.	Eüak. 3. § d) pont (forrás: EUAK). [EUAK]
Prompt injection	Támadás, amelynél a támadó utasítást juttat a modell bemenetére. Az indirekt változatnál a támadó távolról, közvetlen felület nélkül olyan adatba injektál promptokat, amelyet az alkalmazás valószínűleg előhív. Így védett adat lopható el, vagy rosszindulatú kód futtatható távolról.	Munkadefiníció. [NIST-600-1], [OWASP-LLM]. KOC-11
RAG	Retrieval-augmented generation: a modell a válasz előtt külső, például vállalati adatforrásból előhívott adatot kap. Az adatot gyakran beágyazásként, külső szolgáltatók által üzemeltetett vektoradatbázisban tárolják. Megfelelő jogosultságellenőrzés hiányában a felhasználó a feladatkörén kívüli adatbázis-tartalmat is lekérdezheti.	Munkadefiníció. [BSI-GENAI], [ANSSI-BSI-LLM-ZT]. KOC-13
SCC	Standard szerződéses kikötések (Standard Contractual Clauses, (EU) 2021/914). Megfelelőségi határozat hiányában az EGT-n kívüli adattovábbítás garanciája. Az adatátvevő a 2. modul szerint az adatátadó előzetes kifejezett írásbeli hozzájárulása nélkül nem vehet igénybe további adatfeldolgozót, a vitákat uniós tagállam bírósága rendezi.	[GDPR], [SCC], [SCC]
SecNumCloud	Az ANSSI felhőszolgáltatókra vonatkozó követelményrendszere (3.2 változat). A szolgáltatónak az ügyfél adatait az Európai Unión belül kell tárolnia és feldolgoznia, az adminisztrációs és felügyeleti műveleteket is az Unióból kell végeznie. A minősítés nem szavatol az ügyfél felhőre épített saját szolgáltatásainak biztonsági szintjéért.	[ANSSI-SECNUMCLOUD], [ANSSI-CLOUD-SENS]
Shadow AI	A szervezet által nem jóváhagyott MI-eszközök használata, például érzékeny adat bevitele fogyasztói szintű szolgáltatásba (KOC-18). A NAIH jelentése (nem kötelező	[NAIH-BANK-MI], [ANSSI-GENAI-PA102]

	erejű) szerint adatbiztonsági kockázat, mert a szervezet nem rendelkezik kontrollal az ilyen adatkezelések felett.	
Szuverén felhő	A tanulmány KON-04 konstrukciója: az európai szolgáltatók (OVHcloud, STACKIT, IONOS, Aleph Alpha) felhőkínálata. A mércéje a SecNumCloud és a C5. A fogalom nem jogszabályi, a tanulmány a konstrukció megnevezésére használja. A felhő-szuverenitási keret javaslata nem hatályos.	Munkadefiníció (8.1 alfejezet). [ANSSI-SECNUMCLOUD], [BSI-C5-2026], [EU-CLOUD-SOV-COM502]
Ügyvédi titok	Az ügyvédi tevékenység gyakorlója köteles megtartani, és a titok az adathordozón (iraton) is kiterjed. Az ügyvédet nem terheli titoktartási kötelezettség az adathordozót tároló vagy az adatokat feldolgozó személlyel szemben, az általuk nyújtott szolgáltatás nyújtásához szükséges mértékben. A titokkal az ügyfél vagy jogutódja jogosult rendelkezni.	[UTTV], [UTTV], [UTTV]
Üzleti titok	A tanulmány a törvényi fogalmat használja. Üzleti titoknak az minősül, amelynek titokban tartása érdekében a jogosult az adott helyzetben általában elvárható magatartást tanúsítja. Jogosulatlan hasznosítás vagy felfedés az is, ha valaki a titoktartási megállapodást vagy más titoktartási kötelezettséget megsérti.	[UZLETI-TITOK-TV], [UZLETI-TITOK-TV]
Visszaélés-figyelés (abuse monitoring)	A szolgáltató eljárása, amely a szolgáltatás szabálysértő használatát keresi. Automatikus osztályozásból, mintázatfelismerésből, majd automatizált és szükség esetén emberi felülvizsgálatból állhat, a naplókat a szolgáltató megőrzi (az OpenAI API-nál alapértelmezésben legfeljebb 30 napig).	Munkadefiníció. [MSFT-AOAI-ABUSE]†, [OAI-DATA-CTRL]†
Zero data retention (ZDR)	A szolgáltató vállalása vagy a beállítás, amely mellett az ügyféltartalmat a szolgáltató nem őrzi meg. Nem alapértelmezés. Az OpenAI-nál előzetes jóváhagyáshoz kötött, és a végpontok viselkedését is módosítja, az Anthropicnál jóváhagyással érhető el, a Mistralnál csak az állapotmentes API-hívásokra szól. Az OpenAI-nál a visszaélés-figyelési naplókból ZDR mellett kizárják az ügyféltartalmat.	Munkadefiníció. [OAI-DATA-CTRL]†, [OAI-DATA-CTRL]†, [ANT-ZDR]†, [MIS-ZDR]†

1.B. Rövidítések

A tábla a tanulmányban előforduló rövidítéseket ábécérendben sorolja fel. A Típus oszlop a rövidítés jellegét mutatja. A forráskódok (például OAI-DPA, ANT-CT) a kiadót és a dokumentumot jelölik, a teljes listájuk a Forrásanyagok mellékletben van, ezért itt nem szerepelnek.

AES	Advanced Encryption Standard (fejlett titkosítási szabvány), az AES-256 256 bites kulcsú változat	szakkifejezés
AIA, AI Act	Az (EU) 2024/1689 rendelet, a mesterséges intelligenciáról szóló uniós rendelet (Artificial Intelligence Act). Az AIA a tanulmány forráskódja	jogi
AILD	AI Liability Directive (MI-felelősségi irányelv javaslata), a Bizottság visszavonta	jogi
ANSSI	Agence nationale de la sécurité des systèmes d'information (francia nemzeti információbiztonsági ügynökség)	szervezet
AP	Autoriteit Persoonsgegevens (holland adatvédelmi hatóság)	szervezet
API	Application Programming Interface (alkalmazásprogramozási felület)	szakkifejezés
ÁSZF	Általános szerződési feltételek	jogi
AUP	Acceptable Use Policy (elfogadható használati szabályzat)	szakkifejezés
AWS	Amazon Web Services (az Amazon felhőszolgáltatása)	szervezet
BSI	Bundesamt für Sicherheit in der Informationstechnik (német szövetségi információbiztonsági hivatal)	szervezet
C5	Cloud Computing Compliance Criteria Catalogue (a BSI felhőbiztonsági követelménykatalógusa)	szakkifejezés
CADA	Cloud and AI Development Act (a Bizottság készülő felhő- és MI-fejlesztési jogszabálya)	jogi
CCBE	Council of Bars and Law Societies of Europe (Európai Ügyvédi Kamarák Tanácsa)	szervezet
CCC	Customer Copyright Commitment (a Microsoft szellemi tulajdoni kártalanítási vállalása)	szakkifejezés
CISA	Cybersecurity and Infrastructure Security Agency (amerikai kiberbiztonsági és infrastruktúra-biztonsági ügynökség)	szervezet
CJIB	Centraal Justitieel Incassobureau (holland központi bírósági behajtási hivatal)	szervezet
CMK	Customer-managed key (ügyfél által kezelt titkosítási kulcs)	szakkifejezés
CNIL	Commission nationale de l'informatique et des libertés (francia adatvédelmi hatóság)	szervezet
COD	Rendes jogalkotási eljárás az eljárásszámban, például 2025/0360(COD)	jogi
COM	A Bizottság dokumentumjelzete, például COM(2025) 836	jogi
CSA	Cybersecurity Act (Kiberbiztonsági Aktus), a CSA-felülvizsgálat megnevezésében	jogi

CSAM	Child sexual abuse material (gyermekek szexuális bántalmazását ábrázoló anyag)	szakkifejezés
CSA STAR	Cloud Security Alliance, Security Trust Assurance and Risk (felhőbiztonsági tanúsítási program)	szakkifejezés
CSE	Client-side encryption (ügyféloldali titkosítás)	szakkifejezés
CURIA	Az Európai Unió Bíróságának hivatalos honlapja és adatbázisa	szervezet
CVE	Common Vulnerabilities and Exposures (nyilvános sérülékenység-azonosító)	szakkifejezés
CVSS	Common Vulnerability Scoring System (sérülékenység-pontozási rendszer)	szakkifejezés
DPA	Data processing agreement vagy addendum (adatfeldolgozási megállapodás)	jogi
DPC	Data Protection Commission (ír adatvédelmi hatóság)	szervezet
DPF	Data Privacy Framework (EU–USA adatvédelmi keret)	jogi
DR	Diffusion restreinte (korlátozott terjesztésű, francia kezelési jelölés)	szakkifejezés
EDPB	European Data Protection Board (Európai Adatvédelmi Testület)	szervezet
EDPS	European Data Protection Supervisor (európai adatvédelmi biztos)	szervezet
EFTA	Európai Szabadkereskedelmi Társulás (European Free Trade Association)	szervezet
EGT	Európai Gazdasági Térség	szakkifejezés
EK	Európai Közösség, az 593/2008/EK jelzetű Róma I rendelet jelölésében	jogi
EKM	Enterprise Key Management (az OpenAI ügyfélkulcs-kezelési szolgáltatása)	szakkifejezés
ENISA	Az Európai Unió Kiberbiztonsági Ügynöksége	szervezet
EP	Európai Parlament	szervezet
ESZT	Egységes Szanálási Testület	szervezet
ETSI	European Telecommunications Standards Institute (Európai Távközlési Szabványügyi Intézet)	szervezet
EU	Európai Unió	szakkifejezés
EUB	Európai Unió Bírósága. A forráskódokban az uniós bírósági ítéletek előtagja (például EUB-C300-21)	szervezet
EUCS	European Union Cybersecurity Certification Scheme for Cloud Services (az ENISA felhő-kiberbiztonsági tanúsítási sémájának tervezete)	szakkifejezés

Eüak.	Az egészségügyi és a hozzájuk kapcsolódó személyes adatok kezeléséről és védelméről szóló 1997. évi XLVII. törvény	jogi
FedRAMP	Federal Risk and Authorization Management Program (amerikai szövetségi felhő-megfelelőségi program)	szakkifejezés
GDPR	General Data Protection Regulation, az (EU) 2016/679 általános adatvédelmi rendelet	jogi
GO/NO-GO	A döntési kérdés tárgya: vállalható-e az MI-feldolgozás. A döntési javaslatot a 9. fejezet adja	jelölés
GPAI	General-Purpose AI (általános célú MI), l. az 1.A pont „Általános célú MI-modell” sorát	szakkifejezés
GPU	Graphics processing unit (grafikus feldolgozóegység)	szakkifejezés
GYIK	Gyakran ismételt kérdések	szakkifejezés
HDS	Hébergeur de Données de Santé (francia egészségügyi adat-tárhely tanúsítvány)	szakkifejezés
HIA	Vállalási hiány (a szolgáltatói vállalások hiánya), HIA-01–HIA-18	azonosító
HIPAA	Health Insurance Portability and Accountability Act (amerikai egészségügyi adatvédelmi és biztosítási törvény)	jogi
HIV	Hivatásbeli titok (adatkör)	azonosító
HL	Az Európai Unió Hivatalos Lapja, a kihirdetés helyének jelölésében (például HL L 119.)	szakkifejezés
HmbBfDI	Der Hamburgische Beauftragte für Datenschutz und Informationsfreiheit (hamburgi adatvédelmi és információszabadság-biztos)	szervezet
Hpt.	A hitelintézetekről és a pénzügyi vállalkozásokról szóló 2013. évi CCXXXVII. törvény	jogi
IaaS	Infrastructure as a Service (infrastruktúra mint szolgáltatás)	szakkifejezés
IEC	International Electrotechnical Commission (Nemzetközi Elektrotechnikai Bizottság)	szervezet
IKT	Infokommunikációs technológia	szakkifejezés
Infotv.	Az információs önrendelkezési jogról és az információszabadságról szóló 2011. évi CXII. törvény	jogi
IP	Intellectual property (szellemi tulajdon), például IP-kártalanítás	szakkifejezés
ISAE	International Standard on Assurance Engagements (nemzetközi megbízhatósági megbízások standardja), például ISAE 3000	szakkifejezés

ISO	International Organization for Standardization (Nemzetközi Szabványügyi Szervezet)	szervezet
Kibtv.	A Magyarország kiberbiztonságáról szóló 2024. évi LXIX. törvény	jogi
KMS	Key Management Service (kulcskezelő szolgáltatás), például AWS KMS	szakkifejezés
KOC	Kockázat (szivárgási vektor vagy gyökérok), KOC-01–KOC-19	azonosító
KON	Konstrukció (szolgáltatói és szerződéses-technikai megoldás), KON-01–KON-05	azonosító
Korm.	Kormány, a Korm. rendelet és a Korm. határozat megnevezésében	jogi
KOZ	Közszféra- és minősített adat (adatkör)	azonosító
LLM	Large language model (nagy nyelvi modell)	szakkifejezés
M365	Microsoft 365	szakkifejezés
Mavtv.	A minősített adat védelméről szóló 2009. évi CLV. törvény	jogi
MI	Mesterséges intelligencia	szakkifejezés
MIN	Minimum-követelmény, MIN-01–MIN-30	azonosító
ML	Machine learning (gépi tanulás)	szakkifejezés
MNB	Magyar Nemzeti Bank	szervezet
MSRC	Microsoft Security Response Center	szervezet
MÜK	Magyar Ügyvédi Kamara	szervezet
n. a.	Jelölés: forráshiány, a szerződéses szöveg nincs a forráskészletben (1.C pont)	jelölés
NAIH	Nemzeti Adatvédelmi és Információszabadság Hatóság	szervezet
NBF	Nemzeti Biztonsági Felügyelet	szervezet
NCSC	National Cyber Security Centre (brit nemzeti kiberbiztonsági központ)	szervezet
NDA	Non-disclosure agreement (titoktartási megállapodás)	jogi
NÉ	Jelölés: nem értelmezhető, a KON-05 oszlopban nincs szolgáltatói megfelelője a kérdésnek (1.C pont)	jelölés
n.f.	Jelölés: nem nyilvános vagy nem elérhető forrás (1.C pont)	jelölés
NIS2	Az Unió egész területén egységesen magas szintű kiberbiztonságot biztosító intézkedésekről szóló (EU) 2022/2555 irányelv (NIS 2 irányelv)	jogi

NIST	National Institute of Standards and Technology (amerikai Nemzeti Szabványügyi és Technológiai Intézet)	szervezet
NJT	Nemzeti Jogszabálytár (a magyar jogszabályok hivatalos adatbázisa)	szervezet
NSA	National Security Agency (amerikai Nemzetbiztonsági Ügynökség)	szervezet
NVD	National Vulnerability Database (amerikai nemzeti sérülékenység-adatbázis)	szakkifejezés
OGYK	Országgyűlési Könyvtár	szervezet
OWASP	Open Worldwide Application Security Project (nyílt közösségi alkalmazásbiztonsági projekt)	szervezet
PaaS	Platform as a Service (platform mint szolgáltatás)	szakkifejezés
PDF	Portable Document Format (hordozható dokumentumformátum), az idézetek helyének megjelölésében a PDF oldalszáma	szakkifejezés
PLD	Product Liability Directive, az új termékfelelősségi irányelv ((EU) 2024/2853)	jogi
RAD	Representative Actions Directive, a képviseleti keresetekről szóló (EU) 2020/1828 irányelv	jogi
RAG	Retrieval-augmented generation (l. az 1.A pont „RAG” sorát)	szakkifejezés
SaaS	Software as a Service (szoftver mint szolgáltatás)	szakkifejezés
SAML	Security Assertion Markup Language (az egyszeri bejelentkezés egyik szabványa)	szakkifejezés
SCC	Standard Contractual Clauses (standard szerződéses kikötések), (EU) 2021/914	jogi
SK	Jelölés: szervezeti kontroll, a hiányt a szervezetnek kell saját rendszerében kezelnie (1.C pont)	jelölés
SOC	System and Organization Controls (auditjelentések, SOC 1, SOC 2, SOC 3)	szakkifejezés
SSO	Single sign-on (egyszeri bejelentkezés)	szakkifejezés
SWOT	Strengths, Weaknesses, Opportunities, Threats (erősségek, gyengeségek, lehetőségek, veszélyek)	szakkifejezés
SZA	Személyes adat (adatkör)	azonosító
TLS	Transport Layer Security (szállítási réteg biztonsága, továbbítási titkosítás)	szakkifejezés
URL	Uniform Resource Locator (webcím)	szakkifejezés
USA	Amerikai Egyesült Államok	szakkifejezés

USD, EUR	Amerikai dollár, euró	szakkifejezés
UTI	Üzleti titok (adatkör)	azonosító
Üttv.	Az ügyvédi tevékenységről szóló 2017. évi LXXVIII. törvény	jogi
ZDR	Zero data retention (l. az 1.A pont „Zero data retention (ZDR)” sorát)	szakkifejezés

MELLÉKLET

Kockázat-katalógus (2. sz. melléklet)

A melléklet a kockázat-katalógus áttekintő tábláját (2.A) közli. Minden KOC-azonosító egy szivárgási vektort vagy gyökérokot jelöl (KOC-01–KOC-19).

A kockázatokat **négy vektortípus** szerint csoportosítottuk: (A) szerződéses és szolgáltatói működésből eredő, (B) földrajzi és joghatósági, (C) technikai támadás és hiba, (D) szervezeti és felhasználói. D típusú kockázatot csak akkor vettünk fel, ha forrás megállapítása támasztja alá. A hasonló vektorokat összevontuk, például a modellinverzió, a memorizáció és a regurgitáció egy kockázat (KOC-14).

A **valószínűség** és a **hatás** háromfokú (alacsony, közepes, magas), szakértői besorolás, nem számszerű becslés. A valószínűséget a vektor dokumentáltsága támasztja alá: dokumentált incidens, alapértelmezett beállítás vagy több forrás által rögzített kockázat magasabb besorolást indokol. A hatást az érintett adatkör és a jogi következmény határozza meg: különleges kategóriás, hivatásbeli vagy minősített adat érintettsége magas hatást támaszt alá. Minden kockázat besorolását forrás-hivatkozással indokoltuk.

2.A. Kockázatáttekintő tábla

A tábla mind a **19 kockázatot** tartalmazza. A valószínűség és a hatás **szakértői besorolás**, nem számszerű becslés.

KOC-01	Modelltanítás és szolgáltatói saját célú felhasználás	A. Szerződéses és szolgáltatói	SZA, UTI, HIV, KOZ	közepes	magas
KOC-02	Fogyasztói és ingyenes szint használata üzleti adatra	A. Szerződéses és szolgáltatói	SZA, UTI, HIV, KOZ	magas	magas
KOC-03	Hosszú megőrzés és késleltetett törlés	A. Szerződéses és szolgáltatói	SZA, UTI, HIV, KOZ	magas	közepes
KOC-04	Emberi hozzáférés a visszaélés-figyelés keretében	A. Szerződéses és szolgáltatói	SZA, UTI, HIV, KOZ	közepes	közepes
KOC-05	A zero data retention hiánya vagy korlátai	A. Szerződéses és szolgáltatói	SZA, UTI, HIV, KOZ	magas	közepes
KOC-06	Alfeldolgozói lánc és harmadik fél szolgáltatók	A. Szerződéses és szolgáltatói	SZA, UTI, HIV, KOZ	magas	közepes
KOC-07	Szolgáltatói oldali titkosítási és kulcskezelési hiányosságok	A. Szerződéses és szolgáltatói	SZA, UTI, HIV, KOZ	közepes	magas
KOC-08	Feldolgozás az EU-n kívül: flex routing, globális telepítés és keresztrégiós inferencia	B. Földrajzi és joghatósági	SZA, UTI, HIV, KOZ	magas	magas
KOC-09	Harmadik országbeli hatósági hozzáférés	B. Földrajzi és joghatósági	SZA, UTI, HIV, KOZ	közepes	magas
KOC-10	Az EU–USA adattovábbítási keret (DPF) jogi bizonytalansága	B. Földrajzi és joghatósági	SZA	közepes	közepes
KOC-11	Prompt injection és indirekt injekció	C. Technikai támadás és hiba	SZA, UTI, HIV, KOZ	magas	magas
KOC-12	Kiszivárogtatás a kimeneten, a bővítményeken és a rendszerprompton át	C. Technikai támadás és hiba	SZA, UTI, HIV, KOZ	közepes	közepes
KOC-13	Jogosulatlan adatelérés RAG-on és vektoradatbázison át	C. Technikai támadás és hiba	SZA, UTI, HIV, KOZ	közepes	magas

KOC-14	Modellinverzió, memorizáció és regurgitáció	C. Technikai támadás és hiba	SZA, UTI, HIV	közepes	magas
KOC-15	Ellátási lánc: modell, adatkészlet és szoftverkönyvtár	C. Technikai támadás és hiba	SZA, UTI, HIV, KOZ	közepes	közepes
KOC-16	Többbérlős és munkamenet-izoláció, gyorsítótár- és kódhiba	C. Technikai támadás és hiba	SZA, UTI, HIV, KOZ	magas	közepes
KOC-17	Védtelen adatbázis, hibás konfiguráció és infrastruktúra-támadás	C. Technikai támadás és hiba	SZA, UTI, HIV, KOZ	közepes	magas
KOC-18	Érzékeny adat bevitele nem jóváhagyott eszközbe	D. Szervezeti és felhasználói	SZA, UTI, HIV, KOZ	közepes	magas
KOC-19	Szolgáltatói feltételek és tanúsítások átvilágításának elmaradása	D. Szervezeti és felhasználói	SZA, UTI, HIV, KOZ	közepes	közepes

Vektortípusonként: **A** 7, **B** 3, **C** 7, **D** 2 kockázat.

MELLÉKLET

Vállalási hiány-elemzés (3. sz. melléklet)

A melléklet a vállalási hiány-elemzés hiánytábláját (3.B) közli. Minden HIA-azonosító egy vállalási hiányt jelöl (HIA-01–HIA-18): azt, hogy egy kockázat ellen mit kívánna meg a jog, mit várnak el a hatóságok és a biztonsági keretek, és ehhez képest mit vállalnak ténylegesen a szolgáltatók.

Az értékelés **szakértői**. Négy fokozata van (elégséges, részben elégséges, elégtelen, nincs vállalás), és külön jelzi a forráshiányt (n. a.). A mércét az értékelési szempontrendszer adja. A † jelölés azt mutatja, hogy a cella értékelése csak nem szerződéses dokumentumra (súgó, termékdokumentáció, közlemény) épül. Az ilyen vállalás gyengébb, mert kötőereje a konkrét szerződés ismerete nélkül nem állapítható meg (3.6 alfejezet).

A † jelölés azt mutatja, hogy a cella értékelése csak nem szerződéses dokumentumra épül (a szolgáltatói dokumentumok „(nem szerződéses dokumentum)” jelölése szerint). Az **összesített értékelés** (3.B) az ismert, vagyis nem n. a. cellák közül azt a legmagasabb fokozatot adja, amelyet a cellák legalább kétharmada elér.

3.B. Hiánytábla

A tábla mind a **18 hiányt** tartalmazza. Az elvárás- és a vállalás-oldal rövid összefoglalója forrás-hivatkozással áll. Az értékelés szakértői. Az Értékelés oszlop az összesített fokozatot és a tíz szolgáltató celláinak eloszlását mutatja.

HIA-01	Tanítási és saját célú felhasználás kizárása üzleti szinten	KOC-01, KOC-14	Az adatfeldolgozó csak utasításra kezel adatot, saját célra nem, a megállapodás zárja ki a modellképzést.	Üzleti szinten tanítási tilalom van. Szerződésben az OpenAI, az Anthropic és a Google, dokumentációban a Microsoft, az AWS és az EU-s szolgáltatók vállalják. A Mistral DPA-ja engedi.	**részben elégséges** Cellák: 3 elégséges, 6 részben, 1 elégtelen.
HIA-02	Fogyasztói és ingyenes szint feltételei	KOC-02	Az adatkezelő csak garanciákat nyújtó adatfeldolgozót vehet igénybe, a felelősség nem hárítható az érintettekre.	A védelem az ajánlati szinthez kötött. A fogyasztói és ingyenes feltételek fejlesztési felhasználást és emberi felülvizsgálatot engednek.	**elégtelen** Cellák: 1 részben, 3 elégtelen, 1 nincs vállalás, 5 n. a.
HIA-03	Törlés és visszaadás a szerződés megszűnésekor	KOC-03	A szolgáltatás befejezése után a feldolgozó az adatkezelő döntése szerint töröl vagy visszajuttat, a másolatokat is törli.	A megszűnés utáni törlés 30 nap (OpenAI, Anthropic), 90 nap (AWS), 90+90 nap (Microsoft), legfeljebb 180 nap (Google). A Microsoft a törlésért nem vállal felelősséget.	**részben elégséges** Cellák: 2 elégséges, 4 részben, 4 n. a.
HIA-04	Működés közbeni megőrzés és emberi hozzáférés	KOC-03, KOC-04	A feldolgozó csak utasításra kezelhet adatot, az ügyvédnek értenie kell a szolgáltató adatkezelési műveleteit, egyértelmű megőrzési szabályzat kell.	Az alapértelmezett megőrzés 30 nap, a jelölt tartalom az Anthropicnál 2 évig marad. Az OpenAI-nál a gyanított CSAM-képek ZDR mellett is megmaradnak, az AWS egyes modelleknél maga végez emberi felülvizsgálatot.	**részben elégséges** Cellák: 7 részben, 3 elégtelen.
HIA-05	Zero data retention elérhetősége és kivételei	KOC-05	Jogszabályi ZDR-követelmény nincs a jogszabályi és hatósági források között, a legközelebbi az arányos intézkedés, az egyértelmű megőrzési szabályzat és a szolgáltatói hozzáférés kockázata.	A ZDR nem alapértelmezés. Jóváhagyás kell (OpenAI, Anthropic, Mistral), egyes funkcióknál nem lehetséges (Google), a Microsoftnál nincs vállalás.	**részben elégséges** Cellák: 7 részben, 1 elégtelen, 1 nincs vállalás, 1 n. a.
HIA-06	Feldolgozási hely és az EU-n kívüli kivételek	KOC-08	Harmadik országba csak az V. fejezet feltételeivel, külföldi adatkezelés csak	Választható régió (OpenAI, AWS, Google listás szolgáltatásai), de kivételekkel:	**részben elégséges** Cellák: 1 elégséges,

			adatosztályozás után, a szerződés rögzítse a helyszíneket.	rendszeradat, flex routing, Global telepítés, keresztrégiós inferencia, „bármely ország". Az Anthropicnál nincs földrajzi vállalás.	8 részben, 1 nincs vállalás.
HIA-07	Adattovábbítási jogalap és harmadik országbeli hatósági hozzáférés	KOC-09, KOC-10	Megfelelő garanciák kellenek, a hatósági adatkiadási kérelemről az adatátvevő haladéktalanul értesít, a DPF-határozat felfüggeszthető.	Az OpenAI, az Anthropic, a Microsoft és a Mistral az SCC-re épít, a Microsoft DPF-tanúsítvánnyal is rendelkezik. Külön hatósági-hozzáférési vállalás nincs.	**részben elégséges** Cellák: 4 részben, 2 nincs vállalás, 4 n. a.
HIA-08	Alfeldolgozói lánc	KOC-06, KOC-15	Előzetes írásbeli felhatalmazás vagy általános felhatalmazás tájékoztatással, teljes felelősség az alfeldolgozóért, ellátási lánc biztonsága.	Általános felhatalmazás, előzetes értesítés és kifogási jog 10 és 90 nap között, a kifogás következménye többnyire felmondás. Az alfeldolgozóért az OpenAI a felelősségi plafonon belül felel.	**részben elégséges** Cellák: 1 elégséges, 6 részben, 3 n. a.
HIA-09	Titkosítás és kulcskezelés	KOC-07	Arányos technikai és szervezési intézkedések, köztük titkosítás, az ügyféloldali titkosítás vizsgálata, használat közbeni védelem.	AES-256 és TLS 1.2 az OpenAI-nál és az Anthropicnál, alapértelmezett titkosítás a Googlenél és a Microsoftnál, ügyfélkulcs dokumentációban. Használat közbeni védelemre vállalás nincs.	**részben elégséges** Cellák: 3 elégséges, 3 részben, 4 n. a.
HIA-10	Szerepmegosztás és saját célú adatkezelés	KOC-01	A feldolgozó csak utasításra, saját céljaira nem kezelhet adatot, a MÜK szerint az MI-szolgáltató adatfeldolgozó.	A nagy szolgáltatók adatfeldolgozóként járnak el, de a Microsoft az üzleti műveleteknél, a Google a számlázási és használati adatnál, a Mistral a tanításnál és a moderációnál önálló adatkezelő.	**részben elégséges** Cellák: 2 elégséges, 4 részben, 1 elégtelen, 3 n. a.

HIA-11	Incidens-értesítési határidő	KOC-06, KOC-16, KOC-17	A feldolgozó indokolatlan késedelem nélkül értesít, a 72 órás határidő az adatkezelőt terheli, NIS2 és közszféra esetén 24 óra.	Az incidens-értesítés „indokolatlan késedelem nélkül” szól. Órában mért határidőt csak az Anthropic nevesít, 48 órát.	**részben elégséges** Cellák: 1 elégséges, 5 részben, 4 n. a.
HIA-12	Felelősségi plafon	KOC-19, KOC-02	A kárt szenvedett személy kártérítésre jogosult az adatkezelőtől vagy a feldolgozótól, a szerződés rögzítse a kárral arányos biztosítékokat és a kártérítést.	Az OpenAI, az Anthropic és a Mistral felelőssége az esemény előtti 12 hónapban fizetett díjra korlátozott, a Microsoft az adattörlésért nem vállal felelősséget.	**elégtelen** Cellák: 4 elégtelen, 6 n. a.
HIA-13	Adatvédelmi kártalanítás hiánya	KOC-19	A kárt szenvedett személy kártérítésre jogosult, a hitelintézet felel a kiszervezett tevékenységért, a szerződés rögzítse a kártérítést.	A kártalanítás szellemi tulajdoni igényekre szól. Adatvédelmi incidens miatti kártalanítási vállalás a katalógusban nincs.	**nincs vállalás** Cellák: 6 nincs vállalás, 4 n. a.
HIA-14	Auditjog és ellenőrizhetőség	KOC-19, KOC-17	A feldolgozó a megfelelés igazolásához szükséges információt átadja, és az auditot lehetővé teszi, a szerződés biztosítsa a felügyelet ellenőrzési jogát.	Évi egy audit vagy auditjelentés bizalmassági feltétellel és az ügyfél költségén. ISO 27001, SOC 2 vagy C5 tanúsítvány minden szolgáltatónál szerepel, az EU-s szolgáltatóknál dokumentációban.	**részben elégséges** Cellák: 9 részben, 1 n. a.
HIA-15	Kulcsvállalások nem szerződéses jellege	KOC-19, KOC-03, KOC-05	A DPA a szerződés tartalma, a helyszíneket szerződésben kell rögzíteni, az ügyvédnek a szerződés tényleges érvényesíthetőségét is ellenőriznie kell.	A 190 szolgáltatói megállapításból 96 nem szerződéses dokumentumra épül. A ZDR, a megőrzés és a feldolgozási hely egy része ilyen oldalon áll.	**részben elégséges** Cellák: 5 részben, 1 elégtelen, 4 n. a.
HIA-16	Technikai támadások elleni szolgáltatói vállalás hiánya	KOC-11, KOC-12, KOC-14, KOC-15, KOC-17	A rendszerszintű kockázatot jelentő modell szolgáltatójának kiberbiztonsági védelme, MI-red teaming, az MI-	A szolgáltatói dokumentumokban szolgáltatói vállalás az injekciós támadás, a kimeneti kiszivárogtatás, a memorizáció, az	**nincs vállalás** Cellák: 1 elégtelen, 5 nincs vállalás, 4 n. a.

			biztonság kiegészítő erőfeszítés.	ellátási lánc és a konfigurációs hibák ellen nincs. Dokumentált esetek: Copilot CVE-2025-32711, DeepSeek-adatbázis.	
HIA-17	Ügyfelek közötti izoláció és RAG-hozzáférés	KOC-13, KOC-16	Többbérlős izoláció, finomszemcsés hozzáférés-vezérlés a vektoradatbázisban, az adat és az ágensek elkülönítése.	Szerződéses vállalás az ügyfelek közötti elkülönítésre nincs. Dokumentáció szerint a Microsoft Foundry és az AWS Bedrock elkülönít. Az OpenAI 2023-as gyorsítótár-hibája izolációs hiba volt.	**elégtelen** Cellák: 4 részben, 1 elégtelen, 2 nincs vállalás, 3 n. a.
HIA-18	Felügyeleti ellenőrzés és kilépés (HIV, KOZ)	KOC-19	A bank szerződése biztosítsa a Felügyelet ellenőrzését, a Kibtv. hatálya alatt költség-haszon elemzés és kilépési terv kell, visszafordíthatósági záradék.	Visszaadás vagy kinyerés van, ügyfél-audit korlátozásokkal. Felügyeleti hozzáférési és visszafordíthatósági vállalást a katalógus nem rögzít.	**elégtelen** Cellák: 6 elégtelen, 4 n. a.

MELLÉKLET

Minimum-követelmény-katalógus (4. sz. melléklet)

A melléklet a minimum-követelmény-katalógus követelménytábláját (4.A) közli. Minden MIN-azonosító egy követelményt jelöl (MIN-01–MIN-30), amelynek a szolgáltatóval, szükség esetén az igénybe vevő szervezettel szemben elvárhatónak kellene lennie. Az Adatkör-szint oszlop azt mutatja, hogy a követelmény adatkörönként alap, emelt vagy ajánlott szintű.

A követelmény kötelező erejének három szintje van. Az **erősség** a MIN fő alapjára vonatkozik, az érvényességi kört (például a NIS2, a Hpt. vagy a Kibtv. hatályát) az adatkör-szint és a követelménylap jelzi.

- **Jogszabályi:** kötelező erejű jogszabályból következik (a jogszabályi és hatósági források „Követelmény:", valamint a hatályos jogszabályból származó „Keret:" megállapítás).
- **Hatósági elvárás:** iránymutatásból, ajánlásból vagy szakmai álláspontból következik (a jogszabályi és hatósági források „Elvárás:"). Ide tartoznak a szakmai kamarák (MÜK, CCBE) álláspontjai is, amelyek nem jogszabályok.
- **Szakmai ajánlás:** biztonsági keretből vagy legjobb gyakorlatból következik (a biztonsági keretek és szabványok „Kontroll:" vagy „Keret:").

4.A. Követelménytábla

A tábla mind a **30 követelményt** tartalmazza. A MIN-01–MIN-22 a szolgáltatóval szemben, a MIN-23–MIN-30 az igénybe vevő szervezettel szemben fogalmaz meg elvárást.

MIN-01	A szolgáltató az ügyféltartalmat kizárólag az ügyfél utasításai szerint, a szolgáltatás nyújtására használja, modelltanításra és saját célú fejlesztésre nem, és ezt szerződéses rendelkezésben (DPA vagy szolgáltatási szerződés) vállalja.	HIA-01, HIA-10, HIA-15	Jogszabályi	Alap: SZA, UTI, KOZ. Emelt: HIV.
MIN-02	A szolgáltató az üzleti és a fogyasztói vagy ingyenes szint feltételei közötti eltérést (tanítás, emberi felülvizsgálat, felelősség) egyértelműen közli, és az üzleti szintű védelmeket nem a felhasználó egyéni beállításától teszi függővé.	HIA-02	Hatósági elvárás	Alap: SZA, UTI, HIV, KOZ.
MIN-03	A szolgáltató az ügyféltartalom megőrzési idejét és annak okait (visszaélés-figyelés, jogszabály) szerződésben vagy kötelező erejű termékleírásban rögzíti, és az alapértelmezettnél hosszabb megőrzést (jelölt tartalom) csak előre közölt esetekben végzi.	HIA-04, HIA-15	Szakmai ajánlás	Alap: SZA, UTI, HIV, KOZ.
MIN-04	A szolgáltató az ügyféltartalomhoz emberi hozzáférést csak az ügyfél utasításán alapuló, szerződésben felsorolt szűk esetekben enged, erről az ügyfelet tájékoztatja, és érzékeny adatkörnél az emberi felülvizsgálat kizárását kérni lehet.	HIA-04	Jogszabályi	Alap: SZA, UTI. Emelt: HIV, KOZ.
MIN-05	A szolgáltató kérésre zero data retention vagy azzal egyenértékű nem tároló üzemmódot biztosít, amelynek kivételeit (visszaélés-figyelés, osztályozó-eredmények, állapotot tároló végpontok) a szerződés vagy a termékleírás pontosan felsorolja.	HIA-05	Szakmai ajánlás	Emelt: HIV. Ajánlott: SZA, UTI, KOZ.
MIN-06	A szolgáltató a szerződés megszűnésekor az ügyféltartalmat az ügyfél választása szerint visszaadja vagy törli, a másolatokat az alfeldolgozóknál is, szerződésben rögzített határidőn belül, és a törlésért felelősséget vállal.	HIA-03	Jogszabályi	Alap: SZA, UTI, KOZ. Emelt: HIV.
MIN-07	A szolgáltató a feldolgozás és tárolás helyét (régió, országok), a rendszer- és naplóadatokat is beleértve, szerződésben rögzíti, és az alapértelmezett működés ettől nem tér el (flex routing, globális telepítés, keresztrégiós inferencia csak az ügyfél kifejezett bekapcsolásával).	HIA-06	Szakmai ajánlás	Alap: SZA, UTI. Emelt: HIV, KOZ.
MIN-08	A szolgáltató személyes adatot az EGT-n kívülre csak az V. fejezet szerinti jogalap alapján továbbít, a jogalapot a szerződésben megnevezi, és a jogalap kiesése esetére tartalék jogalapot (például SCC) vállal.	HIA-07, HIA-06	Jogszabályi	Alap: SZA. Emelt: HIV, KOZ. Ajánlott: UTI.
MIN-09	A szolgáltató a harmadik országbeli hatóság adatkiadási kérelmét az ügyfélnek haladéktalanul jelenti, amennyiben jogszabály azt nem tiltja, és átláthatóan közli, hogyan kezeli az ilyen kérelmeket.	HIA-07	Jogszabályi	Alap: SZA, UTI. Emelt: HIV, KOZ.

MIN-10	A szolgáltató az alfeldolgozó igénybevételéhez az ügyfél előzetes felhatalmazását kéri (általános felhatalmazásnál előzetes tájékoztatással és kifogási lehetőséggel), és a nem teljesítő alfeldolgozóért teljes felelősséggel tartozik.	HIA-08	Jogszabályi	Alap: SZA. Emelt: HIV, KOZ. Ajánlott: UTI.
MIN-11	A szolgáltató az ügyféladatot nyugalmi és továbbítási állapotban a kockázattal arányosan titkosítja, és a konkrét eljárást (a piaci alapszint AES-256 és TLS 1.2 vagy újabb) a szerződésben rögzíti.	HIA-09	Jogszabályi	Alap: SZA, UTI, HIV, KOZ.
MIN-12	A szolgáltató az érzékeny adatkörnél ügyfél által kezelt titkosítási kulcsot (CMK) vagy ügyféloldali titkosítást tesz lehetővé, és a támogatott szolgáltatások körét (a CMK nélküli előzetes funkciókat is) közli.	HIA-09	Szakmai ajánlás	Alap: HIV, KOZ. Ajánlott: SZA, UTI.
MIN-13	A szolgáltató a használat közbeni védelmet (bizalmas számítástechnika) nyújtja, vagy kifejezetten közli, hogy a tartalom feldolgozás közben titkosítatlan.	HIA-09, HIA-04	Szakmai ajánlás	Alap: SZA, UTI, HIV, KOZ.
MIN-14	A szolgáltató az ügyfelek közötti adat- és munkamenet-izolációt műszakilag biztosítja, a RAG- és vektortároló hozzáférés-vezérlését is, és ezt vállalásként rögzíti.	HIA-17	Szakmai ajánlás	Alap: SZA, UTI, HIV, KOZ.
MIN-15	A szolgáltató az MI-specifikus támadások (prompt injection, kimeneti kiszivárogtatás, memorizáció) elleni védelmi gyakorlatát, például a red teaminget, dokumentálja, és az ügyfél kérésére átadja.	HIA-16	Szakmai ajánlás	Alap: HIV, KOZ. Ajánlott: SZA, UTI.
MIN-16	A szolgáltató az ügyfél rendelkezésére bocsátja a megfelelés igazolásához szükséges információt, és az auditot, a helyszíni vizsgálatot is beleértve, lehetővé teszi.	HIA-14	Jogszabályi	Alap: SZA, UTI, HIV. Emelt: KOZ.
MIN-17	A szolgáltató független tanúsítványait és auditjelentéseit (ISO 27001, SOC 2, C5) úgy adja át, hogy a tanúsítvány hatóköre az igénybe vett MI-szolgáltatásra is kiterjed, és a hatókört igazolja.	HIA-14, HIA-15	Szakmai ajánlás	Alap: SZA, UTI, HIV, KOZ.
MIN-18	A szolgáltató a szektorális felügyelet ellenőrzési jogát (az ügyfél belső ellenőrzése, adatvédelmi tisztviselője, könyvvizsgálója, a Felügyelet és az MNB) a szerződésben lehetővé teszi.	HIA-18, HIA-14	Jogszabályi	Alap: KOZ. Emelt: HIV. Ajánlott: SZA, UTI.
MIN-19	A szolgáltató a szerződésben visszafordíthatósági (reverzibilitási) záradékot vállal, amely az összes ügyféladat visszaadását lehetővé teszi.	HIA-18, HIA-03	Szakmai ajánlás	Emelt: HIV, KOZ. Ajánlott: SZA, UTI.
MIN-20	A szolgáltató az ügyfelet a biztonsági incidensről a tudomásszerzéstől számított indokolatlan késedelem nélkül, a szerződésben rögzített, órában mért	HIA-11	Jogszabályi	Alap: SZA, UTI. Emelt: HIV, KOZ.

	határidőn belül értesíti, és az értesítés a bejelentéshez szükséges adatokat tartalmazza.			
MIN-21	A szolgáltató felelősségkorlátozása nem zárja ki az adatvédelmi jogsértésből és az adatbiztonsági incidensből eredő károkat, vagy ezekre a várható kárral arányos külön plafont ír elő.	HIA-12	Hatósági elvárás	Emelt: HIV. Ajánlott: SZA, UTI, KOZ.
MIN-22	A szolgáltató adatvédelmi kártalanítást vállal a saját adatvédelmi jogsértéséből eredő harmadik fél és hatósági igényekre, nem csak szellemi tulajdoni kártalanítást.	HIA-13	Hatósági elvárás	Emelt: HIV. Ajánlott: SZA, UTI, KOZ.
MIN-23	A szervezet az MI-használatot adatosztályozás alapján engedélyezi, érzékeny adatot csak jóváhagyott, üzleti szintű szerződéses feltételekkel rendelkező szolgáltatói szinten enged, a fogyasztói és ingyenes szintet érzékeny adatra tiltja.	HIA-02	Szakmai ajánlás	Alap: SZA, UTI, HIV. Emelt: KOZ.
MIN-24	A szervezet a szolgáltatói feltételeket, a DPA-t és a tanúsítványok hatókörét az igénybevétel előtt és évente átvilágítja, és a szolgáltató C5- vagy azzal egyenértékű jelentését maga rendeli meg és elemzi.	HIA-14, HIA-15	Szakmai ajánlás	Alap: SZA, UTI, KOZ. Emelt: HIV.
MIN-25	A szervezet a nem szerződéses (dokumentációs) szolgáltatói vállalásokat, például a ZDR-t, a megőrzést és a feldolgozási helyet, szerződéses mellékletbe vagy megrendelőlapra emelteti, és a konkrét szerződés szövegét is ismeri.	HIA-15, HIA-05, HIA-06	Szakmai ajánlás	Alap: SZA, UTI, KOZ. Emelt: HIV.
MIN-26	A szervezet az MI-szolgáltatás bevezetése előtt adatvédelmi hatásvizsgálatot végez, ha különleges kategóriás adatot nagy számban kezel vagy az adatkezelés valószínűsíthetően magas kockázatú, és a hatásvizsgálatban a szolgáltatói vállalások kötőerejét is értékeli.	HIA-01, HIA-15	Jogszabályi	Alap: SZA. Emelt: HIV. Ajánlott: KOZ.
MIN-27	A szervezet külföldi adatkezelés vagy nem privát felhő igénybevétele előtt adatosztályozást, költség-haszon elemzést és kilépési tervet készít, és dokumentáltan igazolja a harmadik országbeli kezelésre vonatkozó előírások mérlegelését.	HIA-06, HIA-18	Jogszabályi	Emelt: HIV, KOZ. Ajánlott: SZA, UTI.
MIN-28	A szervezet az MI-szolgáltatót és annak ügyféladatot érintő közvetlen beszállítóit (alfeldolgozók, analitikai és kiszolgáló szolgáltatók) az ellátási lánc kockázatkezelésébe bevonja, és a változásokat figyeli.	HIA-08	Jogszabályi	Emelt: HIV, KOZ. Ajánlott: SZA, UTI.
MIN-29	A szervezet minősített adatot csak a Nemzeti Biztonsági Felügyelet engedélye alapján, a közreműködő védelmi feltételeinek előzetes ellenőrzése után ad át MI-szolgáltatónak.	HIA-18, HIA-06	Jogszabályi	Emelt: KOZ.

MIN-30	A szervezet hivatásbeli titok átadása előtt a szakmai szabályok szerinti feltételeket biztosítja: banktitoknál a kiszervezési kivételt vagy az ügyfél felhatalmazását, ügyvédi titoknál a MÜK ajánlása szerinti adatfeldolgozási megállapodást.	HIA-08, HIA-01	Jogszabályi	Emelt: HIV.

MELLÉKLET

Forrásanyagok

A források lezárásának dátuma: 2026. október 29. Minden hivatkozás az eredeti, hivatalos lelőhelyre mutat. A melléklet kizárólag külső, nyilvános forrásokat tartalmaz. Megbízhatóság: **M** = magas (hivatalos, lektorált vagy elsődleges intézményi forrás), **K** = közepes (érdekelt fél saját közlése).

Hazai források

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
EUAK	1997. évi XLVII. tv. (egészségügyi adatok)	NJT	–	M
HPT	2013. évi CCXXXVII. tv. (Hpt.)	NJT	–	M
INFOTV	2011. évi CXII. tv. (Info tv.)	NJT	–	M
KIBTV	2024. évi LXIX. tv. (kiberbiztonság)	NJT	–	M
KORM-344-2025	344/2025. (X. 31.) Korm. rendelet	NJT	2025.10.31.	M
KORM-418-2024	418/2024. (XII. 23.) Korm. rendelet (a kiberbiztonsági tv. végrehajtása)	NJT	2024.12.23.	M
KORMHAT-1369-2025	1369/2025. Korm. határozat (magyar multimodális adatbázis)	NJT	–	M
MAVTV	2009. évi CLV. tv. (minősített adat)	NJT	–	M
MI-VH-TV	2025. évi LXXV. tv. (MI-rendelet végrehajtása)	NJT	–	M
MNB-2-2025	MNB 2/2025. (I.13.) ajánlás a felhőszolgáltatásokról	MNB	2025.01.13.	M
MUK-4-2026	MÜK Elnökség 4/2026. (VII.13.) Szakmai Álláspontja az MI-alapú átirat használatáról (és Ajánlás)	MÜK	2026.07.13.	M
NAIH-BANK-MI	NAIH-jelentés a magyarországi bankok MI-használatáról	NAIH	2025.12.22.	M
OGYK-IJ-2025-29	OGYK infojegyzet 2025/29 – MI-rendelet végrehajtása	Országgyűlési Könyvtár	–	M
UTTV	2017. évi LXXVIII. tv. (ügyvédi tevékenység)	NJT	–	M
UZLETI-TITOK-TV	2018. évi LIV. tv. (üzleti titok)	NJT	–	M

Uniós források

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
AIA	AI Act (EU) 2024/1689	EP és Tanács	–	M
AILD-WITHDRAWAL	MI-felelősségi irányelv-javaslat (2022/0303(COD)) visszavonása, HL C/2025/5423	Bizottság	2025.10.06.	M
BRUSSELS-IA	Brüsszel Ia rendelet 1215/2012	EP és Tanács	–	M
CSA-REV-COM11	Kiberbiztonsági Aktus felülvizsgálata COM(2026) 11	Bizottság	–	M
DATA-ACT	Data Act (EU) 2023/2854	EP és Tanács	–	M
EC-GPAI-GL	Bizottsági iránymutatás a GPAI-modellek szolgáltatóinak kötelezettségei hatályáról, C(2025) 7719 final (AI Act)	Európai Bizottság	2025.11.19.	M
EDPB-CHATGPT-TF	EDPB ChatGPT Taskforce jelentés	EDPB	2024.05.23.	M
EDPB-GL07-2020	EDPB Guidelines 07/2020 (adatkezelő/adatfeldolgozó)	EDPB	–	M
EDPB-OP28	EDPB Opinion 28/2024 (MI-modellek)	EDPB	–	M
EDPB-SPE-LLM	EDPB SPE – AI Privacy Risks & Mitigations: LLMs	EDPB (külső szakértő)	–	M
EU-CLOUD-SOV-COM502	Felhő-szuverenitási keret javaslata COM(2026) 502	Bizottság	–	M
EU-CYBERPKG-QA	Cybersecurity Package – Q&A	Bizottság	–	M
EU-US-DPF	EU–USA DPF megfelelőségi határozat (EU) 2023/1795	Bizottság	–	M
EUB-C200-23	C-200/23	Európai Unió Bírósága	–	M
EUB-C300-21	C-300/21 Österreichische Post	Európai Unió Bírósága	–	M
EUB-C311-18	C-311/18 Schrems II	Európai Unió Bírósága	–	M
EUB-C319-20	C-319/20 Meta Platforms Ireland	Európai Unió Bírósága	–	M

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
EUB-C340-21	C-340/21 Natsionalna agentsia za prihodite	Európai Unió Bírósága	–	M
EUB-C498-16	C-498/16 Schrems (Facebook, fogyasztói joghatóság)	Európai Unió Bírósága	–	M
EUB-C655-23	C-655/23	Európai Unió Bírósága	2025.09.04.	M
EUB-C667-21	C-667/21 Krankenversicherung Nordrhein	Európai Unió Bírósága	–	M
EUB-C683-21	C-683/21 Nacionalinis visuomenės sveikatos centras	Európai Unió Bírósága	–	M
EUB-C687-21	C-687/21 MediaMarktSaturn	Európai Unió Bírósága	–	M
EUB-C703-25P	C-703/25 P Latombe-fellebbezés (HL-közlemény)	Európai Unió Bírósága	2025.10.31. (benyújtás)	M
EUB-C741-21	C-741/21 juris	Európai Unió Bírósága	–	M
EUB-C807-21	C-807/21 Deutsche Wohnen	Európai Unió Bírósága	–	M
EUB-T553-23	T-553/23 Latombe	Törvényszék	2025.09.03.	M
GDPR	GDPR (EU) 2016/679	EP és Tanács	–	M
GPAI-COP	GPAI Code of Practice	AI Office	–	M
NIS2	NIS2 (EU) 2022/2555	EP és Tanács	–	M
OMNIBUS-AI-2026-1744	Digital Omnibus on AI – (EU) 2026/1744 rendelet	EP és Tanács	2026.07.24. (HL L), hatály: 2026.07.27.	M
OMNIBUS-DATA-COM837	Digital Omnibus (adat/GDPR/ePrivacy) COM(2025) 837, 2025/0360(COD)	Bizottság / EP	–	M
PLD-2024	Új termékfelelősségi irányelv (EU) 2024/2853	EP és Tanács	–	M
RAD	Képviseleti keresetek irányelv 2020/1828	EP és Tanács	–	M
ROME-I	Róma I rendelet 593/2008	EP és Tanács	–	M
SCC	SCC – (EU) 2021/914	Bizottság	–	M

Nemzetközi források

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
ALEPH-COHERE	Aleph Alpha – Cohere-megállapodás	Aleph Alpha	aláírva: 2026.09.16.	K
ALEPH-PGA	Aleph Alpha – Pharia Government Assistant	Aleph Alpha	–	K
ALEPH-STACKIT	Aleph Alpha – STACKIT partnerség	Aleph Alpha	–	K
ANSSI-BSI-LLM-ZT	ANSSI–BSI – LLM-rendszerek zero-trust tervezési elvei	BSI és ANSSI	–	M
ANSSI-CLOUD-SENS	ANSSI – érzékeny IS felhőben	ANSSI	–	M
ANSSI-GENAI-PA102	ANSSI – generatív MI biztonsági ajánlások (PA-102)	ANSSI	2024.04.29.	M
ANSSI-SECNUMCLOUD	SecNumCloud v3.2	ANSSI	v3.2	M
ANSSI-SNC-FAQ	ANSSI – Cloud / SecNumCloud FAQ	ANSSI	mentve 2026.10.29.	M
ANT-CONSUMER-F	Anthropic – Consumer Terms	Anthropic	–	K
ANT-CT	Anthropic – Commercial Terms	Anthropic	hatály: 2025.06.17.	K
ANT-DPA	Anthropic – DPA	Anthropic	hatály: 2025.02.24.	K
ANT-RETENTION	Anthropic – Privacy Center: megőrzési idők	Anthropic	2026.07.01.	K
ANT-TRUST	Anthropic – Trust Center	Anthropic	–	K
ANT-ZDR	Anthropic – Privacy Center: a ZDR hatóköre	Anthropic	–	K
AP-CLEARVIEW-HAT	AP – Clearview bírság (határozat)	AP (NL)	–	M
AP-CLEARVIEW-PK	AP – Clearview sajtóközlemény	AP (NL)	–	M

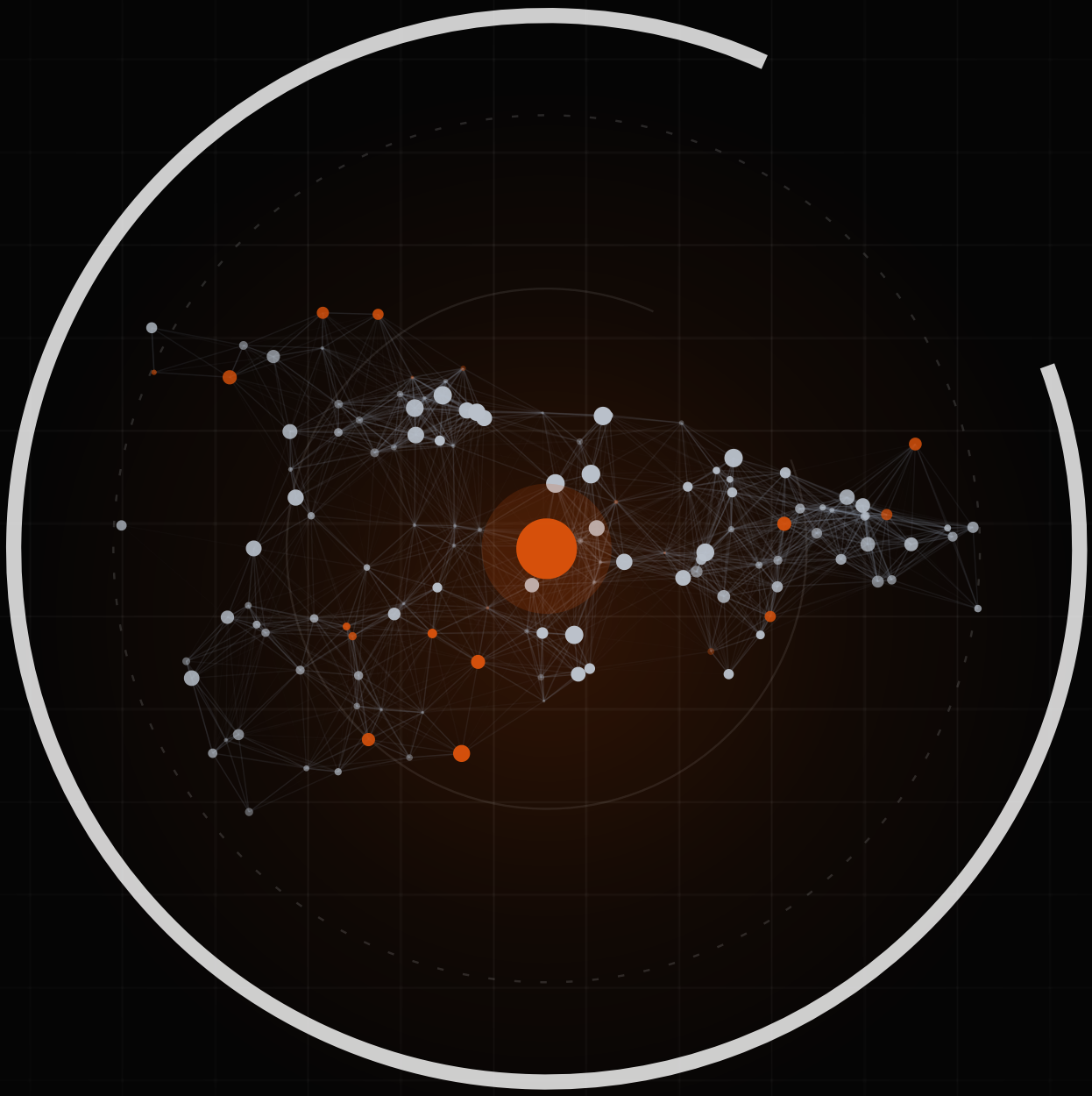
KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
AWS-BDP	AWS – Data protection in Amazon Bedrock	AWS	–	K
AWS-BEDROCK-ABUSE	AWS – Bedrock abuse detection	AWS	–	K
AWS-BEDROCK-RETENTION	AWS – Bedrock data retention	AWS	–	K
AWS-DPA	AWS – GDPR DPA	AWS	–	K
AWS-PRIVACY-FAQ	AWS – Data Privacy FAQ	AWS	–	K
AWS-SVC-TERMS	AWS – Service Terms (Bedrock)	AWS	–	K
BSI-C5	BSI C5 áttekintő	BSI	–	M
BSI-C5-2026	BSI C5:2026	BSI	–	M
BSI-GENAI	BSI – Generative AI Models: Opportunities and Risks	BSI	2025.01. (frissítés)	M
BSI-KRIT-GENKI	Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen	BSI	1.0, 2025.6.6.	M
BSI-MINDEST-CLOUD	BSI Mindeststandard externe Cloud-Dienste v2.1	BSI	v2.1	M
CCBE-GENAI	CCBE guide on the use of generative AI by lawyers	CCBE	2025.10.02.	M
CCBE-TECH	CCBE technical guide on the use of AI tools and models by lawyers	CCBE	2026.03.27.	M
CNIL-INTERET-LEG	CNIL – jogos érdek MI-fejlesztésnél	CNIL	–	M
CNIL-STATUT-MODELE	CNIL – MI-modell GDPR szerinti státuszának elemzése (+ Genmod-eszköz, + nyílt forráskódú gyakorlatok elemző jegyzete)	CNIL	2025.7.22. (Genmod: 2026.8.26., jegyzet: 2024.6.)	M

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
DEEPSEEK-LIC	DeepSeek License Agreement 1.0 (V3) és MIT licenc (R1)	DeepSeek	1.0, 2023.10.23. (V3)	K
ETSI-EN-304223	ETSI EN 304 223 V2.1.1: Securing AI (SAI), Baseline Cyber Security Requirements for AI Models and Systems	ETSI	V2.1.1, 2025.12.	M
GARANTE-DEEPSEEK	Garante – DeepSeek	Garante	–	M
GARANTE-OPENAI	Garante – OpenAI-határozat (755/2024., 15 M EUR)	Garante	–	M
GARANTE-REPLIKA	Garante – Replika	Garante	–	M
GCP-DPA	Google Cloud – DPA	Google	–	K
GCP-TERMS	Google Cloud Terms / Service Specific Terms	Google	–	K
GCP-VERTEX-GOV	Vertex AI – generative AI data governance	Google	–	K
GOOG-GEMINI-API	Gemini API Additional Terms (ingyenes vs. fizetős)	Google	–	K
GOOG-GEMMA-TOU	Gemma Terms of Use, Prohibited Use Policy és Gemma 4 Apache 2.0 oldal	Google	2026.4.1. (ToU és Apache-oldal)	K
HF-SEC-PICKLE	Hugging Face Hub: Security és Pickle Scanning (+ Safetensors dokumentáció)	Hugging Face	–	M
HMBBFDI-LLM	HmbBfDI vitairat: nagy nyelvi modellek és személyes adatok	Hamburgi adatvédelmi és információszabadság-biztos (HmbBfDI)	2024.7.	M
IONOS-DATA	IONOS AI Model Hub – Data Handling	IONOS	–	K
META-LLAMA-LIC	Llama 3.3 Community License Agreement és AUP, Llama 3.2 AUP, Llama 4 Community License Agreement és AUP	Meta Platforms Ireland Ltd. (EGT, Svájc), Meta Platforms, Inc.	3.3: 2024.12.6., 4: 2025.4.5.	K
MIS-CT	Mistral – Commercial Terms	Mistral	hatály: 2026.09.25.	K

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
MIS-DPA	Mistral – DPA	Mistral	2026.03.12.	K
MIS-GOV-HELP	Mistral – Data Governance súgó	Mistral	–	K
MIS-OPEN-LIC	Mistral nyílt modellek licencei: Apache 2.0, módosított MIT (súgó, Mistral 3 bejelentés, modellkártyák)	Mistral AI, Apache Software Foundation	2025.12.2. (Mistral 3)	K
MIS-PRIVACY	Mistral – Privacy Policy	Mistral	–	K
MIS-ZDR	Mistral – ZDR dokumentáció	Mistral	–	K
MSFT-AOAI-ABUSE	Azure OpenAI – abuse monitoring	Microsoft	–	K
MSFT-CCC	Microsoft – Customer Copyright Commitment	Microsoft	–	K
MSFT-DPA	Microsoft – Products and Services DPA	Microsoft	–	K
MSFT-EUDB	Microsoft – EU Data Boundary	Microsoft	–	K
MSFT-FDP	Microsoft – Foundry/Azure OpenAI data privacy	Microsoft	2026.06.05.	K
MSFT-M365-COPILOT	Microsoft 365 Copilot – Data, Privacy, Security	Microsoft	ms.date: 2026-07-09	K
MSFT-M365-FLEX	Microsoft 365 Copilot – Flex routing	Microsoft	ms.date: 2026-09-29	K
MSFT-STP	Microsoft – Service Trust Portal	Microsoft	–	K
MSRC-CVE-2025-32711	M365 Copilot Information Disclosure – CVE-2025-32711 ("EchoLeak")	MSRC	2025.06.11.	M
NCSC-SECAI-DEV	Guidelines for secure AI system development	UK NCSC, CISA és nemzetközi partnerek	2023	M
NIST-600-1	NIST AI 600-1 Generative AI Profile	NIST	–	M
NSA-DEPLOY-AI	Deploying AI Systems Securely (CSI)	NSA AISC, CISA, FBI, ASD ACSC, CCCS, NCSC-NZ, NCSC-UK	2024.4.15.	M

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
OAI-BDP	OpenAI – Business data privacy	OpenAI	–	K
OAI-DATA-CTRL	OpenAI – Data controls in the OpenAI platform	OpenAI	–	K
OAI-DPA	OpenAI – DPA	OpenAI	2025.12.01. (hatály: 2026.01.01.)	K
OAI-ENT-PRIV	OpenAI – Enterprise privacy	OpenAI	2026.01.08.	K
OAI-INC-MIXPANEL	OpenAI – Mixpanel-incidens	OpenAI	2025	M
OAI-INC-REDIS	OpenAI – 2023. márciusi Redis-hiba	OpenAI	2023.03.	M
OAI-SA	OpenAI – Services Agreement	OpenAI	–	K
OAI-TOU-F	OpenAI – Terms of Use	OpenAI	–	K
OAI-TRUST	OpenAI – Trust Portal	OpenAI	–	K
OVH-AIE	OVHcloud AI Endpoints – termékoldal	OVHcloud	–	K
OVH-AIE-CAP	OVHcloud AI Endpoints – képességek	OVHcloud	–	K
OWASP-LLM	OWASP Top 10 for LLM Applications 2025	OWASP	2025	M
QWEN-LIC	Qwen LICENSE AGREEMENT (Qwen2.5-72B) és Qwen3-8B modellkártya	Alibaba Cloud, Qwen	2024.9.19. (Qwen2.5-72B)	K
STACKIT-AIMS	STACKIT AI Model Serving	STACKIT	–	K
STACKIT-CERTS	STACKIT – tanúsítványok	STACKIT	–	K
STACKIT-FAQ	STACKIT – FAQ	STACKIT	–	K
STACKIT-SVC-CERT	STACKIT – Service Certificate	STACKIT	–	K
TRIB-ROMA-4153-26	Tribunale di Roma, 4153/2026. sz. ítélet (R.G. 4785/2025) – az E1 megsemmisítése	Tribunale di Roma (egyetemi tárhelyen)	2026.03.18.	M

KÓD	FORRÁS	KIADÓ	DÁTUM	MEGB.
WIZ-DEEPSEEK	DeepSeek nyilvános adatbázis (Wiz Research)	Wiz	–	M



VAKZÓNA

Ami kimarad a látómezőből.

vakzona.com

ELEMZÉS	VERZIÓ	DÁTUM	ONLINE
Odaadjuk, de mi lesz vele?	1.0	2026. október 31.	vakzona.com/elemzesek/mi-adatvedelmi-garanciak